Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность): 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА
Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)

Спажакина Святослава Игоревича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Методы активного обнаружения узлов и сервисов»

Состав выпускной квалификационной работы:
Расчетно-пояснительная записка на 126 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:
Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (Р.С. Лопатин)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ С.И. Спажакин
(подпись) (инициалы, фамилия)

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки/специальность 10.05.03 Информационная безопасность автоматизированных систем
(код, наименование)
Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)
Зав.кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Спажакину Святославу Игоревичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Методы активного обнаружения узлов и сервисов»
по заданию какой организации выполняется работа

приказ №01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.2025

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Исследование действующих баз данных и актуальных стандартов по защите информации
Раздел 2. Установление взаимосвязи шаблонов атак CAPEC с эксплуатируемыми ими уязвимостями
Раздел 3. Моделирование сценариев атак для заданных шаблонов на основе последовательности реализации техник MITRE ATT&CK
Раздел 4. Противодействие инцидентам информационной безопасности

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03-22.05
2	Исследование действующих баз данных и актуальных стандартов по защите информации	22.03-22.05
3	Установление взаимосвязи шаблонов атак CAPEC с эксплуатируемыми ими уязвимостями	23.05-31.05
4	Моделирование сценариев атак для заданных шаблонов на основе последовательности техник MITRE ATT&CK	01.06-12.06
5	Противодействие инцидентам информационной безопасности	13.06-24.06
6	Заключение	25.06-02.07

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Спажакина Святослава Игоревича

Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Методы активного обнаружения узлов и сервисов»

Характеристика выпускной квалификационной работы

Актуальность исследования

В рамках исследования рассматривается проблема обеспечения защищённости автоматизированных информационных систем от атак класса «Методы активного обнаружения узлов и сервисов». Для её решения предлагается создание единой базы данных деструктивна, которая может быть использована при формировании политик информационной безопасности.

Задачи, решаемые в ВКР

− организация сбора и обобщения данных из открытых интернет-источников по парам «атака – уязвимость» в контексте автоматизированных информационных систем;

− установление соответствия между кибератаками класса «Методы активного обнаружения узлов и сервисов» и уязвимостями в автоматизированных информационных системах, включая сценарное описание атак;

− проведение оценки рисков нарушения информационной безопасности в результате реализации кибератак класса «Методы активного обнаружения узлов и сервисов» с использованием уязвимостей в автоматизированных информационных системах;

− разработка регламентов реагирования и ликвидации последствий кибератак класса «Методы активного обнаружения узлов и сервисов» для обеспечения безопасности автоматизированных информационных систем.

Структура ВКР

Введение – 8 страниц;

Раздел 1. Исследование действующих баз данных и актуальных стандартов по защите информации – 15 страниц;

Раздел 2. Установление взаимосвязи шаблонов атак CAPEC с эксплуатируемыми ими уязвимостями – 13 страниц;

Раздел 3. Моделирование сценариев атак для заданных шаблонов на основе последовательностей реализации техник MITRE ATT&CK – 37 страниц;

Раздел 4. Противодействие инцидентам информационной безопасности – 9 страниц;

Заключение – 3 страницы;

Список литературы – 11 страниц;

Приложение А – 18 страниц;

Приложение Б – 4 страницы.

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Исследование действующих баз данных и актуальных стандартов по защите информации.

Собранные данные из открытых источников позволили проанализировать проблемы противодействия атакам класса «Методы активного обнаружения узлов и сервисов» в контексте обеспечения защиты автоматизированных информационных систем.

Раздел 2. Установление взаимосвязи шаблонов атак CAPEC с эксплуатируемыми ими уязвимостями.

Установление взаимосвязей между шаблонами атак и уязвимостями позволило дать критическую оценку имеющимся слабым местам автоматизированных систем в случае реализации атак класса «Методы активного обнаружения узлов и сервисов».

Раздел 3. Моделирование сценариев атак для заданных шаблонов на основе последовательности реализации техник MITRE ATT&CK.

Составленные сценарии наглядно демонстрируют возможность использования определённых техник в сочетании с уязвимостями при реализации атак класса «Методы активного обнаружения узлов и сервисов» в автоматизированной информационной системе.

Раздел 4. Противодействие инцидентам информационной безопасности.

Были разработаны регламенты реагирования на инциденты информационной безопасности и ликвидации их последствий, направленные на противодействие атакам класса «Методы активного обнаружения узлов и сервисов» с целью обеспечения защиты автоматизированных информационных систем.

Автор ВКР_____Спажакин Святослав Игоревич
(подпись)

СОДЕРЖАНИЕ

Обозначения и сокращения 7
Введение 8
1. Исследование действующих баз данных и актуальных стандартов по защите информации 16
1.1 Анализ баз данных CAPEC, MITRE ATT&CK, NVD, БДУ ФСТЭК и Российских стандартов 16
1.2 Исследование риск-калькуляторов CVSS, EPSS и OWASP 23
2. Установление взаимосвязи шаблонов атак CAPEC с эксплуатируемыми ими уязвимостями 31
2.1 Специфика атак класса «Методы активного обнаружения узлов и сервисов» . 31
2.2 Паспортизация шаблонов атак класса «Методы активного обнаружения узлов и сервисов» 34
3. Моделирование сценариев атак для заданных шаблонов на основе последовательности реализации техник MITRE ATT&CK 44
3.1 Оценка параметров эксплуатируемых уязвимостей 44
3.2 Анализ модели реализации техник сценариев атак 60
4. Противодействие инцидентам информационной безопасности 81
4.1 Регламенты реагирования и ликвидации последствий 81
4.2 Регулирование рисков 84
Заключение 90
Список литературы 93
Приложение А 104
Приложение Б 122

Обозначения и сокращения

АИС – Автоматизированная информационная система;

ЛВС – Локальная вычислительная сеть;

ПО – Программное обеспечение;

ОС – Операционная система;

ИБ – Информационная безопасность;

CAPEC - Common Attack Pattern Enumerations and Classifications (с англ. Перечень и Классификация Распространенных Шаблонов Атак);

MITRE ATT&CK - Adversarial Tactics, Techniques, and Common Knowledge (с англ. Тактики, Техники и Общеизвестные факты о злоумышленниках);

БДУ ФСТЭК России - Банк данных угроз безопасности информации ФСТЭК России;

NVD - National Vulnerability Database (с англ. Национальная база данных об уязвимости);

CISA KEV - Cybersecurity and Infrastructure Security Agency Known Exploited Vulnerabilities (с англ. Агентство по кибербезопасности и защите инфраструктуры Известные используемые уязвимости);

CWE - Common Weakness Enumeration (с англ. Перечень общих недостатков);

CVE - Common Vulnerabilities and Exposures (с англ. Известные уязвимости и дефекты безопасности);

СЗИ - Средства защиты информации;

ВВК – Выполнение вредоносного кода;

ВПО – Вредоносное программное обеспечение.

ВВЕДЕНИЕ

В современной России значительное внимание уделяется развитию цифровых технологий и – вопросам обеспечения их информационной безопасности, вредоносное программное обеспечение остается основным инструментом для осуществления киберпреступлений. Оно использовалось в 65% успешных атак на организации и в 72% случаев против частных лиц. Наиболее распространёнными типами вредоносного ПО в атаках на организации стали программы удалённого управления (44%) и шифровальщики (44%). Против частных лиц чаще всего применялось шпионское ПО (47%). Для частных лиц социальная инженерия остается ключевой угрозой (92% случаев) и используется в каждом втором случае (50%) при атаках на организации. Утечки конфиденциальных данных были зафиксированы более чем в половине (52%) успешных атак на организации и в 77% случаев против частных лиц. Нарушение нормальной деятельности организаций наблюдалось на 5% чаще по сравнению с предыдущим периодом, что связано с ростом активности групп вымогателей [1-8].

При этом, в сфере информационных технологий России наблюдается дефицит квалифицированных кадров, который оценивается на уровне 700 тыс. человек [4-9]. Такая ситуация создаёт благоприятные условия для злоумышленников, которые могут использовать фиктивные собеседования с целью внедрения вредоносного программного обеспечения. Для снижения этих рисков, компаниям и организациям предоставляются различные базы данных уязвимостей и калькуляторы [10-19], позволяющие самостоятельно оценивать критичность возникающих угроз.

С учётом вышеизложенного настоящее исследование нацелено на корпоративные сети, производственную инфраструктуру [20-27], сети общего назначения, малые и средние организации, а также межсетевое киберпространство, включая формирование сценарных моделей для рассматриваемого класса кибератак, где предметом исследования выступают оценка и регулирование информационных рисков [28,29], а также меры обеспечения информационной безопасности [30-35].

Атаки класса «Методы активного обнаружения узлов и сервисов», деструктивное воздействие которых рассматривается в данной работе, являются ключевой составляющей современных методик проведения кибератак на объекты информатизации. Проблема противодействия данному классу угроз остаётся актуальной и по сей день, поскольку такие атаки широко применяются злоумышленниками на всех уровнях – от малых корпоративных сетей до межнациональных инфраструктур провайдеров [36-40].

За первое полугодие 2025 года, количество атак, относящихся к данному классу, демонстрирует значительный рост [41-43]. Согласно последнему отчёту Verizon Data Breach Investigations Report (DBIR), зафиксировано увеличение числа атак с использованием критических уязвимостей, обнаруживаемых на этапе анализа системы, составившее почти 180% [44].

За последние годы увеличилось количество случаев использования вредоносного программного обеспечения, способного самостоятельно обнаруживать и анализировать сетевые узлы и сервисы [45-48]. К началу 2025 года такие схемы функционировали в нескольких направлениях. Основными векторами атак были:

1) Почтовый фишинг – данный вектор остаётся одним из наиболее распространённых, демонстрируя рост более чем на 30 % по сравнению с предыдущими годами;

2) Фишинг направленный на приложения и установление туннелей (VPN) – несмотря на сравнительно низкую активность (около 5 %), метод остаётся актуальным в контексте целевых атак;

3) Эксплойты веб приложений – занимают значительную долю среди современных угроз, составляя около 23 % всех инцидентов [49-50];

В соответствии с данными MITRE ATT&CK, первой и одной из ключевых фаз кибератаки является сбор информации, или рекогносцировка. На данном этапе злоумышленник получает данные об инфраструктуре цели, её слабых местах и возможных путях проникновения. Именно в эту фазу вписывается класс атак, известный как «Методы активного обнаружения узлов и сервисов», являющийся отправной точкой для последующих действий против системы защиты объекта.

Согласно стратегии кибербезопасности CISA на 2024–2026 годы, данный класс атак относится к первому этапу – «Решение первоочередных угроз». В рамках этой стратегии особое внимание уделяется раннему обнаружению подобной активности. Такие инциденты должны выявляться на ранних стадиях и оперативно локализовываться при взаимодействии с квалифицированными специалистами в области кибербезопасности [51-55].

Изложенное выше непосредственно относится к шаблонам кибератак класса «Методы активного обнаружения узлов и сервисов». Из этого следует, что данные угрозы остаются актуальными и демонстрируют значительный рост по сравнению с другими типами атак, что подтверждает необходимость их детального изучения и совершенствования методов защиты [56-60].

На основании данных международной цифровой библиотеки по исследованиям кибербезопасности IEEE Xplore [61-64] наблюдается, что атаки класса «Методы активного обнаружения узлов и сервисов» служат начальным этапом, создающим предпосылки для более серьёзных последующих действий со стороны злоумышленников. Одним из ключевых аспектов данного класса угроз является разнообразие используемых сетевых протоколов [65-68], что значительно усложняет их обнаружение и нейтрализацию.

Указанные методы подразделяются на две основные подкатегории:

1) Статический мониторинг – осуществляется с использованием заранее заданной общей конфигурации сканирования и анализа сетевой среды;

2) Динамический мониторинг – предполагает использование гибких алгоритмов и сетевых графиков, позволяющих адаптироваться к изменяющейся инфраструктуре [69].

Описанные методы могут применяться в различных сетевых средах – от локальных корпоративных сетей до распределённых мультисервисных инфраструктур. Однако действующие нормативные и методические документы, предназначенные для оценки угроз, связанных с такими атаками, зачастую не соответствуют современным требованиям кибербезопасности. Это может привести к

некорректной оценке рисков и формированию ошибочного представления о модели политики информационной безопасности.

Существующие подходы к оценке эффективности защитных мер и вероятности эксплуатации уязвимостей на различных этапах кибератаки уступают по качеству разработанным в рамках данного исследования вероятностным сценариям. Аналоги не могут продемонстрировать специалистам информационной безопасности тактики и техники, которые применяются злоумышленником при выполнении этапов атак, а также не показывают, какие варианты действий он может совершить на следующем этапе [70-74].

Кроме того, анализирование других работ показало, что отсутствие расчётов критичности по актуальным риск-калькуляторам отрицательно влияет на оказание услуг по информационной безопасности, большая часть которых будет некорректно работать на объекте. Требуется так же сказать, что нормативно-правовые регламенты, составленные по итогам данной работы, обеспечивают действенную защиту от выбранных векторов атак ввиду наличия в них конкретных мер по реагированию на регистрируемые инциденты и последующих действий по ликвидации последствий от этих инцидентов. Аналоги данные меры предложить не могут ввиду обобщенности способов защиты и отсутствия необходимой конкретики относительно тактики, избранной злоумышленником.

Целеполагание настоящего исследования предполагает, что:

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Методы активного обнаружения узлов и сервисов».

Предметом исследования процессы обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Методы активного обнаружения узлов и сервисов», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию

подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышении защищенности автоматизированных информационных систем от атак класса «Методы активного обнаружения узлов и сервисов» [75-85].

Исследование аналогов показало наличие ряда **противоречий** между:

– необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака - уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Методы активного обнаружения узлов и сервисов»;

– потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

– существующей методологией вероятностной оценки опасности кибератак класса «Методы активного обнаружения узлов и сервисов» использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

– несовершенством процедур регламентации противодействия кибератакам класса «Методы активного обнаружения узлов и сервисов» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи**:

– организация, сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Методы активного обнаружения узлов и сервисов» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Методы активного обнаружения узлов и сервисов» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы активного обнаружения узлов и сервисов» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

– структурированы база данных кибератак класса «Методы активного обнаружения узлов и сервисов» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Методы активного обнаружения узлов и сервисов», с учётом специфики используемых злоумышленников сценариев;

– комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Методы активного обнаружения узлов и сервисов» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

– в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Методы активного обнаружения узлов и сервисов», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

– впервые для класса кибератак «Методы активного обнаружения узлов и сервисов» была предложены обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

– в отличии от аналогов предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Методы активного обнаружения узлов и сервисов», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

– для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Методы активного обнаружения узлов и сервисов».

Практическая ценность полученных результатов видится в том, что:

− созданная база данных метрик кибератак класса «Методы активного обнаружения узлов и сервисов» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

− сформированное множество сценариев и их рисканализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Методы активного обнаружения уязвимостей и сервисов»;

− предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Методы активного обнаружения узлов и сервисов», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

− предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Методы активного обнаружения узлов и сервисов» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

− сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

− разработанные сценарии атак класса «Методы активного обнаружения узлов и сервисов» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

− представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Методы активного обнаружения узлов и сервисов», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

− в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Методы активного обнаружения узлов и сервисов» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1. Исследование действующих баз данных и актуальных стандартов по защите информации

1.1 Анализ баз данных CAPEC, MITRE ATT&CK, NVD, БДУ ФСТЭК и Российских стандартов

В российской нормативно-правовой базе регламентация мер защиты и обеспечения информационной безопасности для автоматизированных информационных систем построена на стандартах классификации АИС. Для каждого класса приводятся определённые меры по защите информации. Данные меры направленны на закрытые обобщённых слабых сторон АИС.

Основные подсистемы, которые рассматриваются в руководящем документе по классификации АИС:

1) Подсистема управления доступом – в данной подсистеме указаны меры, которые должны разграничивать политику доступа;

2) Подсистема регистрации и учёта – данная подсистема направлена на выполнение функций аутентификации и идентификации пользователей, служб, работающих в системе;

3) Криптографическая подсистема – направлена на обеспечение безопасности методами шифрования;

4) Подсистема обеспечения целостности – нацелена на обеспечение сохранности данных и информации в любом виде.

Данные подсистемы закрывают широкий пласт уязвимых мест. Однако они не описывают методы борьбы с определёнными уязвимостями или определёнными классами атак.

Также в российской нормативно-правовой базе огромную роль играют стандарты по защите информации. На их основе разрабатываются политики безопасности автоматизированных информационных систем. К вниманию рассмотрим такие стандарты:

1) ГОСТ 53113.1 – 2008 Информационная технология. Защита информационных технологий и автоматизированных систем от угроз

информационной безопасности, реализуемых с использованием скрытых каналов. Часть 1. Общие положения;

2) ГОСТ 53113.2 – 2009 Информационная технология. Защита информационных технологий и автоматизированных систем от угроз информационной безопасности, реализуемых с использованием скрытых каналов. Часть 2. Рекомендации по организации защиты информации, информационных технологий и автоматизированных систем от атак с использованием скрытых каналов;

3) ГОСТ 51583 – 2014 Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения.

Рассматривая вышеуказанные стандарты, приходим к выводу, что в них разбираются только обобщённые методы противодействия. На рассмотрение приводят:

– правила формирования модели угроз безопасности – в них учитываются оценки рисков ИБ, угрозы внедрения разнообразных вредоносных ПО;

– порядок организации защиты информации, информационных технологий и автоматизированных систем – в нём рассматривают этапы проектирования архитектуры защиты и разработки политики безопасности организации;

– анализ рисков – в данном разделе производится работа по противодействию угрозам безопасности.

Нормы и требования, установленные в соответствующих ГОСТах, направлены на формирование политик информационной безопасности в организациях различных отраслевых направлений. Представленные методы в обобщённом виде позволяют устранить существующие уязвимые места в автоматизированных информационных системах и локальных вычислительных сетях. При этом изложенные меры в большей степени ориентированы на создание защищённой инфраструктуры с нуля при условии, что организация располагает актуальным и технически обновлённым парком оборудования.

Общей проблемой приведённых стандартов и руководящего документа классификации АИС является отсутствие непосредственно разработанных мер противодействия классу атак «Методы активного обнаружения узлов и сервисов». Не менее важным является разбор непосредственных уязвимостей, которые также не приводятся в стандартах.

Исходя из выше сказанного требуется рассмотреть открытые источники данных и на их основе разработать базу данных, на основе которой имеется возможность моделирования типовых атак и реализации мер по противодействию им.

Базы данных играют ключевую роль в описании и устранении уязвимостей и связанных с ними угроз. В качестве общеизвестных баз данных выступают CAPEC, MITRE ATT&CK, NVD и БДУ ФСТЭК России. В них содержится информация об уязвимостях и связанных с ними рисках. Все данные предоставляются в структурированном виде: последовательно описываются атаки, тактики злоумышленников и конкретные уязвимости программного обеспечения. На данных источниках строится основа построения политик безопасности, комплексного обеспечения защиты автоматизированных информационных систем.

Встают вопросы: какие базы данных использовать? В каких случаях лучше обращаться к другим базам данных? И наконец: как требуется их использовать, чтобы повысить защищённость информации? На эти вопросы будет дан ответ в этой главе.

Базы данных уязвимостей (Vulnerability Databases, VDB) и базы данных угроз (Threat Intelligence Feeds) – это специализированные хранилища информации о киберугрозах, эксплойтах, уязвимостях в ПО, аппаратных устройствах и сетевых сервисах. Они представляют из себя совокупность данных, которые оптимизируют работу с критичными элементами операционных систем для упрощения поиска уязвимостей и последующего облегчения работы по построению комплексной политики безопасности.

При появлении общей глобальной сети в виде ARP-сетей и последующем переходе на стек протоколов TCP/IP концепция информационной безопасности

была реактивной. То есть политика безопасности реагировала только тогда, когда случались события, связанные с защитой. На сегодняшний день положение изменилось полностью, защита стала проактивной. Она направлена на предотвращение вторжений и старается угадать возможные действия злоумышленника. И в данном случае базы данных играют ключевую роль.

Базы данных предназначены для:

– идентификации уязвимостей. Направлены на обнаружение «дыр» в ПО, конфигурациях, стандартизацию через CVE-ID, классификацию по типу XSS и критичность CVSS;

– оценки рисков. Рассматриваются в двух основных вариациях: CVSS – определение критичности уязвимости, EPSS – вероятность использования;

– поддержки сканеров. Предназначены для своевременной актуализации баз данных сканеров для выявления новых уязвимостей;

– прогнозирования угроз. Происходит анализ статистики на частоту использования уязвимостей;

– соответствия стандартам. Помощь в выполнении требований по защиты по PCI DSS, ISO 27001, GDPR;

– подготовки кадров. Внесения плановых инструкций по противодействию данным атакам.

Далее рассмотрим базы данных.

CAPEC (Common Attack Pattern Enumeration and Classification) – это таксономия и база данных атакующих паттернов, разработанная MITRE. Она описывает типовые методы кибератак, которые используют злоумышленники для эксплуатации уязвимостей.

Единично взятая запись CAPEC описывает вектор атаки, который может быть применён. В запись включается информация особенности применения шаблона, раскрываемая информация с его помощью. В паттерне также приводится информация, которая указывает можно ли использовать данный вектор атаки в качестве тестового в информационной системе или нет.

Использование базы данных CAPEC облегчает формирование политики безопасности в условиях известных типов атаки.

С помощью базы данных CAPEC реализуется:

1) Стандартизация векторов атаки, применяемых на АИС;

2) Типы уязвимостей, которые могут присутствовать в системе;

3) Нейтрализующие меры по понижению риска вторжения в информационную систему;

4) Разработка мер защиты от действий злоумышленников, комплексное обеспечение защиты информации.

Полезность базы данных CAPEC очень велика, благодаря ей есть возможность устранять более узконаправленные векторы. Чтобы достичь глубоко эшелонированной защиты, обычно CAPEC используют в связке с матрицей MITRE ATT&CK. Она позволяет описать в связке с векторами атаки тактики и техники.

MITRE ATT&CK представляет собой структурированную базу знаний, ориентированную на специалистов в области информационной безопасности. Она содержит классифицированные модели поведения злоумышленников, представленные в виде тактик и техник, что позволяет проводить детальный анализ современных киберугроз. Интеграция данной модели в процессы анализа угроз, построение систем реагирования и планирование мер противодействия обеспечивает понимание природы кибератак и позволяет формировать адаптивные механизмы защиты в условиях повышения угроз.

База данных MITRE ATT&CK документально подтверждена. Её инциденты обеспечивают высокую точность описания тактик и техник злоумышленников. Благодаря ей можно систематизировать атаки по этапам жизненного цикла (разведка, проникновение, перемещение и т.д.), помогая анализировать как прошлые инциденты, так и прогнозировать новые угрозы.

Матрица MITRE позволяет:

1) привести непосредственные действия злоумышленника на информационную систему;

2) спрогнозировать возможные последствия, которые будут связаны с направление атаки;

3) систематизировать отчётную информацию по проделанной работе настройки контура защиты информации.

Для работы с уязвимостями программно-аппаратных средств используется Национальная база данных уязвимостей (NVD), являющаяся централизованным репозиторием информации о известных уязвимостях в программном обеспечении и аппаратных устройствах. NVD поддерживается Национальным институтом стандартов и технологий США (NIST) и предназначена для систематизации данных о различных типах уязвимостей, включая их описание, классификацию, рекомендации по устранению и метрики критичности, такие как CVSS (Common Vulnerability Scoring System). Это позволяет оперативно выявлять наиболее опасные уязвимости и оценивать их влияние на защищённость информационных систем.

Интеграция NVD с такими платформами, как MITRE ATT&CK и CAPEC, а также с системами управления уязвимостями (VMS) и решениями SIEM, обеспечивает комплексный подход к управлению рисками и защиту ИТ-инфраструктуры. Такая взаимосвязь важна для организаций с распределёнными и сложными ИТ-ландшафтами, поскольку позволяет автоматизировать процессы обнаружения угроз, мониторинга состояния безопасности и реагирования на инциденты. Таким образом, использование NVD в сочетании с современными моделями киберугроз способствует формированию эффективной стратегии обеспечения информационной безопасности на основе анализа достоверных и стандартизованных данных.

Преимущества NVD:

1) Централизованный и авторитетный источник. Поддерживается NIST (Национальный институт стандартов и технологий США), что гарантирует достоверность и актуальность данных.

2) Стандартизированная оценка уязвимостей. Использует CVSS (Common Vulnerability Scoring System) для объективной оценки критичности уязвимостей, помогая приоритизировать исправления.

3) Полнота информации. Содержит технические описания уязвимостей (CVE), ссылки на патчи с рекомендациями по устранению уязвимостей, историю обновлений и связанные угрозы.

4) Интеграция с экосистемой безопасности. Совместима с MITRE ATT&CK и CAPEC (анализ тактик атак), SIEM-системами (Splunk, IBM QRadar) и сканерами уязвимостей (Nessus, OpenVAS).

5) Поддержка автоматизации. Позволяет интегрировать данные в системы управления уязвимостями (VM), мониторинга и реагирования (SOC), DevSecOps – процессы (через API).

6) Открытый доступ. Бесплатное использование и регулярные обновления (ежедневные синхронизации с новыми CVE).

На основе предоставленной информации от NVD специалисты по кибербезопасности способны закрывать самые критические уязвимости, которые открывают большие бреши в системе безопасности.

Наконец, перейдём к отечественному хранилищу информации. БДУ ФСТЭК России является национальной альтернативой международным базам данных, таким как NVD и ATT&CK. Её основное предназначение – систематизация информации об уязвимостях, угрозах и мерах защиты, соответствующих российским нормативным требованиям и стандартам безопасности

БДУ ФСТЭК (База данных уязвимостей Федеральной службы по техническому и экспортному контролю) разработана с учётом требований российского законодательства в области информационной безопасности. Она служит ключевым ресурсом для специалистов российских компаний и госучреждений, помогая обеспечивать соответствие национальным стандартам защиты информации. База охватывает широкий спектр угроз – от уязвимостей в ПО и сетевых устройствах до методов кибератак, дополняя эти данные практическими рекомендациями по устранению рисков.

Важной особенностью БДУ ФСТЭК является её совместимость как с российскими, так и с международными источниками данных о киберугрозах (например, MITRE ATT&CK, NVD). Это позволяет формировать комплексную

картину угроз и эффективнее противодействовать им. База не только идентифицирует уязвимости, но и предлагает конкретные меры по их устранению, что ускоряет реакцию на инциденты.

Несмотря на различия в подходах, совместное использование этих баз данных позволяет выстраивать многоуровневые стратегии защиты. Например, связка БДУ ФСТЭК + MITRE ATT&CK помогает соотносить локальные угрозы с глобальными трендами, а интеграция NVD с CAPEC – прогнозировать потенциальные векторы атак через известные уязвимости. Для российских организаций БДУ ФСТЭК остаётся обязательным элементом кибербезопасности, дополняющим международные frameworks.

В таблице 1 приведены представлено наглядное сравнение баз данных.

Таблица 1 – Сравнительный анализ баз данных

Параметры	CAPEC	MITRE ATT&CK	NVD	БДУ ФСТЭК
Типы данных	Шаблоны атак	Тактики и техники атак	Уязвимости	Уязвимости
Параметры	CAPEC	MITRE ATT&CK	NVD	БДУ ФСТЭК
Подход	Превентивный	Реактивный и проактивный	Реактивный	Реактивный
Основная задача	Описание типов атак	Описание техник и тактик атак	Актуализация уязвимостей	Соответствие отечественным реалиям
Уровень детализации	Высокий	Высокий	Средний	Средний

Совокупность данных баз данных позволяет гибко и комплексно реагировать на инциденты информационной безопасности. Каждая база данных дополняет другую, создавая единую картину угроз и уязвимостей, что значительно повышает эффективность работы специалистов по информационной безопасности.

1.2 Исследование риск-калькуляторов CVSS, EPSS и OWASP

Как показывает анализ в пункте 1.1, эффективная защита информационных систем строится на двух ключевых процессах: управлении уязвимостями и

грамотной оценке рисков. Однако перед специалистами по безопасности регулярно встаёт вопрос выбора приоритета угроз, а также оценки степени опасности конкретной уязвимости. Ответы на эти вопросы предоставляют современные риск-калькуляторы.

На сегодняшний день активно используют такие риск-калькуляторы как: CVSS (Common Vulnerability Scoring System), EPSS (Exploit Prediction Scoring System), OWASP Risk Rating Methodology. Это стандартизированные калькуляторы, имеющие доверие со стороны организаций. Их оценки являются универсальными, позволяющие гибко дать характеристику уязвимости.

CVSS представляет собой открытый стандарт для оценки severity (серьезности) уязвимостей программного обеспечения. Разрабатывается и поддерживается международным форумом FIRST (Forum of Incident Response and Security Teams). Текущая актуальная версия - CVSS v4.0.

Ключевые особенности:

1) Количественный подход. Оценка производится по шкале от 0.0 до 10.0. Позволяет сравнивать критичность разных уязвимостей;

2) Многофакторная модель. Включает три группы метрик Base Metrics (базовая оценка), Temporal Metrics (изменяемые параметры), Environmental Metrics (контекст окружения);

3) Объективность. Устраняет субъективность в оценке и стандартизирует процесс приоритизации.

CVSS нашёл своё практическое применение в базах данных БДУ ФСТЭК и NVD. Данные оценки отражают критичность воздействия уязвимости на информационную систему.

CVSS 3.1 и CVSS 4.0 состоит из 3 основных групп метрик:

1) Базовая метрика (Base Metrics) – отражает основную природу уязвимости;

2) Временная метрика (Temporal Metrics) – показывает, как со временем меняется опасность уязвимости;

3) Контекстная метрика (Environmental Metrics) – учитывает специфические условия конкретной среды.

Для непосредственного наглядного представления особенностей CVSS 3.1 и CVSS 4.0 составлена таблица 2.

Таблица 2 – особенности CVSS 3.1, CVSS 4.0

Метрика	CVSS v3.1	CVSS v4.0
Базовые метрики		
Attack Vector (AV)	Сетевой (N), Смежный (A), Локальный (L), Физический (P)	Сетевой (N), Смежный (A), Локальный (L), Физический (P)
Attack Complexity (AC)	Высокий (H), Низкий (L)	Высокий (H), Низкий (L), Средний (M)
Privileges Required (PR)	Нет (N), Низкий (L), Высокий (H)	Низкий (L), Высокий (H). Уточнены условия для Low/High
User Interaction (UI)	Требуется (R), Не требуется (N)	Требуется (R), Не требуется (N)
Scope (S)	Неизменный (U), Измененный (C)	-
Confidentiality (C)	Высокий (H), Низкий (L), Нет (N)	Шкала расширена: Critical (CR), High (H), Low (L), None (N)
Integrity (I)	Аналогично Confidentiality	Аналогично Confidentiality
Availability (A)	Аналогично Confidentiality	Аналогично Confidentiality
Временные метрики		
Exploit Code Maturity (E)	Неизвестно (U), Подтвержденный (P), Функциональный (F), Высокий (H)	Exploit Maturity (EM) с уточненными уровнями
Remediation Level (RL)	Официальное исправление (O), Временное (T), Workaround (W), Недоступно (U)	Официальное исправление (O), Временное (T), Workaround (W), Недоступно (U)
Report Confidence (RC)	Неподтвержденный (U), Неофициальный (R), Подтвержденный (C)	Упрощена шкала
Окружающие метрики		
Security Requirements (CR,IR,AR)	Задаются вручную (Low/Medium/High)	Добавлена градация Mission Critical (MC)
Modified Base Metrics	Корректировка базовых метрик под окружение	Упрощен процесс модификации

Метрики угроз позволяют оценить риск эксплуатации уязвимости в реальном времени. Они помогают приоретизировать исправления, учитывая факторы текущих атак.

Метрики CVSS позволяют наиболее полно описать возможное воздействие злоумышленника при использовании уязвимости. Данные характеристики затрагивают полный спектр возможностей.

Ещё нужно упомянуть один риск-калькулятор EPSS (Exploit Prediction Scoring System). EPSS (Exploit Prediction Scoring System) представляет собой риск-калькулятор, разработанный для оценки вероятности использования уязвимости в реальных кибератаках. В отличие от традиционных систем оценки, EPSS фокусируется не на потенциальной опасности уязвимости, а на прогнозировании её фактической эксплуатации злоумышленниками. Этот инструмент был создан как дополнение к CVSS, позволяя специалистам по безопасности получать более точную и актуальную картину угроз.

В основе EPSS лежат сложные статистические модели, включая байесовские методы анализа вероятности. Система учитывает множество факторов:

- исторические данные об эксплуатации уязвимостей;
- активность киберпреступников;
- наличие публичных эксплойтов;
- информацию из открытых источников.

Для обработки этих данных применяются алгоритмы машинного обучения, что позволяет системе постоянно совершенствовать точность прогнозов.

Ключевые особенности:

1) Формат оценки. EPSS предоставляет результат в виде процентной вероятности (от 0% до 100%). Например, показатель 85% означает высокую вероятность использования уязвимости в ближайшее время.

2) Динамический характер. В отличие от статичной оценки CVSS, показатели EPSS регулярно обновляются, отражая текущую ситуацию в мире киберугроз.

3) Практическая направленность. Система фокусируется на факторах, непосредственно влияющих на вероятность атаки: наличие работающих эксплойтов; активность хакерских группировок; популярность уязвимости в darknet.

В конце концов, требуется сказать про OWASP. OWASP Risk Rating Calculator представляет собой современный и практичный инструмент, разработанный сообществом OWASP для комплексной оценки рисков, связанных с уязвимостями веб-приложений. Его ключевая особенность – способность учитывать не только технические параметры уязвимостей, но и их потенциальное влияние на бизнес-процессы.

Основная задача этого калькулятора – обеспечить стандартизированный подход к оценке угроз, позволяя специалистам по информационной безопасности:

1) Объективно определять уровень критичности уязвимостей.

2) Аргументированно выстраивать приоритеты их устранения.

3) Принимать взвешенные решения с учетом как технических, так и бизнес-факторов.

Этот инструмент особенно востребован при:

1) Аудите безопасности веб-приложений.

2) Планировании работ по исправлению уязвимостей.

3) Обосновании инвестиций в кибербезопасность перед руководством.

Благодаря своему сбалансированному подходу, OWASP Risk Rating Calculator стал одним из наиболее актуальных решений для оценки рисков в веб-среде.

Методология оценки строится из ниже приведённых этапов:

1) определение факторов угрозы (Threat Factors);

2) оценка факторов воздействия (Impact Factors);

3) расчёт уровня риска (Risk Score Calculation);

Первоочередным анализом периметра систем является определение факторов угроз, которые задействуются в ходе атак злоумышленника. Данные факторы описывают, что какие средства выступают критическими. В таблице 3 приводятся факторы.

Таблица 3 – Факторы угроз

Факторы угроз	Описание	Шкала оценки (1-9)
Навыки атакующего	Компетентность злоумышленника в области информационных технологий	1(высокие навыки) – 9 (низкие навыки)
Разведка по открытым источникам	Распространение информации о внутренней инфраструктуры в глобальной сети	1 (бесконтрольное распространение информации) – 9 (полный контроль «социальной жизни»)
Инструменты	Доступные инструменты с использованием эксплойтов	1 (специфические инструменты) – 9 (публичные инструменты)
Мотивированность	Какова вероятность, что злоумышленник целенаправленно будет нацелен на систему	1 (высокая) – 9 (низкая)
Доступность	Уровень доступности, требуемый для работы в системе	1 (удалённый доступ) – 9 (локальный доступ)

Из факторов угроз вытекают последствия для возможных шаблонов атак. Каждый фактор несёт в себе определённый набор уязвимостей, который комплексно может быть применён в ходе масштабной атаки. Дальше разбираются факторы воздействия в таблице 4. Они приводятся в аналогии с гексадой Паркера.

Таблица 4 – Факторы воздействия

Факторы воздействия	Описание
Влияние на конфиденциальность	Воздействия на конфиденциальность информации
Влияние на целостность	Может ли атакующий нарушить целостность данных
Влияние на доступность	Может ли атакующий получить доступ к защищаемой информации
Влияние на аутентичность	Может ли атакующий нарушить процесс аутентификации информации
Влияние на полезность	Возможность обесценивания засекреченной информации
Влияние на владение	Возможность подмены подставного лица как хозяина информации

По итогам расчётов, основанных на факторах угрозы и воздействия, будет выявлен уровень риска: низкий (0-3), средний (3-6), высокий (6-9) и критический (9+).

После обозначения основных возможностей риск-калькуляторов, их характеристик можем составить собирательную таблицу с общими параметрами. В таблице 5 аккумулирована вся основная информация.

Таблица 5 – сравнение риск-калькуляторов

Критерий	CVSS	EPSS	OWASP Risk Rating
Назначение	Оценка тяжести уязвимости	Прогнозирование вероятности эксплуатации	Оценка рисков для веб-приложений
Тип оценки	Статическая (базовая угроза)	Динамическая (вероятность атаки)	Комплексная (технические и бизнес-факторы)
Шкала	0.0–10.0 (Critical, High и т.д.)	0–100% (вероятность эксплуатации)	Качественная (Low/Medium/High/Critical)
Ключевые метрики	Base/Temporal/Environmental	Байесовские модели, ML	Техническое воздействие / Бизнес-воздействие
Область применения	Все типы уязвимостей	Все типы уязвимостей	Веб-приложения
Интеграция	NVD, сканеры уязвимостей	Дополняет CVSS	OWASP Top 10, ASVS
Преимущества	Стандартизация, простота	Прогнозирование реальных угроз	Учет бизнес-контекста
Недостатки	Не учитывает вероятность атаки	Не оценивает тяжесть последствий	Ограничен функционалом

Несмотря на то, что все риск-калькуляторы разнообразны, они используются совместно. Благодаря совместному применению получается достичь результата более глубокого изучения инцидента информационной безопасности. Пример совместного применения:

1) CVSS → Определить базовую опасность.
2) EPSS → Оценить вероятность эксплуатации.
3) OWASP → Учесть бизнес-последствия.

Современные системы информационной безопасности вышли за рамки простого устранения уязвимостей. Ключевой задачей сегодня становится интеллектуальная приоретизация исправлений, позволяющая сосредоточиться на наиболее опасных угрозах. Способность точно определять, какие уязвимости с наибольшей вероятностью будут использованы злоумышленниками, значительно повышает эффективность защитных мер и скорость реагирования на инциденты.

Максимальную эффективность защиты обеспечивает интеграция трех взаимодополняющих методологий:

1) CVSS для оценки тяжести уязвимостей;
2) EPSS для прогнозирования вероятности атак;
3) OWASP Risk Rating для анализа бизнес-последствий.

Такой многоуровневый подход позволяет создавать динамичные и адаптивные системы безопасности, способные противостоять современным угрозам.

2. Установление взаимосвязи шаблонов атак CAPEC с эксплуатируемыми ими уязвимостями

2.1 Специфика атак класса «Методы активного обнаружения узлов и сервисов»

CAPEC (Common Attack Pattern Enumeration and Classification, или Перечисление и классификация общих шаблонов атак) – это углублённая база данных, предназначенная для структуризации и сбора данных о возможных типов атак, применяемых в автоматизированных информационных системах. Основная задача CAPEC является поддержка специалистов по информационной безопасности, повышение их осведомлённости насчёт новых угроз и углубление компетенций в направлении построений защиты автоматизированной информационной системы.

В рамках данной работы CAPEC имеет важное значение, так как предоставляет подробную информацию об атаках, использующих вероятностные методы. На основе этой базы данных можно создать классификацию возможных векторов атак, актуальных для предметной области исследования, а также разработать соответствующие регламенты и инструкции.

CAPEC использует структурированную модель шаблонов атак, организованную по уровням абстракции. Это позволяет разбивать массив шаблонов атак на подмножества, которые далее делятся на более узкие группы, основанные на общих признаках и характеристиках.

Таким образом, выстраивается иерархическая система, движущаяся от общего к частному: от универсальных паттернов атак до более узких и детализированных вариантов. Подобная структура упрощает моделирование и анализ потенциальных атак, переходя от общего плана к конкретным примерам. В результате специалисты могут создать комплексную систему защиты, учитывая угрозы на каждом уровне и применяя соответствующие меры для противодействия различным категориям атак.

Шаблоны представляют из себя описание возможных векторов атак, которые используются злоумышленником. Данный шаблон основан на анализе и

теоретическом воспроизведении действия злоумышленника при возможных действиях.

При описании CAPEC используется следующая терминология:

1) Атака (Attack) – это совокупность деструктивного воздействия злоумышленника, направленное на нарушение конфиденциальности, целостности, доступности информации. Атака представляет комплекс мер по нарушению этапов работы информационных систем в организации;

2) Вектор атаки (Attack Vector) – путь или возможный метод по реализации атаки. Вектор атаки описывает возможности использования уязвимостей автоматизированной информационной системы;

3) Техника атаки (Attack Technique) – набор специфических методов и тактик, которые используются атакующим при реализации внедрения в АИС;

4) Механизм защиты (Mitigation) – меры по противодействию возможным угрозам злоумышленника. Механизмы защиты помогают ограничить вектор атаки и снизить вероятность успешной эксплуатации уязвимости;

5) Целевая уязвимость (Targeted Weakness) – это конкретная уязвимость или недостаток в системе безопасности, эксплуатируемый злоумышленником. Она может быть связана с архитектурными изъянами, ошибками в коде или некорректными настройками системы, которые делают её уязвимой для атак;

6) Последствия (Impact) – Это потенциальный ущерб, возникающий в результате успешной атаки. Могут в себя включать как потерю конфиденциальности данных, так и нарушения целостности работы внутренних систем [9-23].

В контексте обобщения проблемы имеет смысл привести детальное описание категории атак, смоделировать лес древовидных графов, основанных на объединенных по общему принципу CAPEC, CWE и уязвимостей CVE, и дополнить сведения паспортами необходимых аспектов. Для данного исследования наиболее актуальными являются атаки типа «методы активного обнаружения узлов и сервисов», общим идентификатором которых является CAPEC-292.

CAPEC-292 «Host Discovery» можно описать следующим образом: злоумышленник запускает сканирование сети с использованием определённых условий, которые могут отобразить рабочие сервисы на узлах. Благодаря данному шаблону атаки есть возможность раскрытия конфиденциальной информации несанкционированному лицу.

На рассмотрение в данном исследовании выносятся CAPEC, для которых CAPEC-292 является родительским. CAPEC, рассматриваемые в работе, ориентированы на сканирование сети с использованием активных методов, то есть используются такие шаблоны: CAPEC-297, CAPEC-298, CAPEC-299, CAPEC-618 [15-20]. В данных шаблонах используются ключевые сетевые протоколы и их особенности работы. Данные графы представлены в виде дерева на рисунке 1.

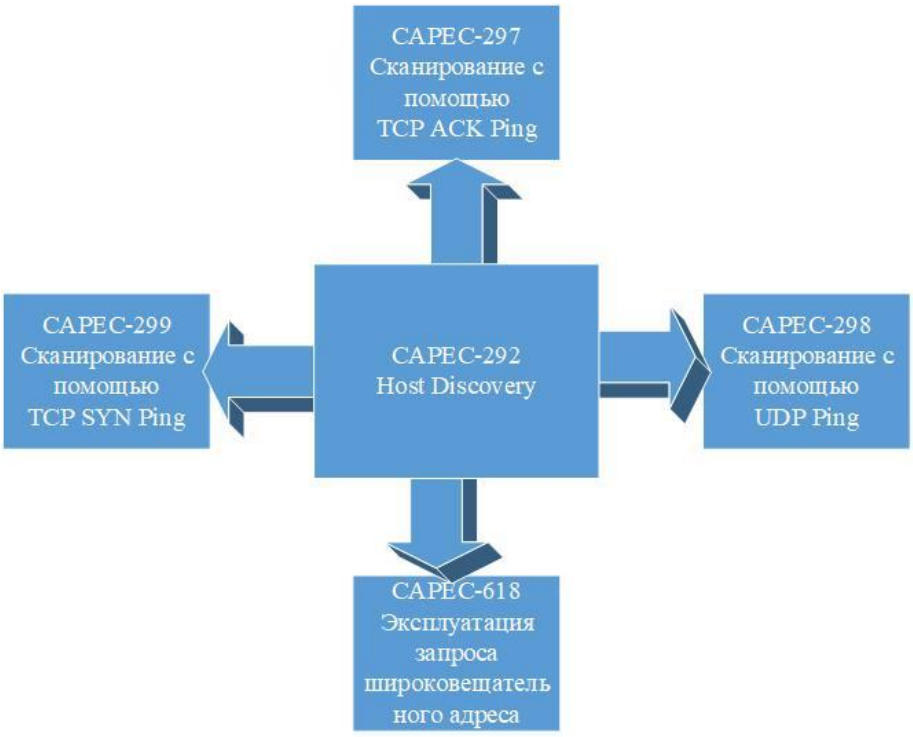


Рисунок 1 – Древовидный граф векторов атаки CAPEC

Данные шаблоны кибератак возникают на 1 этапе матрицы техник и тактик MITRE. Непосредственно благодаря им проводится первичный анализ сетевой инфраструктуры, узлов и особенностей устройств. С рассекречиванием информации у злоумышленника появляется возможность поэтапного проектирования атаки.

Дальше стоит сказать как взаимосвязаны шаблоны с техниками. Техники приводятся в соответствии с матрицей MITRE ATT&CK. В таблице 6 демонстрируется взаимосвязь.

Таблица 6 – Разложение шаблона на техники

CAPEC ID	Разведка	Выполнение	Предотвращение обнаружения	Обнаружение	Организация управления	Деструктивное воздействие
CAPEC-297	T1595 T1590	T1203	T1134	T1046 T1049	-	T1498
CAPEC-298	T1595 T1590	-	T1205	T1010 T1049	T1095	T1499
CAPEC-299	T1595 T1590	T1203	T1542 T1205	T1010 T1049	-	T1499
CAPEC-618	T1595.001	-	T1542	T1046 T1049	T1095	T1498

Из выше приведённой таблицы становится ясно, что шаблоны применяются в 3-5 этапах матрицы MITRE [10]. В зависимости от шаблона, используются разные техники, которые взаимосвязаны между собой. Дальше будет разобраны примеры как техники связаны, но для этого нужно разобрать паспорт шаблона атаки.

2.2 Паспортизация шаблонов атак класса «Методы активного обнаружения узлов и сервисов»

В первую очередь для определения направления атаки требуется привести паспорт шаблона атаки. В нём перечисляются возможные типы ошибок, которые могут быть использованы. Для наглядного представления будут разобраны пары «атака - уязвимость». Приведены непосредственные связи между шаблоном, слабым местом и уязвимостью в автоматизированной информационной системе.

Для разбора связей начнём с шаблона атаки CAPEC-297. В таблице 7 указан вектор атаки.

Таблица 7 – Паспорт шаблона атаки

Идентификатор системы CAPEC	CAPEC-297 TCP ACK Ping	
Описание вектора атаки	Злоумышленник с помощью ACK пакетов может определять состояние порта, жив он или нет.	
Тип атаки	Активное сканирование	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Раскрытие конфиденциальной информации неавторизованному лицу	Запрещено использование сопоставление с реальными уязвимостями

Вектор CAPEC-297 TCP ACK Ping связывает с собой только 1 тип ошибки – CWE-200 Host Discovery.

На рисунке 2 представлено дерево вектора CAPEC-297.

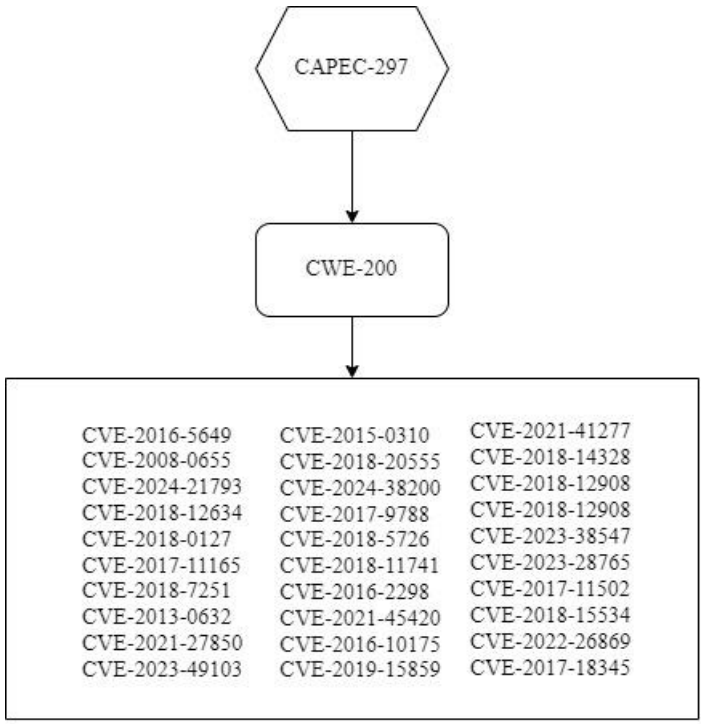


Рисунок 2 – Древовидный граф вектора атаки CAPEC-297

Дальше приводятся все связанные ошибки с вектором атаки CAPEC-297 (таблица 8).

Таблица 8 – Соотношение CAPEC-297 с парой «атака-уязвимость»

Вектор атаки	Наименование вектора атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-297	TCP ACK Ping	CWE-200	CVE-2016-5649
			CVE-2008-0655
			CVE-2024-21793
			CVE-2018-12634
			CVE-2018-0127
			CVE-2017-11165
			CVE-2018-7251
			CVE-2013-0632
			CVE-2021-27850
			CVE-2023-49103
			CVE-2015-0310
			CVE-2018-20555
			CVE-2024-38200
			CVE-2017-9788
			CVE-2018-5726
			CVE-2018-11741
			CVE-2016-2298
			CVE-2021-45420
			CVE-2016-10175
			CVE-2019-15859
			CVE-2021-41277
			CVE-2018-14328
			CVE-2018-12908
			CVE-2023-38547
			CVE-2023-28765
			CVE-2017-11502
			CVE-2018-15534
			CVE-2022-26869
			CVE-2017-18345

Паспорт безопасности одной из уязвимостей указан в таблице 9.

Таблица 9 - Паспорт уязвимости

Идентификатор уязвимости	CVE-2016-5649 В странице 'BSW_cxttongr.htm' устройств Netgear DGN2200, версия DGN2200-V1.0.0.50_7.0.50, и DGND3700, версия DGND3700-V1.0.0.17_1.0.17, имеется уязвимость, которая может позволить удаленному злоумышленнику получить доступ к этой странице без какой-либо аутентификации. При обработке он раскрывает пароль администратора открытым текстом перед перенаправлением на страницу absw_vfysucc.cgia. Злоумышленник может использовать этот пароль для получения доступа администратора к веб-интерфейсу маршрутизатора.
Идентификатор типа ошибки	CWE-200

Продолжение таблицы 9

Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Вектор CAPEC-298: сканирование с использованием UDP Ping. Использует тип ошибки CWE-200. Ниже в таблице 10 приведён паспорт вектора атаки.

Таблица 10 – Паспорт шаблона атаки CAPEC-298

Идентификатор системы CAPEC	CAPEC-298 UDP Ping	
Описание вектора атаки	Злоумышленник с помощью UDP пакетов может определять состояние хоста, жив он или нет. Часто межсетевые экраны не блокируют UDP пакеты, поэтому они могут проникать через средства защиты.	
Тип атаки	Активное сканирование	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Раскрытие конфиденциальной информации неавторизованному лицу	Запрещено использование сопоставление с реальными уязвимостями

Древовидный граф CAPEC-298 представлен на рисунке 3.

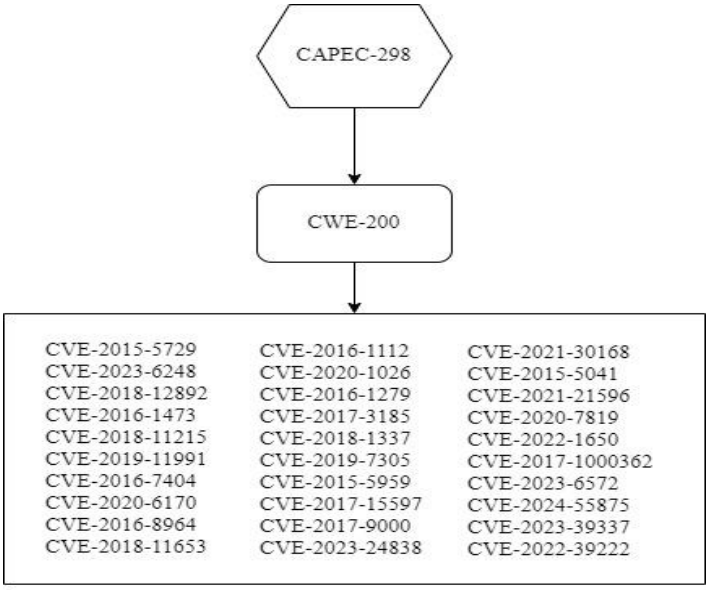


Рисунок 3 – Древовидный граф CAPEC-298

Дальше приводятся все связанные ошибки с вектором атаки CAPEC-298 (таблица 11).

Таблица 11 – Соотношение CAPEC-298 с парой «атака-уязвимость»

Вектор атаки	Наименование вектора атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-297	UDP Ping	CWE-200	CVE-2015-5729
			CVE-2023-6248
			CVE-2018-12892
			CVE-2016-1473
			CVE-2018-11215
			CVE-2019-11991
			CVE-2016-7404
			CVE-2020-6170
			CVE-2016-8964
			CVE-2018-11653
			CVE-2016-1112
			CVE-2020-1026
			CVE-2016-1279
			CVE-2017-3185
			CVE-2018-1337
			CVE-2019-7305
			CVE-2015-5959
			CVE-2017-15597
			CVE-2017-9000
			CVE-2023-24838
			CVE-2021-30168
			CVE-2015-5041
			CVE-2021-21596
			CVE-2020-7819
			CVE-2022-1650
			CVE-2017-1000362
			CVE-2023-6572
			CVE-2024-55875
			CVE-2023-39337
			CVE-2022-39222

Паспорт безопасности одной из уязвимостей указан в таблице 12.

Таблица 12 – Паспорт уязвимости

Идентификатор уязвимости	CVE-2015-5729 Функция Soft Access Point (AP) в телевизорах Samsung Smart TV X10P, X12, X14H, X14J и NT14U и принтерах Xpress M288OFW генерирует слабые ключи WPA2 PSK, что облегчает удаленным злоумышленникам получение конфиденциальной информации или обход аутентификации с помощью атаки методом грубой силы.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Уточняется информация
Способ устранения	Обновление версии прошивки

Вектор CAPEC-299: сканирование с использованием TCP ACK Ping. Использует тип ошибки CWE-200. Ниже в таблице 13 приведён паспорт вектора атаки.

Таблица 13 – Пары «атака-уязвимость»

Идентификатор системы CAPEC	CAPEC-299 TCP SYN Ping	
Описание вектора атаки	Злоумышленник с помощью SYN пакетов может определять состояние порта, открыт он или нет. Также данная возможность есть при прохождении через брандмаундер, в случае если отсутствует блокирующее правило на SYN пакеты.	
Тип атаки	Активное сканирование	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Раскрытие конфиденциальной информации неавторизованному лицу	Запрещено использование сопоставление с реальными уязвимостями

Древовидный граф CAPEC-298 представлен на рисунке 4.

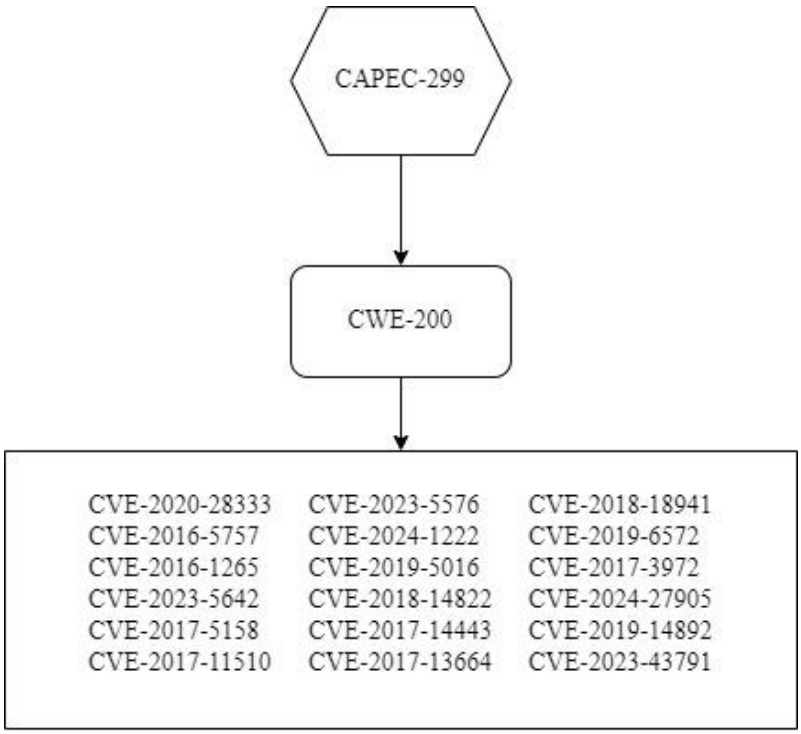


Рисунок 4 – Древовидный граф CAPEC-299

Дальше приводятся все связанные ошибки с вектором атаки CAPEC-299 (таблица 14).

Таблица 14 – Соотношение CAPEC-299 с парой «атака-уязвимость»

Вектор атаки	Наименование вектора атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-299	TCP SYN Ping	CWE-200	CVE-2020-28333
			CVE-2016-5757
			CVE-2016-1265
			CVE-2023-5642
			CVE-2017-5158
			CVE-2017-11510
			CVE-2023-5576
			CVE-2024-1222
			CVE-2019-5016
			CVE-2018-14822
			CVE-2017-14443
			CVE-2017-13664
			CVE-2018-18941
			CVE-2019-6572
			CVE-2017-3972
			CVE-2024-27905
			CVE-2019-14892
			CVE-2023-43791

Паспорт безопасности одной из уязвимостей указан в таблице 15.

Таблица 15 – Паспорт уязвимости

Идентификатор уязвимости	CVE-2015-5729 Устройства Barco wePresent WiPG-1600W допускают обход аутентификации. Затронутая версия(и): 2.5.1.8. Веб-интерфейс Barco wePresent WiPG-1600W не использует сеансовые файлы cookie для отслеживания аутентифицированных сеансов. Вместо этого веб-интерфейс использует маркер "SEID", который добавляется в конец URL-адресов при GET-запросах. Таким образом, "SEID" может быть обнаружен в журналах веб-прокси и истории браузера.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Уточняется информация
Способ устранения	Обновление версии прошивки

Вектор CAPEC-618: сканирование узлов с использованием широковещательного адреса. Использует тип ошибки CWE-201. Ниже в таблице 16 приведён паспорт вектора атаки.

Таблица 16 – Пары «атака-уязвимость»

Идентификатор системы CAPEC	CAPEC-618 Cellular Broadcast Message Request	
Описание вектора атаки	Запустив широковещательное сообщение и прослушав его наличие или отсутствие, злоумышленник может убедиться, что объект находится (или не находится) в определенном месте.	
Тип атаки	Активное сканирование	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-201 Вставка конфиденциальной информации в отправленные данные	Разрешается использование сопоставление с реальными уязвимостями

Древовидный граф CAPEC-298 представлен на рисунке 5.

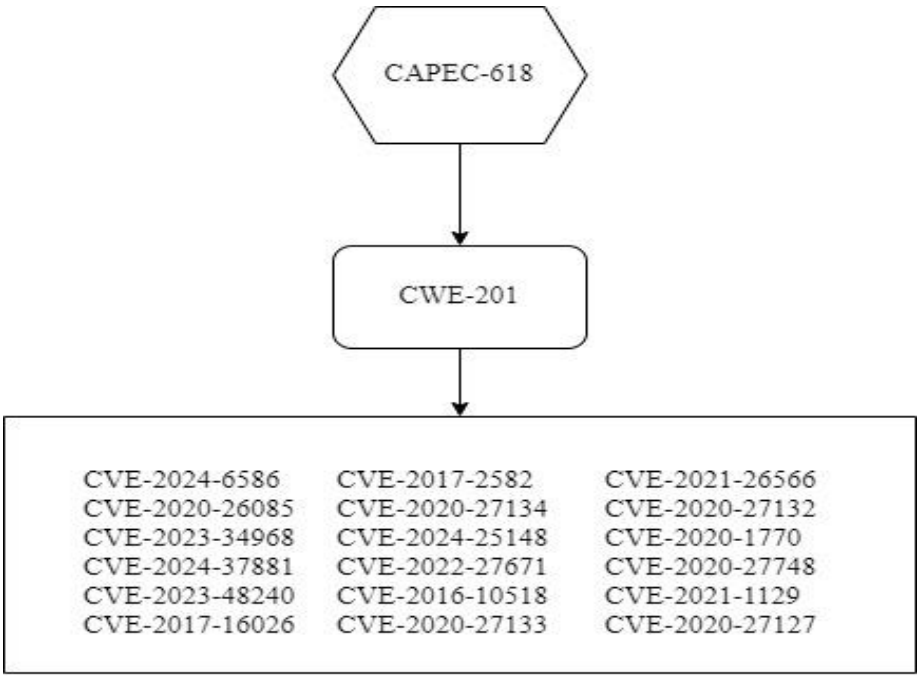


Рисунок 5 – Древовидный граф CAPEC-618

Дальше приводятся все связанные ошибки с вектором атаки CAPEC-618 (таблица 17).

Таблица 17 – Соотношение CAPEC-618 с парой «атака-уязвимость»

Вектор атаки	Наименование вектора атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-618	Cellular Broadcast Message Request	CWE-201	CVE-2020-28333
			CVE-2016-5757
			CVE-2016-1265
			CVE-2023-5642
			CVE-2017-5158
			CVE-2017-11510
			CVE-2023-5576
			CVE-2024-1222
			CVE-2019-5016
			CVE-2018-14822
			CVE-2017-14443
			CVE-2017-13664
			CVE-2018-18941
			CVE-2019-6572
			CVE-2017-3972
			CVE-2024-27905
			CVE-2019-14892
			CVE-2023-43791

Паспорт безопасности одной из уязвимостей указан в таблице 18.

Таблица 18 – Паспорт уязвимости

Идентификатор уязвимости	CVE-2016-5757 Консоль администратора iManager в NetIQ Access Manager 4.1 до версии 4.1.2 Hot Fix 1 и 4.2 до версии 4.2.2 была уязвима для атак с манипуляцией iFrame, что могло позволить удаленным пользователям получить доступ к учетным данным аутентификации.
Идентификатор типа ошибки	CWE-201
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Уточняется информация
Способ устранения	Обновление версии прошивки

3. Моделирование сценариев атак для заданных шаблонов на основе последовательности реализации техник MITRE ATT&CK

3.1 Оценка параметров эксплуатируемых уязвимостей

В данной части будут рассмотрены методы оценки вероятности успешной эксплуатации каждой уязвимости, с применением риск-калькуляторов. Также шаблоны будут разобраны на техники MITRE ATT&CK с их описанием. Из приведённых техник будут составлены сценарии реализации атак с применением уязвимостей.

Оценка уязвимостей будет основана на таких калькуляторах: CVSS 3.1, CVSS 4.0, EPSS, OWASP.

Для нахождения оценок критичности необходимо получить нормализованные оценки. Ввиду того, что оценка проводится в разных диапазонах, необходимо провести нормализацию. Для этого воспользуемся формулой 1:

$$s_{norm} = \frac{s - s_{min}}{s_{max} - s_{min}} \quad (1)$$

где: S – оценка калькулятора, S_{max} и S_{min} – максимальные и минимальные возможные значения оценки калькулятора [1-9].

Для расчёта критичностей воспользуемся методом нахождения среднеквадратичного значения по формуле 2:

$$S_{final} = \sqrt{\frac{1}{N}\sum_{i=1}^{N} S_{norm,i}^2} \quad (2)$$

Приведённый метод применяет среднеквадратичное значение для расчёта итогового значения. Его суть заключается в анализе разброса нормализованных оценок путём возведения каждой оценки в квадрат, суммирования их и деления суммы на общее количество [1-9].

Преимуществами данного метода является чувствительность к выбросам, что эффективно выявляет аномальные значения. Учёт неопределённости отражает степень разброса данных, также комплектность оценки отображает среднее значение оценок и их вариативные значения.

В соответствии с этими положительными характеристиками метод среднеквадратичного значения оптимален для выполнения задач оценок уязвимостей.

Для расчёта нормированных значений первым требуется получить с помощью риск-калькуляторов значения вероятности успешной реализации уязвимости.

Результаты оценок для шаблона CAPEC-297 будут занесены в таблицы 19-20.

Таблица 19 – Расчёт калькуляторов CVE (CAPEC-297)

Уязвимости	CVSS v3,0	CVSS v4,0	EPSS	OWASP
CVE-2016-5649	7,5	8,1	0,85	8,875
CVE-2008-0655	9,3	9,8	0,92	9,05
CVE-2024-21793	8,8	9,2	0,45	6,345
CVE-2018-12634	7,8	8,3	0,78	5,55
CVE-2018-0127	6,5	7,1	0,35	6,85
CVE-2017-11165	9,8	10	0,95	7,25
CVE-2018-7251	5,5	6,2	0,28	4,125
CVE-2013-0632	9,3	9,7	0,89	6,95
CVE-2021-27850	9,8	10	0,97	8,025
CVE-2023-49103	8,1	8,7	0,62	5,95
CVE-2015-0310	10	10	0,99	6,5
CVE-2018-20555	7,5	8	0,72	7,75
CVE-2024-38200	6,8	7,3	0,4	8,15
CVE-2017-9788	8,8	9,2	0,83	6,75
CVE-2018-5726	5,3	6	0,25	4,45
CVE-2018-11741	9,8	10	0,96	7,8
CVE-2016-2298	7,2	7,8	0,68	7
CVE-2021-45420	7,5	8,1	0,55	6,25
CVE-2016-10175	9,8	10	0,94	5,05
CVE-2019-15859	8,1	8,6	0,6	4,75
CVE-2021-41277	7,8	8,3	0,75	3
CVE-2018-14328	6,5	7,1	0,3	8,125
CVE-2018-12908	7,5	8	0,65	6,5
CVE-2023-38547	8,8	9,2	0,8	9
CVE-2023-28765	7,5	8	0,5	5,525
CVE-2017-11502	9,8	10	0,98	6,375

Продолжение таблицы 19

Уязвимости	CVSS v3,0	CVSS v4,0	EPSS	OWASP
CVE-2018-15534	8,8	9,3	0,82	4,85
CVE-2022-26869	9,8	10	0,97	5,125
CVE-2017-18345	7,5	8,1	0,7	7,85

Таблица 20 – Расчёт нормированных значений калькуляторов CVE (CAPEC-297)

Уязвимости	Норм. CVSS v3,0	Норм. CVSS v4,0	Норм. EPSS	Норм. OWASP
CVE-2016-5649	0,75	0,81	0,085	0,8875
CVE-2008-0655	0,93	0,98	0,092	0,905
CVE-2024-21793	0,88	0,92	0,045	0,6345
CVE-2018-12634	0,78	0,83	0,078	0,555
CVE-2018-0127	0,65	0,71	0,035	0,685
CVE-2017-11165	0,98	1	0,095	0,725
CVE-2018-7251	0,55	0,62	0,028	0,4125
CVE-2013-0632	0,93	0,97	0,089	0,695
CVE-2021-27850	0,98	1	0,097	0,8025
CVE-2023-49103	0,81	0,87	0,062	0,595
CVE-2015-0310	1	1	0,099	0,65
CVE-2018-20555	0,75	0,8	0,072	0,775
CVE-2024-38200	0,68	0,73	0,04	0,815
CVE-2017-9788	0,88	0,92	0,083	0,675
CVE-2018-5726	0,53	0,6	0,025	0,445
CVE-2018-11741	0,98	1	0,096	0,78
CVE-2016-2298	0,72	0,78	0,068	0,7
CVE-2021-45420	0,75	0,81	0,055	0,625
CVE-2016-10175	0,98	1	0,094	0,505
CVE-2019-15859	0,81	0,86	0,06	0,475
CVE-2021-41277	0,78	0,83	0,075	0,3
CVE-2018-14328	0,65	0,71	0,03	0,8125
CVE-2018-12908	0,75	0,8	0,065	0,65
CVE-2023-38547	0,88	0,92	0,08	0,9
CVE-2023-28765	0,75	0,8	0,05	0,5525
CVE-2017-11502	0,98	1	0,098	0,6375
CVE-2018-15534	0,88	0,93	0,082	0,485
CVE-2022-26869	0,98	1	0,097	0,5125
CVE-2017-18345	0,75	0,81	0,07	0,785
CVE-2016-5649	0,75	0,81	0,085	0,8875

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-297. Результаты представлены в таблице 21 ниже.

Таблица 21 – Расчёт критичности уязвимостей (CAPEC-297)

Уязвимость	Значение критичности
CVE-2016-5649	0,7095
CVE-2008-0655	0,8144
CVE-2024-21793	0,7116
CVE-2018-12634	0,6347
CVE-2018-0127	0,591
CVE-2017-11165	0,7898
CVE-2018-7251	0,4631
CVE-2013-0632	0,7578
CVE-2021-27850	0,8084
CVE-2023-49103	0,6654
CVE-2015-0310	0,7798
CVE-2018-20555	0,6724
CVE-2024-38200	0,6444
CVE-2017-9788	0,7217
CVE-2018-5726	0,4581
CVE-2018-11741	0,8028
CVE-2016-2298	0,6367
CVE-2021-45420	0,6349
CVE-2016-10175	0,7457
CVE-2019-15859	0,6374
CVE-2021-41277	0,5901
CVE-2018-14328	0,63
CVE-2018-12908	0,6382
CVE-2023-38547	0,7806
CVE-2023-28765	0,6145
CVE-2017-11502	0,7708
CVE-2018-15534	0,6858
CVE-2022-26869	0,7471
CVE-2017-18345	0,6782
CVE-2016-5649	0,7095

После приведения оценок риск-калькуляторов, нормированных оценок, и приведения критичности уязвимостей следующим этапом будет разложение шаблона на техники и составление из них сценариев атак. В ходе составления будут указаны уязвимости, которые могут быть задействованы злоумышленником в реализации атаки.

В таблице 22 приводится тактики и техники вместе с уязвимостью.

Таблица 22 – Соотнесение техник и тактик с уязвимостями CAPEC-297

Тактика	Техника	Эксплуатируемая уязвимость
Разведка	Активное сканирование (T1595)	CVE-2017-18345, CVE-2023-28765
	Топология сети (T1590.004)	CVE-2024-38200

Продолжение таблицы 22

Тактика	Техника	Эксплуатируемая уязвимость
Выполнение	Эксплуатация уязвимостей в клиентском ПО(T1203)	CVE-2015-0310, CVE-2018-20555
Предотвращение обнаружения	Манипуляция с токенами(T1134)	CVE-2024-21793, CVE-2008-0655
Обнаружение	Изучение конфигурации сети(T1046)	CVE-2018-0127
	Изучение сетевых служб(T1049)	CVE-2017-11165, CVE-2018-7251
Деструктивное воздействие	Остановка службы(T1498)	CVE-2018-14328, CVE-2018-7251

На рисунке 6 представлена группа сценариев шаблона атаки CAPEC-297.

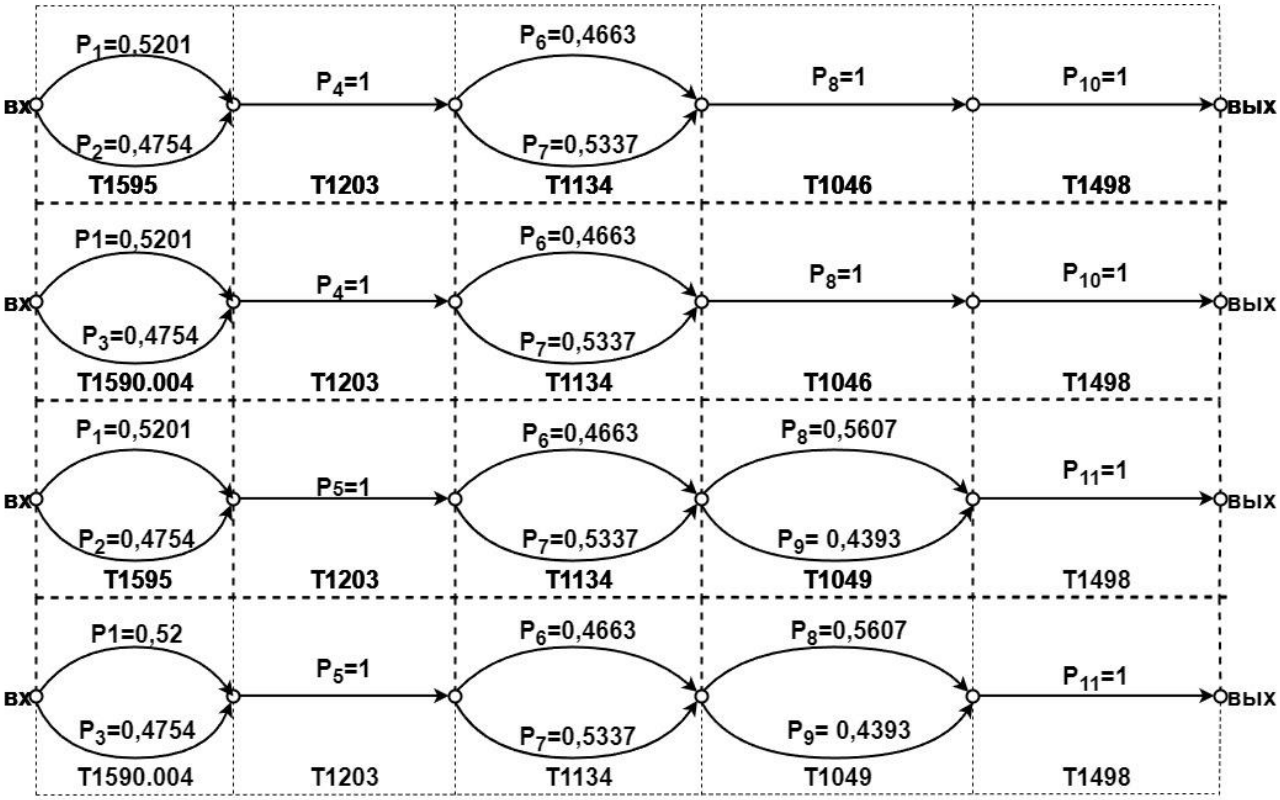


Рисунок 4 – Группа сценариев CAPEC-297

Цифрами обозначены следующие уязвимости:

1) CVE-2017-18345;
2) CVE-2023-28765;
3) CVE-2024-38200;
4) CVE-2015-0310;
5) CVE-2018-20555;

6) CVE-2024-21793;

7) CVE-2008-0655;

8) CVE-2018-0127;

9) CVE-2018-7251;

10) CVE-2017-11165;

11) CVE-2018-14328.

Результаты оценок для шаблона CAPEC-298 будут занесены в таблицы 23-24.

Таблица 23 – Расчёт калькуляторов CVE (CAPEC-298)

Уязвимости	CVSS v3,0	CVSS v4,0	EPSS	OWASP
CVE-2015-5729	7,5	8,1	0,78	3
CVE-2023-6248	8,8	9,2	0,45	8,125
CVE-2018-12892	7,8	8,3	0,62	6,5
CVE-2016-1473	9,8	10	0,95	7,75
CVE-2018-11215	7,5	8	0,68	8,15
CVE-2019-11991	8,1	8,6	0,72	6,75
CVE-2016-7404	6,5	7,1	0,35	9,05
CVE-2020-6170	7,2	7,8	0,58	6,345
CVE-2016-8964	5,3	6	0,25	5,55
CVE-2018-11653	8,8	9,2	0,82	6,85
CVE-2016-1112	7,5	8,1	0,65	7,25
CVE-2020-1026	7,8	8,3	0,75	4,125
CVE-2016-1279	9,8	10	0,97	5,525
CVE-2017-3185	7,5	8	0,6	6,375
CVE-2018-1337	6,5	7,1	0,3	4,85
CVE-2019-7305	7,8	8,3	0,7	5,125
CVE-2015-5959	5,5	6,2	0,22	6,75
CVE-2017-15597	8,1	8,6	0,65	9
CVE-2017-9000	7,2	7,8	0,55	6,005
CVE-2023-24838	8,8	9,2	0,8	7
CVE-2021-30168	7,5	8,1	0,68	5,45
CVE-2015-5041	6,5	7,1	0,32	8,875
CVE-2021-21596	8,8	9,2	0,85	8,875
CVE-2020-7819	7,8	8,3	0,72	9,05
CVE-2022-1650	9,8	10	0,96	8,875
CVE-2017-1000362	7,5	8,1	0,65	9,05
CVE-2023-6572	8,1	8,6	0,55	6,345
CVE-2024-55875	7,2	7,8	0,4	5,55
CVE-2023-39337	8,8	9,2	0,78	6,85

Таблица 24 – Расчёт нормированных значений калькуляторов CVE (CAPEC-298)

Уязвимости	Норм. CVSS v3,0	Норм. CVSS v4,0	Норм. EPSS	Норм. OWASP
CVE-2015-5729	0,75	0,81	0,078	0,3
CVE-2023-6248	0,88	0,92	0,045	0,8125
CVE-2018-12892	0,78	0,83	0,062	0,65
CVE-2016-1473	0,98	1	0,095	0,775
CVE-2018-11215	0,75	0,8	0,068	0,815
CVE-2019-11991	0,81	0,86	0,072	0,675
CVE-2016-7404	0,65	0,71	0,035	0,905
CVE-2020-6170	0,72	0,78	0,058	0,6345
CVE-2016-8964	0,53	0,6	0,025	0,555
CVE-2018-11653	0,88	0,92	0,082	0,685
CVE-2016-1112	0,75	0,81	0,065	0,725
CVE-2020-1026	0,78	0,83	0,075	0,4125
CVE-2016-1279	0,98	1	0,097	0,5525
CVE-2017-3185	0,75	0,8	0,06	0,6375
CVE-2018-1337	0,65	0,71	0,03	0,485
CVE-2019-7305	0,78	0,83	0,07	0,5125
CVE-2015-5959	0,55	0,62	0,022	0,675
CVE-2017-15597	0,81	0,86	0,065	0,9
CVE-2017-9000	0,72	0,78	0,055	0,6005
CVE-2023-24838	0,88	0,92	0,08	0,7
CVE-2021-30168	0,75	0,81	0,068	0,545
CVE-2015-5041	0,65	0,71	0,032	0,8875
CVE-2021-21596	0,88	0,92	0,085	0,8875
CVE-2020-7819	0,78	0,83	0,072	0,905
CVE-2022-1650	0,98	1	0,096	0,8875
CVE-2017-1000362	0,75	0,81	0,065	0,905
CVE-2023-6572	0,81	0,86	0,055	0,6345
CVE-2024-55875	0,72	0,78	0,04	0,555
CVE-2023-39337	0,88	0,92	0,078	0,685

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-298.Результаты представлены в таблице 25 ниже.

Таблица 25 – Расчёт критичности уязвимостей (CAPEC-298)

Уязвимость	Значение критичности
CVE-2015-5729	0,5733
CVE-2023-6248	0,7555
CVE-2018-12892	0,6564
CVE-2016-1473	0,8016
CVE-2018-11215	0,684
CVE-2019-11991	0,6813
CVE-2016-7404	0,6608
CVE-2020-6170	0,619
CVE-2016-8964	0,4872

Продолжение таблицы 25

Уязвимость	Значение критичности
CVE-2018-11653	0,724
CVE-2016-1112	0,6611
CVE-2020-1026	0,6069
CVE-2016-1279	0,7542
CVE-2017-3185	0,6349
CVE-2018-1337	0,5391
CVE-2019-7305	0,6255
CVE-2015-5959	0,5346
CVE-2017-15597	0,7433
CVE-2017-9000	0,6104
CVE-2023-24838	0,7275
CVE-2021-30168	0,6165
CVE-2015-5041	0,6548
CVE-2021-21596	0,7771
CVE-2020-7819	0,7283
CVE-2022-1650	0,8303
CVE-2017-1000362	0,7145
CVE-2023-6572	0,6711
CVE-2024-55875	0,5993
CVE-2023-39337	0,7239
CVE-2015-5729	0,5733

После приведения оценок риск-калькуляторов, нормированных оценок, и приведения критичности уязвимостей следующим этапом будет разложение шаблона на техники и составление из них сценариев атак

В таблице 26 приводится тактики и техники вместе с уязвимостями.

Таблица 26 – Соотнесение техник и тактик с уязвимостями CAPEC-298

Тактика	Техника	Эксплуатируемая уязвимость
Разведка	Активное сканирование (T1595)	CVE-2020-6170, CVE-2017-3185
	Топология сети (T1590.004)	CVE-2018-1337, CVE-2017-9000
Предотвращение обнаружения	Передача управляющих сигналов в трафике(T1205)	CVE-2017-9000, CVE-2023-24838, CVE-2020-7819
Обнаружение	Изучение сетевых служб(T1046)	CVE-2017-1000362, CVE-2023-6572
	Изучение сетевых подключений (T1049)	CVE-2019-11991, CVE-2016-8964
Организация управления	Протоколы(T1095)	CVE-2023-39337, CVE-2024-55875
Деструктивное воздействие	Точечный отказ в обслуживании(T1499)	CVE-2016-7404, CVE-2017-9000

На рисунке 7 представлена группа сценариев шаблона атаки CAPEC-298.

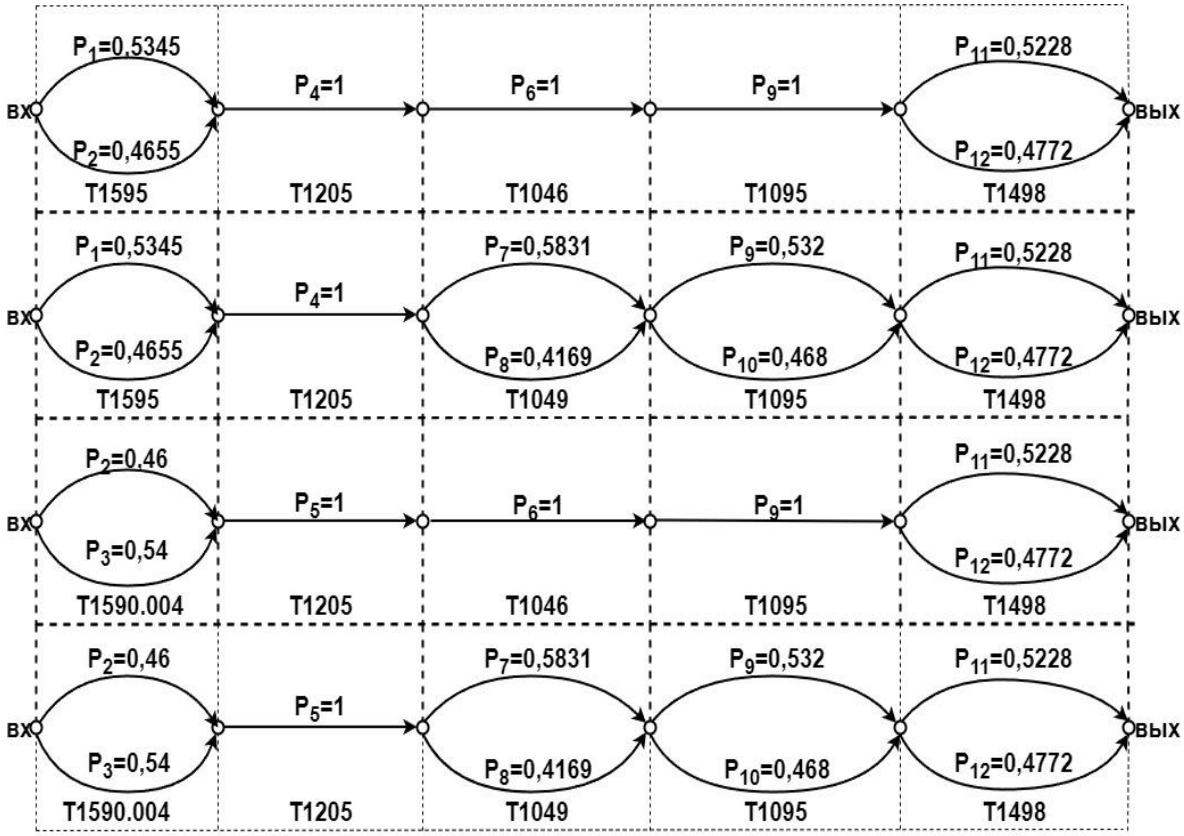


Рисунок 5 – Группа сценариев CAPEC-298

Цифрами обозначены следующие уязвимости:

1) CVE-2020-6170;
2) CVE-2018-1337;
3) CVE-2017-3185;
4) CVE-2017-9000;
5) CVE-2020-7819;
6) CVE-2017-1000362;
7) CVE-2019-11991;
8) CVE-2016-8964;
9) CVE-2019-11991
10) CVE-2024-55875
11) CVE-2023-39337;

12) CVE-2016-7404.

Результаты оценок для шаблона CAPEC-299 будут занесены в таблицы 27-28.

Таблица 27 – Расчёт калькуляторов CVE (CAPEC-299)

Уязвимости	CVSS v3,0	CVSS v4,0	EPSS	OWASP
CVE-2020-28333	7,5	8,1	0,68	5,525
CVE-2016-5757	6,5	7,1	0,45	8,875
CVE-2016-1265	9,8	10	0,95	8,875
CVE-2023-5642	8,8	9,2	0,52	9,05
CVE-2017-5158	7,8	8,3	0,72	6,345
CVE-2017-11510	8,1	8,6	0,65	5,55
CVE-2023-5576	7,5	8,1	0,48	6,75
CVE-2024-1222	8,2	8,7	0,35	9
CVE-2019-5016	7,2	7,8	0,6	6,005
CVE-2018-14822	9,8	10	0,97	7
CVE-2017-14443	8,8	9,2	0,82	4,125
CVE-2017-13664	7,5	8,1	0,58	5,525
CVE-2018-18941	6,5	7,1	0,3	6,375
CVE-2019-6572	7,8	8,3	0,75	4,85
CVE-2017-3972	5,3	6	0,25	3,85
CVE-2024-27905	8,1	8,6	0,42	6,345
CVE-2019-14892	7	7,6	0,55	9,05
CVE-2023-43791	7,5	8,1	0,38	8,875
CVE-2020-28333	7,5	8,1	0,68	5,525
CVE-2016-5757	6,5	7,1	0,45	8,875
CVE-2016-1265	9,8	10	0,95	8,875
CVE-2023-5642	8,8	9,2	0,52	9,05
CVE-2017-5158	7,8	8,3	0,72	6,345
CVE-2017-11510	8,1	8,6	0,65	5,55
CVE-2023-5576	7,5	8,1	0,48	6,75
CVE-2024-1222	8,2	8,7	0,35	9
CVE-2019-5016	7,2	7,8	0,6	6,005
CVE-2018-14822	9,8	10	0,97	7
CVE-2017-14443	8,8	9,2	0,82	4,125
CVE-2017-13664	7,5	8,1	0,58	5,525
CVE-2018-18941	6,5	7,1	0,3	6,375
CVE-2019-6572	7,8	8,3	0,75	4,85
CVE-2017-3972	5,3	6	0,25	3,85
CVE-2024-27905	8,1	8,6	0,42	6,345
CVE-2019-14892	7	7,6	0,55	9,05
CVE-2023-43791	7,5	8,1	0,38	8,875

Таблица 28 – Расчёт нормированных значений калькуляторов CVE (CAPEC-299)

Уязвимости	Норм. CVSS v3,0	Норм. CVSS v4,0	Норм. EPSS	Норм. OWASP
CVE-2020-28333	0,75	0,81	0,068	0,5525
CVE-2016-5757	0,65	0,71	0,045	0,8875
CVE-2016-1265	0,98	1	0,095	0,8875

Продолжение таблицы 28

Уязвимости	Норм. CVSS v3,0	Норм. CVSS v4,0	Норм. EPSS	Норм. OWASP
CVE-2023-5642	0,88	0,92	0,052	0,905
CVE-2017-5158	0,78	0,83	0,072	0,6345
CVE-2017-11510	0,81	0,86	0,065	0,555
CVE-2023-5576	0,75	0,81	0,048	0,675
CVE-2024-1222	0,82	0,87	0,035	0,9
CVE-2019-5016	0,72	0,78	0,06	0,6005
CVE-2018-14822	0,98	1	0,097	0,7
CVE-2017-14443	0,88	0,92	0,082	0,4125
CVE-2017-13664	0,75	0,81	0,058	0,5525
CVE-2018-18941	0,65	0,71	0,03	0,6375
CVE-2019-6572	0,78	0,83	0,075	0,485
CVE-2017-3972	0,53	0,6	0,025	0,385
CVE-2024-27905	0,81	0,86	0,042	0,6345
CVE-2019-14892	0,7	0,76	0,055	0,905
CVE-2023-43791	0,75	0,81	0,038	0,8875
CVE-2020-28333	0,75	0,81	0,068	0,5525
CVE-2016-5757	0,65	0,71	0,045	0,8875
CVE-2016-1265	0,98	1	0,095	0,8875
CVE-2023-5642	0,88	0,92	0,052	0,905
CVE-2017-5158	0,78	0,83	0,072	0,6345
CVE-2017-11510	0,81	0,86	0,065	0,555
CVE-2023-5576	0,75	0,81	0,048	0,675
CVE-2024-1222	0,82	0,87	0,035	0,9
CVE-2019-5016	0,72	0,78	0,06	0,6005
CVE-2018-14822	0,98	1	0,097	0,7
CVE-2017-14443	0,88	0,92	0,082	0,4125
CVE-2017-13664	0,75	0,81	0,058	0,5525
CVE-2018-18941	0,65	0,71	0,03	0,6375
CVE-2019-6572	0,78	0,83	0,075	0,485
CVE-2017-3972	0,53	0,6	0,025	0,385
CVE-2024-27905	0,81	0,86	0,042	0,6345
CVE-2019-14892	0,7	0,76	0,055	0,905
CVE-2023-43791	0,75	0,81	0,038	0,8875

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-299. Результаты представлены в таблице 29 ниже.

Таблица 29 – Расчёт критичности уязвимостей (CAPEC-299)

Уязвимость	Значение критичности
CVE-2015-5729	0,6182
CVE-2023-6248	0,655
CVE-2018-12892	0,8302
CVE-2016-1473	0,7814
CVE-2018-11215	0,6529
CVE-2019-11991	0,6534

Продолжение таблицы 29

Уязвимость	Значение критичности
CVE-2016-7404	0,6474
CVE-2020-6170	0,7484
CVE-2016-8964	0,6105
CVE-2018-11653	0,7842
CVE-2016-1112	0,6704
CVE-2020-1026	0,6179
CVE-2016-1279	0,5775
CVE-2017-3185	0,6201
CVE-2018-1337	0,4443
CVE-2019-7305	0,6708
CVE-2015-5959	0,6873
CVE-2017-15597	0,7085
CVE-2017-9000	0,6182
CVE-2023-24838	0,655
CVE-2021-30168	0,8302
CVE-2015-5041	0,7814
CVE-2021-21596	0,6529
CVE-2020-7819	0,6534
CVE-2022-1650	0,6474
CVE-2017-1000362	0,7484
CVE-2023-6572	0,6105
CVE-2024-55875	0,7842
CVE-2023-39337	0,6704
CVE-2015-5729	0,6179

После приведения оценок риск-калькуляторов, нормированных оценок, и приведения критичности уязвимостей следующим этапом будет разложение шаблона на техники и составление из них сценариев атак.

В таблице 30 приводится тактики и техники вместе с уязвимостями.

Таблица 30 – Соотнесение техник и тактик с уязвимостями CAPEC-299

Тактика	Техника	Эксплуатируемая уязвимость
Разведка	Активное сканирование (T1595)	CVE-2016-1265, CVE-2017-11510
	Топология сети (T1590.004)	CVE-2024-1222, CVE-2017-14443
Выполнение	Передача управляющих сигналов в трафике(T1203)	CVE-2016-5757, CVE-2018-14328
Предотвращение обнаружения	Изучение сетевых служб(T1046)	CVE-2017-13664, CVE-2019-6572
	Изучение сетевых подключений (T1049)	CVE-2017-3972

Продолжение таблицы 30

Тактика	Техника	Эксплуатируемая уязвимость
Обнаружение	Изучение открытых протоколов(T1010)	CVE-2023-43791, CVE-2024-21793
Обнаружение	Протоколы(T1095)	CVE-2018-18941 CVE-2018-0127
Деструктивное воздействие	Точечный отказ в обслуживании(T1498)	CVE-2016-1112, CVE-2020-6170

На рисунке 8 представлена группа сценариев шаблона атаки CAPEC-299.

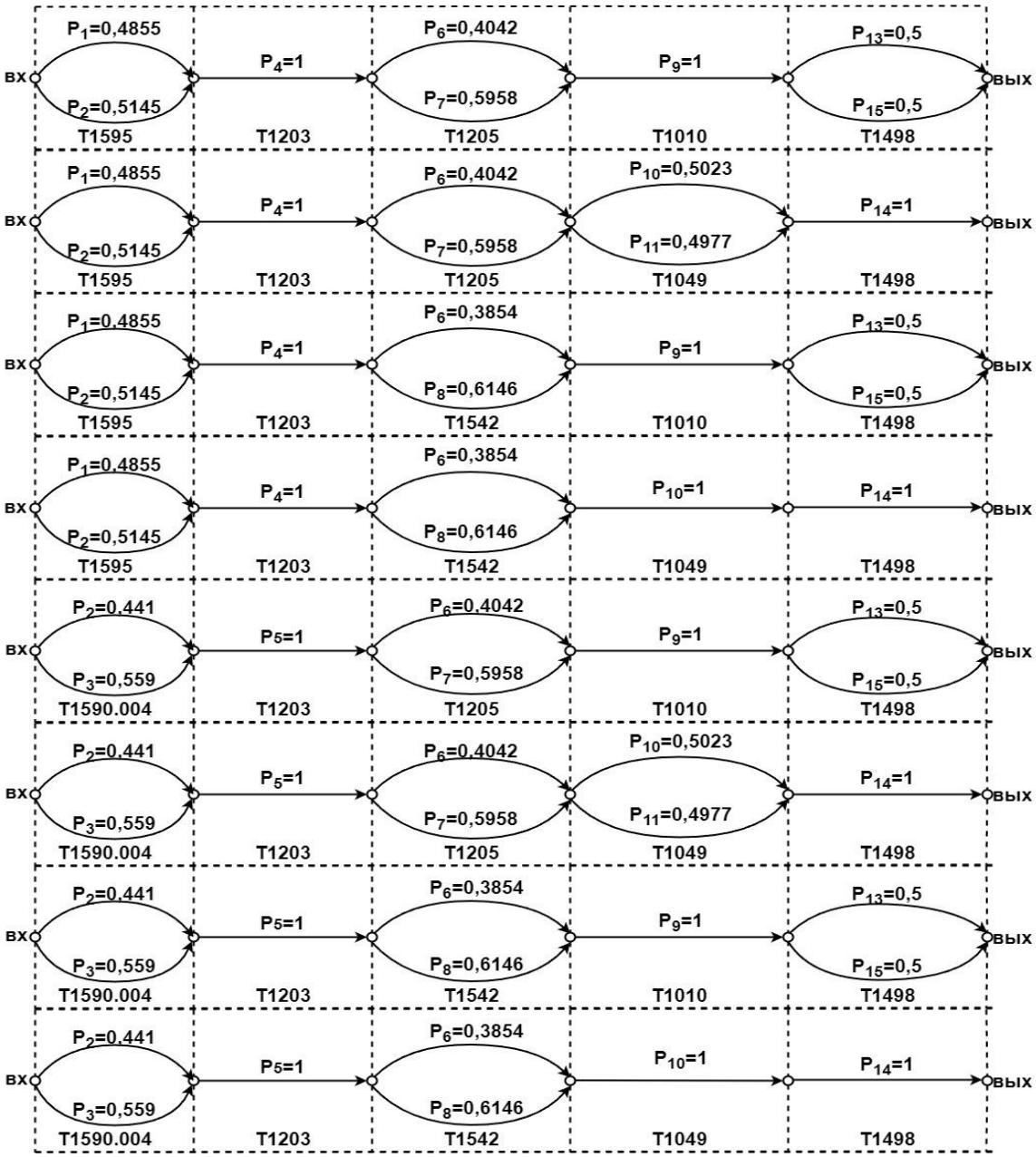


Рисунок 6 – Группа сценариев CAPEC-299

Цифрами обозначены следующие уязвимости:

1) CVE-2016-1265;
2) CVE-2017-11510;
3) CVE-2017-14443;
4) CVE-2016-5757;
5) CVE-2018-14328;
6) CVE-2017-13664;
7) CVE-2018-5726;
8) CVE-2019-6572;
9) CVE-2017-3972;
10) CVE-2023-43791;
11) CVE-2024-21793;
12) CVE-2018-18941;
13) CVE-2018-0127;
14) CVE-2016-1112;
15) CVE-2020-6170.

Результаты оценок для шаблона CAPEC-618 будут занесены в таблицы 31-32.

Таблица 31 – Расчёт калькуляторов CVE (CAPEC-618)

Уязвимости	CVSS v3,0	CVSS v4,0	EPSS	OWASP
CVE-2020-28333	7,5	8,1	0,68	6,005
CVE-2016-5757	6,5	7,1	0,45	7
CVE-2016-1265	9,8	10	0,95	4,125
CVE-2023-5642	8,8	9,2	0,52	5,525
CVE-2017-5158	7,8	8,3	0,72	4,125
CVE-2017-11510	8,1	8,6	0,65	5,525
CVE-2023-5576	7,5	8,1	0,48	6,375
CVE-2024-1222	8,2	8,7	0,35	4,85
CVE-2019-5016	7,2	7,8	0,6	8,875
CVE-2018-14822	9,8	10	0,97	8,005
CVE-2017-14443	8,8	9,2	0,82	9,05
CVE-2017-13664	7,5	8,1	0,58	6,345
CVE-2018-18941	6,5	7,1	0,3	5,55
CVE-2019-6572	7,8	8,3	0,75	5,45
CVE-2017-3972	5,3	6	0,25	8,875
CVE-2024-27905	8,1	8,6	0,42	8,875
CVE-2019-14892	7	7,6	0,55	9,05
CVE-2023-43791	7,5	8,1	0,38	8,875

Таблица 32 – Расчёт нормированных значений калькуляторов CVE (CAPEC-618)

Уязвимости	Норм. CVSS v3,0	Норм. CVSS v4,0	Норм. EPSS	Норм. OWASP
CVE-2020-28333	0,75	0,81	0,068	0,6005
CVE-2016-5757	0,65	0,71	0,045	0,7
CVE-2016-1265	0,98	1	0,095	0,4125
CVE-2023-5642	0,88	0,92	0,052	0,5525
CVE-2017-5158	0,78	0,83	0,072	0,4125
CVE-2017-11510	0,81	0,86	0,065	0,5525
CVE-2023-5576	0,75	0,81	0,048	0,6375
CVE-2024-1222	0,82	0,87	0,035	0,485
CVE-2019-5016	0,72	0,78	0,06	0,8875
CVE-2018-14822	0,98	1	0,097	0,8005
CVE-2017-14443	0,88	0,92	0,082	0,905
CVE-2017-13664	0,75	0,81	0,058	0,6345
CVE-2018-18941	0,65	0,71	0,03	0,555
CVE-2019-6572	0,78	0,83	0,075	0,545
CVE-2017-3972	0,53	0,6	0,025	0,8875
CVE-2024-27905	0,81	0,86	0,042	0,8875
CVE-2019-14892	0,7	0,76	0,055	0,905
CVE-2023-43791	0,75	0,81	0,038	0,8875

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-618. Результаты представлены в таблице 33 ниже.

Таблица 33 – Расчёт критичности уязвимостей (CAPEC-618)

Уязвимость	Значение критичности
CVE-2020-28333	0,6293
CVE-2016-5757	0,5955
CVE-2016-1265	0,7314
CVE-2023-5642	0,6944
CVE-2017-5158	0,6068
CVE-2017-11510	0,6529
CVE-2023-5576	0,6378
CVE-2024-1222	0,6453
CVE-2019-5016	0,6925
CVE-2018-14822	0,8079
CVE-2017-14443	0,7821
CVE-2017-13664	0,6373
CVE-2018-18941	0,5558
CVE-2019-6572	0,6324
CVE-2017-3972	0,5977
CVE-2024-27905	0,7391
CVE-2019-14892	0,6873
CVE-2023-43791	0,7085
CVE-2018-18941	0,7314

Продолжение таблицы 33

Уязвимость	Значение критичности
CVE-2019-6572	0,6944

После приведения оценок риск-калькуляторов, нормированных оценок, и приведения критичности уязвимостей следующим этапом будет разложение шаблона на техники и составление из них сценариев атак

В таблице 34 приводится тактики и техники вместе с уязвимостями.

Таблица 34 – Соотнесение техник и тактик с уязвимостями CAPEC-618

Тактика	Техника	Эксплуатируемая уязвимость
Разведка	Топология сети (T1590.001)	CVE-2016-1265, CVE-2017-5158
Предотвращение обнаружения	Загрузка раньше ОС (T1542)	CVE-2017-11510, CVE-2024-1222
Обнаружение	Изучение сетевых служб(T1046)	CVE-2017-13664, CVE-2018-18941
	Изучение сетевых подключений(T1049)	CVE-2017-3972, CVE-2019-14892
Организация управления	Протоколы(T1095)	CVE-2023-43791
Деструктивное воздействие	Точечный отказ в обслуживании(T1498)	CVE-2020-28333

На рисунке 9 представлена группа сценариев шаблона атаки CAPEC-618.

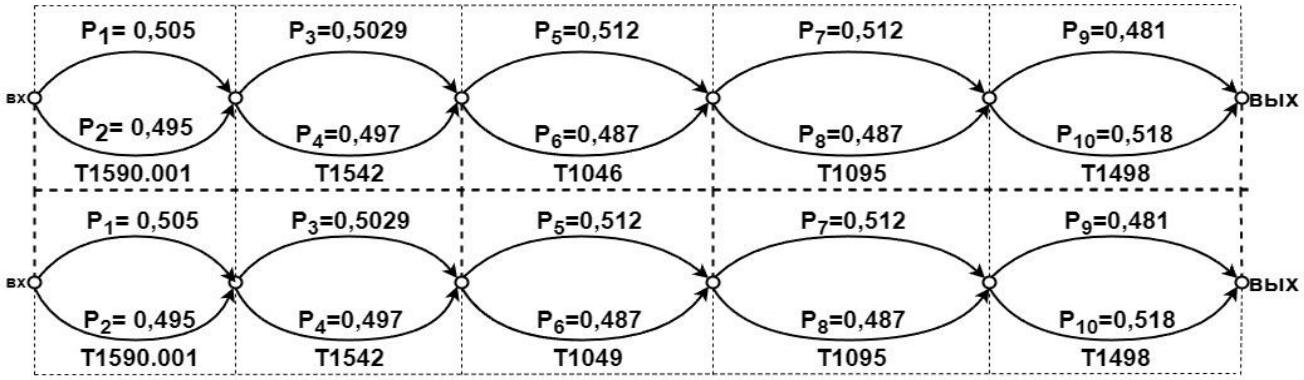


Рисунок 7 – Группа сценариев CAPEC-618

Цифрами обозначены следующие уязвимости:

1) CVE-2016-1265;
2) CVE-2017-5158;

3) CVE-2017-11510;

4) CVE-2024-1222;

5) CVE-2017-11510;

6) CVE-2017-3972;

7) CVE-2019-14892;

8) CVE-2023-43791;

9) CVE-2020-28333;

10) CVE-2020-6170.

В итоге, с использованием калькуляторов CVSS 3.0, CVSS 4.0, EPSS и OWASP были подсчитаны критичности рассматриваемых в контексте выделенных CAPEC класса «методы активного обнаружения узлов и сервисов» уязвимостей, а также построены модели сценариев выбранных векторов атак.

3.2 Анализ модели реализации техник сценариев атак

Считая, что в ходе атаки может быть использована лишь одна из рассматриваемых уязвимостей, вероятность её успешной эксплуатации определяется следующим образом (3) [1-9]:

$$p_i = \frac{K_i}{\sum_{i=1}^{n} k_i} \quad (3)$$

где: K_i – критичность i-ой уязвимости.

Для количественной оценки величины ущерба применяется формула (4), учитывающая ключевые параметры информационных активов и возможный вред от инцидента информационной безопасности [5, 6]:

$$U = 1 - (1 - U_{к})(1 - U_{ц})(1 - U_{д}) , \quad (4)$$

где Uк, Uц, Uд – показатели ущерба по трём основным аспектам информационной безопасности: конфиденциальность, целостность и доступность. Данные показатели берутся из ресурса CVSS [8] с областью допустимых значений 0-1.

На основании полученных значений можно определить степень критичности уязвимости в контексте её эксплуатации с использованием соответствующей атакующей техники. При этом риск определяется (5) как произведение вероятности эксплуатации каждой отдельной уязвимости P_i на величину соответствующей ей ущерб U_i:

$$Risk = Pi \times Ui\ . \tag{5}$$

Для расчёта общего риска по всему сценарию атаки используется формула (6), которая учитывает совокупную эксплуатацию всех входящих в сценарий уязвимостей [9]:

$$Risk_{\sum} \quad = \prod_{i=1}^{k} P_{i} \times \sum_{j=1}^{k} U_{j}, \tag{6}$$

где k – количество используемых техник.

В качестве примера рассмотрим шаблон CAPEC-618. В таблице 1 приведены вероятности эксплуатации и ущербы уязвимостей.

Перейдём к разбору CAPEC-297.

В таблице 35 приведены вероятности эксплуатации единичной уязвимости и ущерб.

Таблица 35 – Вероятность и ущерб эксплуатации уязвимостей для микромоделей сценария CAPEC-297

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемых систем	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Ущерб эксплуатируемой уязвимости	Вероятность успешной эксплуатации уязвимостей атакуемой системы
1	2	3	4	5	6
CAPEC-297	T1595	CVE-2017-18345	0,6782	0,9148	0,5246383
		CVE-2023-28765	0,6145	0,9148	0,4753616
	T1590.004	CVE-2017-18345	0,6782	0,9148	0,5246383
		CVE-2024-38200	0,6444	0,9148	0,4753616
	T1203	CVE-2015-0310	0,7798	0,9148	1
		CVE-2018-20555	0,6724	0,56	1
	T1134	CVE-2024-21793	0,7116	0,9148	0,4663171
		CVE-2008-0655	0,8144	0,9148	0,5336828
	T1046	CVE-2018-0127	0,591	0,56	1
	T1049	CVE-2018-0127	0,591	0,56	0,5606678
		CVE-2018-7251	0,4631	0,56	0,4393321
	T1498	CVE-2017-11165	0,7898	0,9148	0,5562755
		CVE-2018-14328	0,63	0,9148	0,4437244

Перейдём к расчёту рисков сценариев. На рисунках 10-13 представлены группы сценариев CAPEC-297.

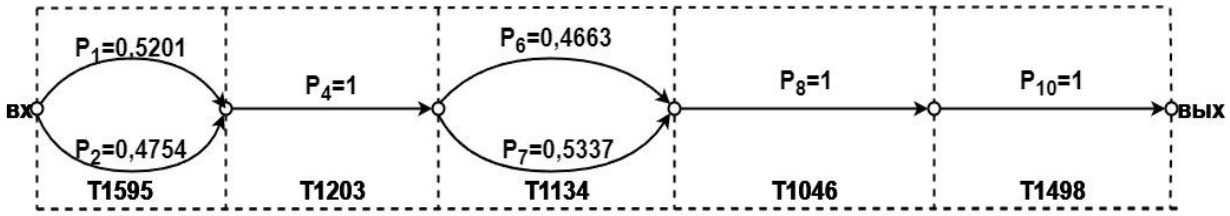


Рисунок 10 – Модель группы сценариев 1 CAPEC-297

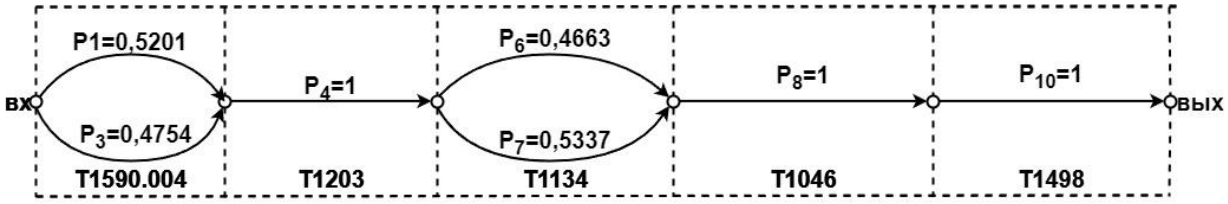


Рисунок 11 – Модель группы сценариев 2 CAPEC-297

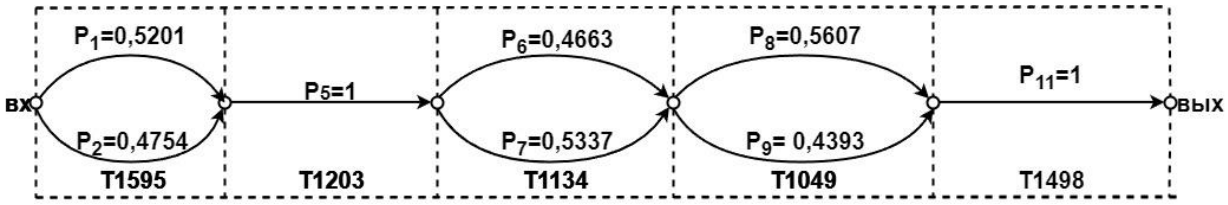


Рисунок 12 – Модель группы сценариев 3 CAPEC-297

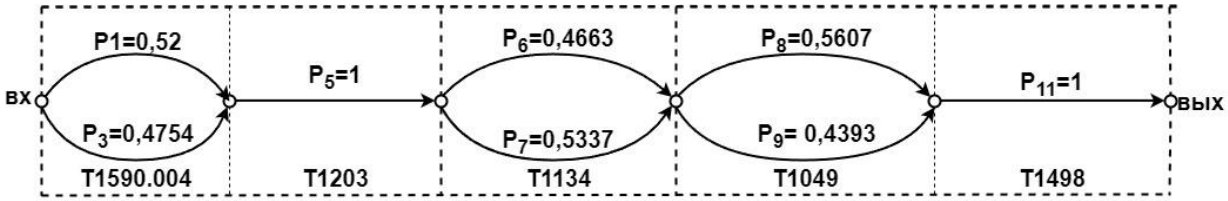


Рисунок 13 – Модель группы сценариев 4 CAPEC-297

В таблице 36 – 39 проведены расчёты рисков для CAPEC-297.

Таблица 36 – Наибольшие риски для группы сценариев 1 CAPEC-297

Техника (Уязвимости)	Риск
T1595(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,1032
T1595(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,0935
T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,1181
T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,107

Максимальный риск: T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)= 0,1181.

Таблица 37 – Наибольшие риски для группы сценариев 2 CAPEC-297

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,0945
T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,1082

Продолжение таблицы 37

Техника (Уязвимости)	Риск
T1590.004(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,0878
T1595(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,1005

Максимальный риск: T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165)= 0,1082.

Таблица 38 – Наибольшие риски для группы сценариев 3 CAPEC-297

Техника (Уязвимости)	Риск
T159(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,5787
T1595(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,4535
T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,6623
T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,519
T1595(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,5244
T1595(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,4109
T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,6001
T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-0127)-> T1498(CVE-2017-11165)	0,4703

Максимальный риск: T1595(CVE-2023-28765)-> T1203(CVE-2015-0310)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)= 0,6623.

Таблица 39 – Наибольшие риски для группы сценариев 4 CAPEC-297

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,5301
T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,4154
T1590.004(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,6066
T1590.004(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)	0,4754
T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,4923
T1590.004(CVE-2017-18345)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,3857
T1590.004(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,5634
T1590.004(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2008-0655)-> T1049(CVE-2018-7251)-> T1498(CVE-2018-14328)	0,4415

Наибольший риск: T1590.004(CVE-2023-28765)-> T1203(CVE-2018-20555)-> T1134(CVE-2024-21793)-> T1049(CVE-2018-0127)-> T1498(CVE-2018-14328)= 0,6066.

Сценарий с наименьшим риском: T1595(CVE-2017-18345)-> T1203(CVE-2015-0310)-> T1134(CVE-2008-0655)-> T1046(CVE-2018-0127)-> T1498(CVE-2017-11165) =0,0935

По итогу расчётов замечаем, что наибольший риск составляет 3 сценарий с 0,6623. Он является наиболее вероятным. На рисунке 14 представлен путь с наибольшим риском.

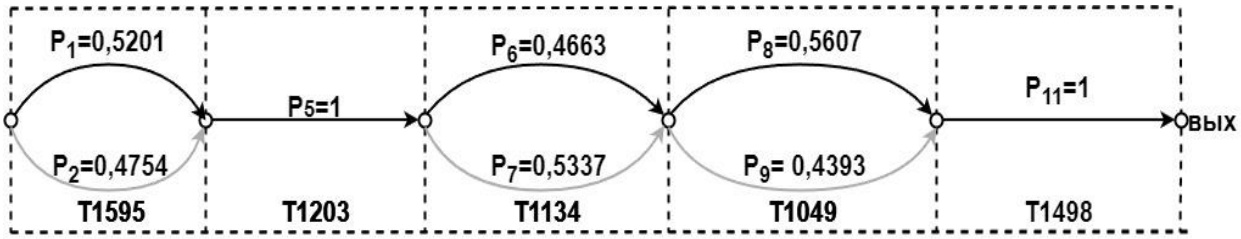


Рисунок 14 – Путь с наибольшим риском для основного сценария CAPEC-297

Дальше приступим к рассмотрению шаблона CAPEC-298. В таблице 40 приведены вероятности эксплуатации единичной уязвимости и ущерб.

Таблица 40 – Вероятность эксплуатации единичной уязвимости и ущерб для микромоделей сценария CAPEC-298

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемых систем	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Ущерб эксплуатируемой уязвимости	Вероятность успешной эксплуатации уязвимостей атакуемой системы
1	2	3	4	5	6
CAPEC-298	T1595	CVE-2020-6170	0,619	0,6568	0,5344961
		CVE-2018-1337	0,5391	0,56	0,4655038
	T1590.004	CVE-2018-1337	0,5391	0,56	0,4655038
		CVE-2017-3185	0,6349	0,9148	0,5408006
	T1205	CVE-2017-9000	0,6104	0,56	1
		CVE-2020-7819	0,7283	0,9148	1
	T1046	CVE-2017-1000362	0,7145	0,9148	1
	T1049	CVE-2019-11991	0,6813	0,9148	0,5830551
		CVE-2016-8964	0,4872	0,56	0,4169448
	T1095	CVE-2019-11991	0,6813	0,9148	1
		CVE-2019-11991	0,6813	0,9148	0,5320162
		CVE-2024-55875	0,5993	0,9148	0,4679837
	T1498	CVE-2023-39337	0,7239	0,56	0,5227847
		CVE-2016-7404	0,6608	0,9148	0,4772152

Перейдём к расчёту рисков сценариев. На рисунках 15-18 представлены группы сценариев CAPEC-298.

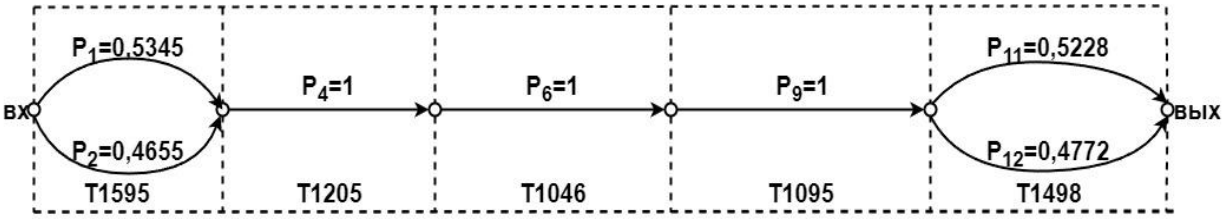


Рисунок 15 – Модель группы сценариев 1 для CAPEC-298

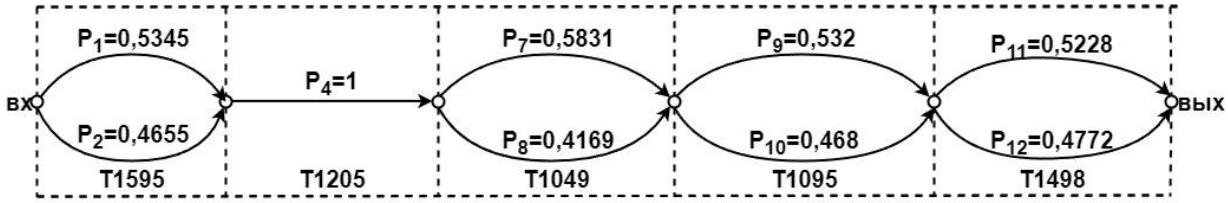


Рисунок 16 – Модель группы сценариев 2 для CAPEC-298

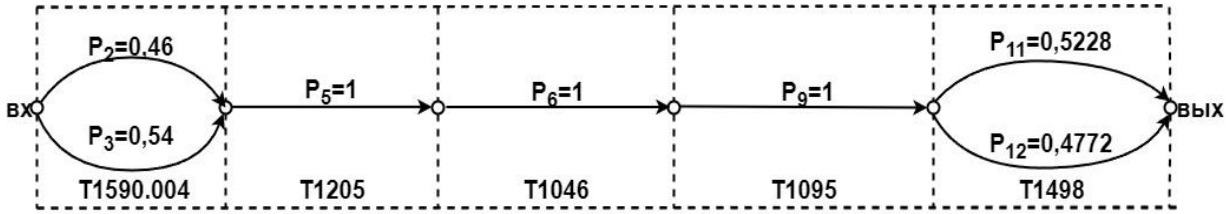


Рисунок 17 – Модель группы сценариев 3 для CAPEC-298

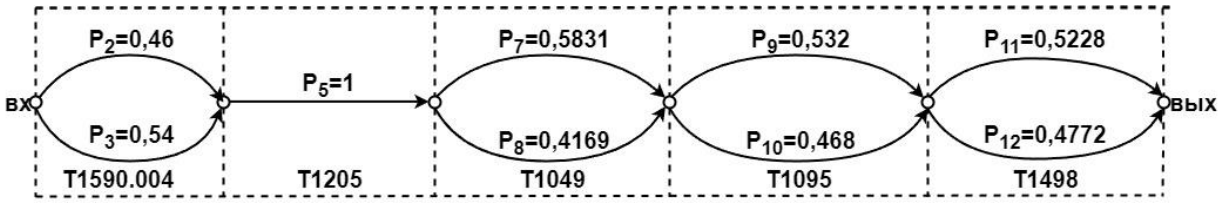


Рисунок 18 – Модель группы сценариев 4 для CAPEC-298

В таблице 41-44 проведены расчёты рисков для CAPEC-298.

Таблица 41– Наибольший риск для группы сценариев 1 CAPEC-298

Техника (Уязвимости)	Риск
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,1008
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,101
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,8541
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,8585

Максимальный риск: T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)= 0,8585.

Таблица 42– Наибольший риск для группы сценариев 2 CAPEC-298

Техника (Уязвимости)	Риск
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,8441
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,8485
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,1093
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,1089

Максимальный риск: T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)= 0,8485.

Таблица 43 – Наибольший риск для группы сценариев 3 CAPEC-298

Техника (Уязвимости)	Риск
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,3126
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,3134
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,2757
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,1795
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,2041
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,2015
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,275
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,2015
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,2649
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,2663
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,2342

Продолжение таблицы 43

Техника (Уязвимости)	Риск
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,1521
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,1729
T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,1703
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,233
T1595(CVE-2018-1337)-> T1205(CVE-2017-9000)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,1703

Максимальный риск: T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)= 0,3134.

Таблица 44 – Наибольший риск для группы сценариев 4 CAPEC-298

Техника (Уязвимости)	Риск
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,2649
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,2663
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,2342
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,1521
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,1729
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,1703
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,233
T1590.004(CVE-2018-1337)-> T1205(CVE-2020-7819)-> T1049(CVE-2019-11991)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,1703
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,3389
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,3378
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,2971
T1595(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1046(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,1946
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)	0,2212
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2016-7404)	0,2201

Продолжение таблицы 44

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2023-39337)	0,2981
T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2024-55875)-> T1498(CVE-2016-7404)	0,2201

Максимальный риск: T1590.004(CVE-2017-3185)-> T1205(CVE-2020-7819)-> T1049(CVE-2016-8964)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)= 0,3389.

Сценарий с минимальным риском: T1595(CVE-2020-6170)-> T1205(CVE-2017-9000)-> T1046(CVE-2017-1000362)-> T1095(CVE-2019-11991)-> T1498(CVE-2023-39337)= 0,1008.

По итогу расчётов замечаем, что наибольший риск составляет 1 сценарий с 0,8585. Он также является наиболее вероятным. На рисунке 19 представлен путь с наибольшим риском.

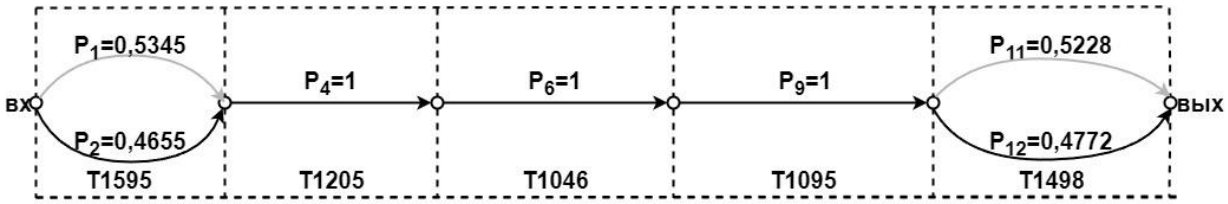


Рисунок 19 – Путь с наибольшим риском для основного сценария CAPEC-298

Дальше приступим к рассмотрению шаблона CAPEC-299. В таблице 45 приведены вероятности эксплуатации единичной уязвимости и ущерб.

Таблица 45 – Вероятность эксплуатации единичной уязвимости и ущерб для микромоделей сценария CAPEC-299

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемых систем	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Ущерб эксплуатируемой уязвимости	Вероятность успешной эксплуатации уязвимостей атакуемой системы
CAPEC-299	T1595	CVE-2016-1265	0,6182	0,56	0,48554822
		CVE-2017-11510	0,655	0,9148	0,51445177
	T1590.004	CVE-2017-11510	0,655	0,9148	0,44101804
	T1590.004	CVE-2017-14443	0,8302	0,9148	0,55898195
	T1203	CVE-2016-5757	0,7814	0,56	1
		CVE-2018-14328	0,5775	0,9148	1
	T1205	CVE-2017-13664	0,4443	0,9148	0,40416628
		CVE-2017-13664	0,655	0,9148	0,5958337
	T1542	CVE-2018-5726	0,4443	0,9148	0,3854094
		CVE-2019-6572	0,7085	0,56	0,6145905
	T1010	CVE-2017-3972	0,655	0,9148	1
		CVE-2018-18941	0,6529	0,9148	1
		CVE-2024-21793	0,6529	0,9148	1
	T1049	CVE-2023-43791	0,6534	0,9148	0,5023062
		CVE-2023-43791	0,6474	0,9148	0,4976937
	T1498	CVE-2018-0127	0,7484	0,56	0,5
		CVE-2016-1112	0,7484	0,6568	0,5
		CVE-2020-6170	0,6704	0,9148	1

Перейдём к расчёту рисков сценариев. На рисунках 20-27 представлены группы сценариев CAPEC-299.

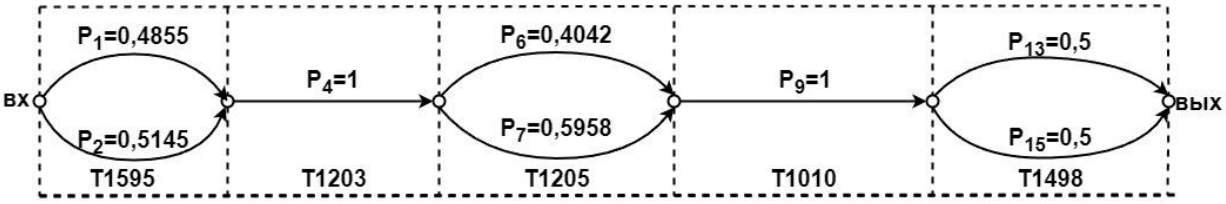


Рисунок 20 – Модель группы сценариев 1 для CAPEC-299

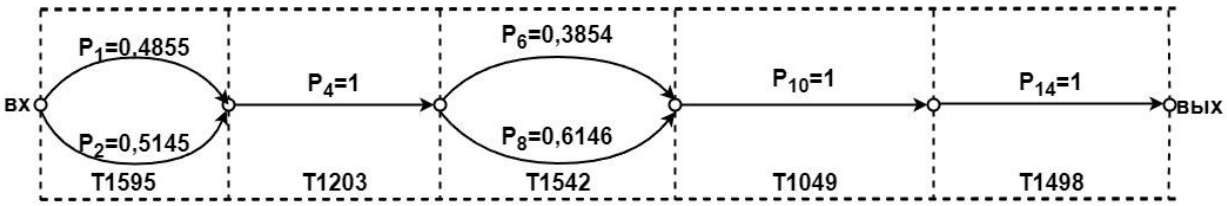


Рисунок 21 – Модель группы сценариев 2 для CAPEC-299

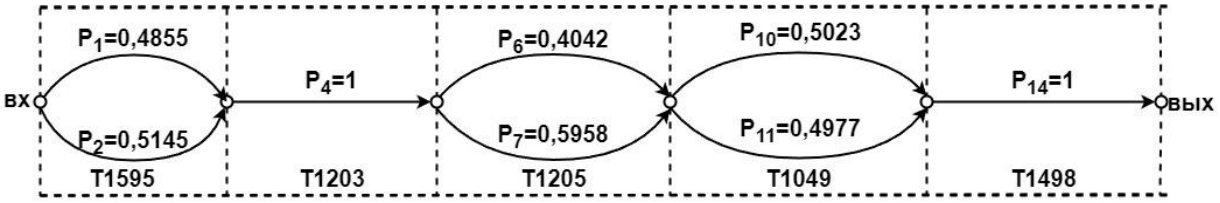


Рисунок 22 – Модель группы сценариев 3 для CAPEC-299

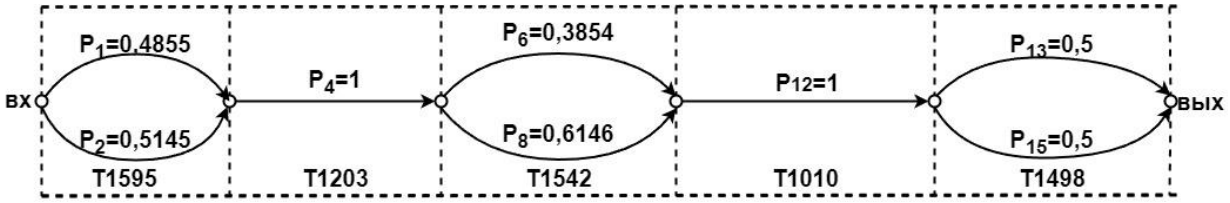


Рисунок 23 – Модель группы сценариев 4 для CAPEC-299

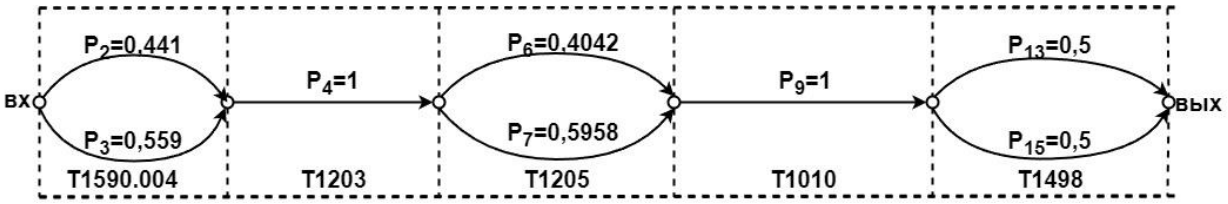


Рисунок 24 – Модель группы сценариев 5 для CAPEC-299

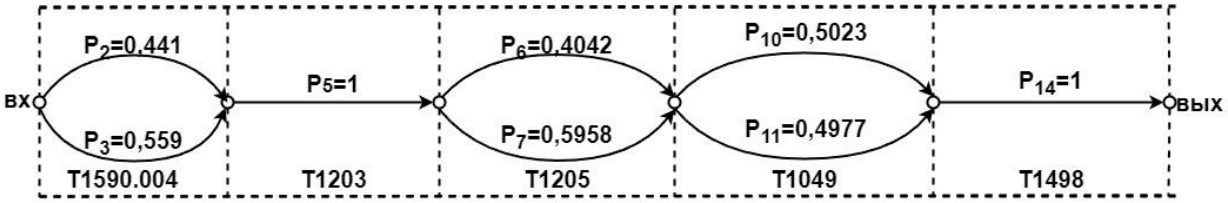


Рисунок 25 – Модель группы сценариев 6 для CAPEC-299

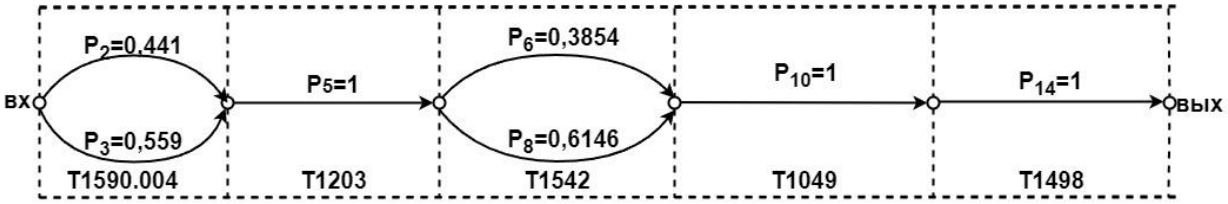


Рисунок 26 – Модель группы сценариев 7 для CAPEC-299

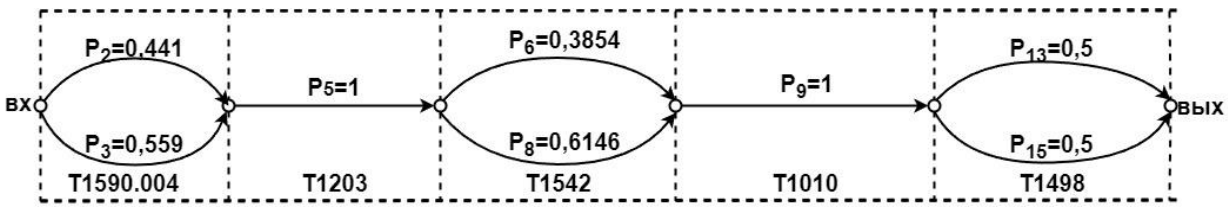


Рисунок 27 – Модель группы сценариев 8 для CAPEC-299

В таблице 46 – 53 проведены расчёты рисков для CAPEC-298.

Таблица 46 – Риск для группы сценариев 1 CAPEC-299

Техника (Уязвимости)	Риск
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,3444
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,3539
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,3539
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,5077
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,4018
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,4118
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,4118
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,5923

Наибольший риск: T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)= 0,5923.

Таблица 47 – Риск для группы сценариев 2 CAPEC-299

Техника (Уязвимости)	Риск
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,3809
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,7584
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,0556
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,5616
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,4407
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,8773
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,0644
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,6496

Наибольший риск: T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1205(CVE-2017-3972)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)= 0,8773

Таблица 48 – Риск для группы сценариев 3 CAPEC-299

Техника (Уязвимости)	Риск
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,7232
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,1047
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,8366
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,1222

Наибольший риск: T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)= 0,8366.

Таблица 49 – Риск для группы сценариев 4 CAPEC-299

Техника (Уязвимости)	Риск
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,3284
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,3374
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,4707
T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,4852
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,3831
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,3927
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,5548
T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,5701

Наибольший риск: T1598(CVE-2017-11510)-> T1203(CVE-2016-5757)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)= 0,5701.

Таблица 50 – Риск для группы сценариев 5 CAPEC-299

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,376
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,3847
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,3847
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,5544
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,4766
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,4875
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2018-0127)	0,4875
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)	0,7026

Наибольший риск: T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1010(CVE-2017-3972)-> T1498(CVE-2020-6170)= 0,7026.

Таблица 51 – Риск для группы сценариев 6 CAPEC-299

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,4095
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,8153
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,0598
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,6037
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,5191
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,1033
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,0758
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1205(CVE-2018-5726)-> T1049(CVE-2024-21793)-> T1498(CVE-2016-1112)	0,7652

Наибольший риск: T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1205(CVE-2017-3972)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)= 0,8153.

Таблица 52 – Риск для группы сценариев 7 CAPEC-299

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,7775
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,1144
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,9854
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)	0,145

Наибольший риск: T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)= 0,9854.

Таблица 53 – Риск для группы сценариев 8 CAPEC-299

Техника (Уязвимости)	Риск
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,3586
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,3668
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,5237
T1590.004(CVE-2017-11510)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,5368
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,4545
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2017-1366)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,4649
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2018-0127)	0,6638
T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)	0,6804

Наибольший риск: T1590.004(CVE-2017-14443)-> T1203(CVE-2018-14328)-> T1542(CVE-2019-6572)-> T1010(CVE-2018-18941)-> T1498(CVE-2020-6170)= 0,6804.

Сценарий с наименьшим риском: T1598(CVE-2016-1265)-> T1203(CVE-2016-5757)-> T1205(CVE-2018-5726)-> T1049(CVE-2023-43791)-> T1498(CVE-2016-1112)= 0,0556.

По итогу расчётов замечаем, что наибольший риск составляет 7 сценарий с 0,9854. Он также является наиболее вероятным. На рисунке 28 представлен путь с наибольшим риском.

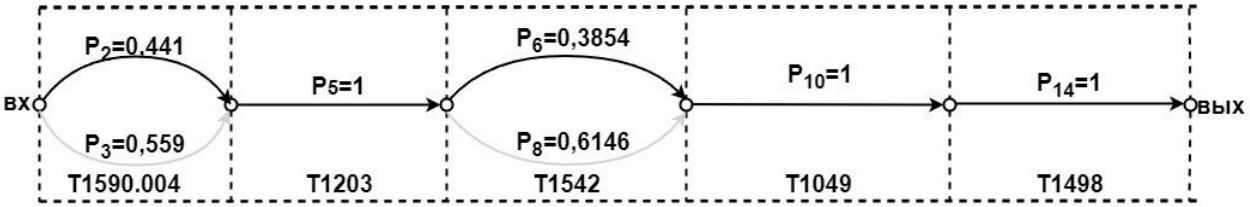


Рисунок 28 – Путь с наибольшим риском для основного сценария CAPEC-299

Дальше приступим к рассмотрению шаблона CAPEC-618. В таблице 54 приведены вероятности эксплуатации единичной уязвимости и ущерб.

Таблица 54 – Вероятность эксплуатации единичной уязвимости и ущерб для микромоделей сценария CAPEC-618

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемых систем	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Ущерб эксплуатируемой уязвимости	Вероятность успешной эксплуатации уязвимостей атакуемой системы
CAPEC-618	T1590.001	CVE-2016-1265	0,6182	0,8064	0,5046530
		CVE-2017-5158	0,6068	0,8064	0,4953469
	T1542	CVE-2017-11510	0,6529	0,9148	0,5029271
		CVE-2024-1222	0,6453	0,8064	0,4970728
	T1046	CVE-2017-11510	0,6293	0,9148	0,5128769
		CVE-2017-3972	0,5977	0,56	0,4871230
	T1049	CVE-2017-11510	0,6293	0,9148	0,5128769
		CVE-2017-3972	0,5977	0,56	0,4871230
	T1095	CVE-2019-14892	0,6873	0,56	0,4924057
		CVE-2023-43791	0,7085	0,22	0,5075942
	T1498	CVE-2020-28333	0,6944	0,8064	0,4812863
		CVE-2020-6170	0,7484	0,6568	0,5187136

Перейдём к расчёту рисков сценариев. На рисунках 29-30 представлены группы сценариев CAPEC-618.

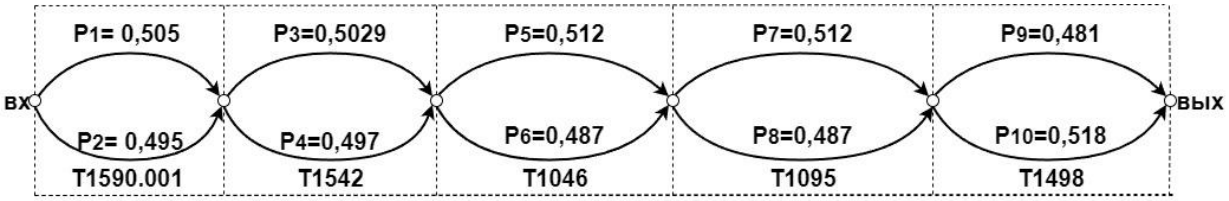


Рисунок 29 – Модель группы сценариев 1 для CAPEC-618

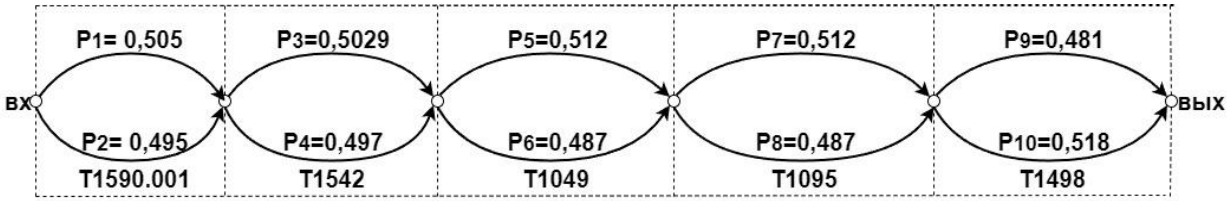


Рисунок 30 – Модель группы сценариев 3 для CAPEC-618

В таблице 55 – 56 проведены расчёты рисков для CAPEC-618.

Таблица 55 –Риск для группы сценариев 1 CAPEC-618

Техника (Уязвимости)	Риск
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2507
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2601
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,217
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2243
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2411
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2499
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2081
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2148
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2461
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2553
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,213
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2202
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2367
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2453
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2043
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1046(CVE-2017-3972)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2109

Максимальный риск: T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1046(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)= 0,2601.

Таблица 56 –Риск для группы сценариев 2 CAPEC-618

Техника (Уязвимости)	Риск
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2407
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2498
T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-28333)	0,2271
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-6170)	0,2347
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2315
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2399
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-28333)	0,2178
T1590.001(CVE-2016-1265)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-6170)	0,2249
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2363
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2452
T1590.001(CVE-2017-5158)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-28333)	0,2229
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-6170)	0,2304
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-28333)	0,2272
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)	0,2355
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-28333)	0,2138
T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-6170)	0,2207

Максимальный риск: T1590.001(CVE-2016-1265)-> T1542(CVE-2017-11510)-> T1049(CVE-2017-11510)-> T1095(CVE-2019-14892)-> T1498(CVE-2020-6170)= 0,2498.

Сценарий с наименьшим риском: T1590.001(CVE-2017-5158)-> T1542(CVE-2024-1222)-> T1049(CVE-2017-11510)-> T1095(CVE-2023-43791)-> T1498(CVE-2020-28333)= 0,2138.

По итогу расчётов замечаем, что наибольший риск составляет 1 сценарий с 0,2601. Он также является наиболее вероятным. На рисунке 31 представлен путь с наибольшим риском.

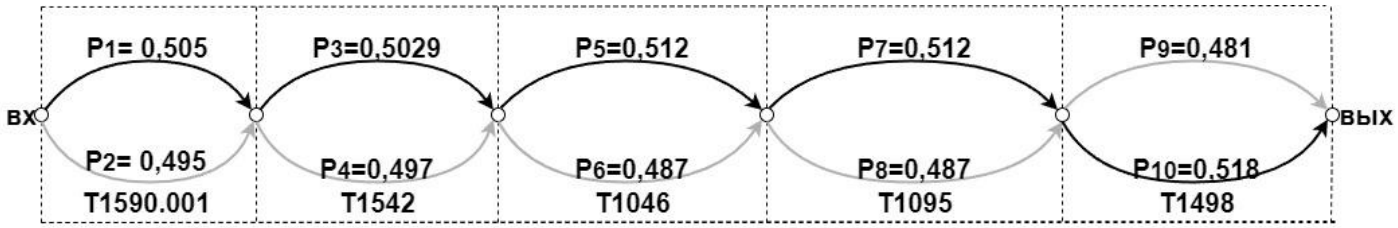


Рисунок 31 – Путь с наибольшим риском для основного сценария CAPEC-618

4. Противодействие инцидентам информационной безопасности

4.1 Регламенты реагирования и ликвидации последствий

На основе проведённого анализа возможных сценариев инцидентов информационной безопасности перейдём к разработке конкретных мер реагирования и ликвидации их последствий. Основой для формирования эффективных и оперативных действий при возникновении угроз в современных автоматизированных информационных системах (АИС) являются частные регламенты – документы, описывающие действия служб информационной безопасности на всех этапах обнаружения, реагирования и восстановления после инцидента.

При разработке данных мер особое внимание уделялось использованию метода анализа открытых источников информации, который является одним из наиболее продуктивных подходов при построении стратегии защиты.

В качестве основных источников информации были использованы международные и отраслевые базы данных:

1) CAPEC (Common Attack Pattern Enumeration and Classification) – содержит классификацию стандартных сценариев атак;

2) MITRE ATT&CK – фреймворк, описывающий тактики и техники, применяемые киберпреступниками на всех этапах кибератаки;

3) NIST (National Institute of Standards and Technology) – источник методических рекомендаций, стандартов и руководств по управлению инцидентами ИБ [76-80].

В процессе составления регламентов противодействия также учитывались нормативно-правовые акты и методические документы, регулирующие вопросы обеспечения информационной безопасности, в частности использовался регламент по классификации автоматизированных информационных систем.

В документации противодействия инцидентам безопасности будет отражена связь между уязвимостями, этапами атаки и с непосредственными мерами реагирования, ликвидации последствий.

В таблице 57 приводятся меры противодействия против CAPEC-297.

Таблица 57 – Организационно-правовой регламент противодействия CAPEC-297

Этапность реализации кибератак, рекомендована MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Разведка	Частые запросы TCP протокола в сети без окончания соединения сигнализируют о использовании техники T1595 или T1590.004 с эксплуатацией уязвимости CVE-2023-28765 или CVE-2017-18345.	1. Требуется настроить мониторинг внутреннего трафика ЛВС через SIEM . 2. Требуется настроить на маршрутизаторах ACL с блокировкой IP адресов. 3. Настройка инспектирования HTTP трафика через WAF [82-85].	1. Обновить Apache Struts до версии 2.5.10.1 для устранения CVE-2017-18345. 2. Обновление библиотеки Log4j для устранения уязвимости CVE-2023-28765. 3. Принудительное закрытие "висящих" TCP-сессий через iptables -F или сброс состояния фаервола. 4. Отключить функцию JNDI (Java Naming and Directory Interface), если она не используется, путем добавления параметра -Dlog4j2.formatMsgNoLookups=true.
Выполнение	Частое обращение к клиентской основе сигнализирует о использовании техники T1203 с эксплуатацией уязвимости CVE-2015-0310 или CVE-2018-20555.	1. Настроить фильтрацию IPS на основе собственно созданных профилей для 443 порта. 2. Внедрение WAF с правилами корреляции HTTPS. Перегенерировать сертификаты «openssl req -x509 -newkey rsa:4096 -nodes -subj" /CN=yourdomain.com" »	1. Обновить версию OpenSSL до 1.0.1g для устранения уязвимости CVE-2015-0310. 2. Обновите Apache Tomcat для устранения уязвимости CVE-2018-20555. 3. Проверка на наличие бэкдоров (chkrootkit, rkhunter) [86-90]. 4. Удаление подозрительных файлов (например, web shells в /tmp/ или /var/www/.

Продолжение таблицы 57

1	2	3	4
Предотвращение обнаружения	Повышенная активность в сети с частой подменой токенов сигнализирует о использовании техники T1134 с эксплуатацией уязвимости CVE-2024-21793 или CVE-2008-0655.	1. Внедрение в SIEM правила фильтрации трацика «title: Network Port Scanning Detection description: Detects multiple port scans logsource: category: firewall event_type: "firewall_deny" aggregation: src_ip: count: >20 timeframe: 5m condition: selection and aggregation falsepositives: - Legitimate network scanners (если есть разрешённые сканеры) level: medium ». 2. Настройка правил NTA для поиска аномальных сессий. 3. Внедрения WNAM для настройки многофактороной аутентификации.	1. Обновление Apache HTTP Server для устранения 2024-21793. 2. Обновление PHPMailer для устранения уязвимости CVE-2008-0655. 3. Принудительный инвалидацция всех активных сессий через IAM-систему (например, Keycloak или Okta). 4. Внедрение механизма CAPTCHA.
Обнаружение	Появление огромного потока данных TCP SYN пакетов показывают, что используется техника T1049 или T1046 с эксплуатацией уязвимости CVE-2018-0127	1. Внедрения СОВ с правилом обнаружения сканирования «alert tcp any any -> $HOME_NET any (msg:"Port Scanning Detected (TCP)"; flow:stateless; flags:S; threshold: type both, track by_src, count 20, seconds 10; classtype:attempted-recon; sid:1000002; rev:1;) » . 2. Блокировка или ограничение [91]SYN Cookies на серверах «# Включение SYN Cookies (активно при перегрузке) echo "net.ipv4.tcp_syncookies = 1" >> /etc/sysctl.conf # Уменьшение времени ожидания SYN echo "net.ipv4.tcp_synack_retries = 3" >> /etc/sysctl.conf # Ограничение очереди SYN echo "net.ipv4.tcp_max_syn_backlog = 2048" >> /etc/sysctl.conf	1. Обновить версию операционной системы Windows или перейти на опенсорсные аналоги Linux для устранения уязвимости CVE-2018-0127. 2. Настройка SYN cookies на Linux-серверах: sysctl -w net.ipv4.tcp_syncookies= 3. Определение типа атаки (SYN-флуд, UDP) через tcpdump [92].

Продолжение таблицы 57

1	2	3	4
Деструктивное воздействие	В случае внештатной недоступности узла по сети это указывает на использование техники T1498 с эксплуатацией уязвимости CVE-2018-14328 или CVE-2018-7251	1. Обнаружение уязвимых устройств «nmap -sV --script upnp-info -p 1900,5000 <target_IP>». 2. Проверка версии libupnp «dpkg -l | grep libupnp # Для Debian/Ubuntu rpm -qa | grep libupnp # Для CentOS/RHEL» 3. Обнаружение активности «alert tcp any any -> $HOME_NET 44818 (msg:"Possible CVE-2018-7251 Exploit"; content: sid:1000005; rev:1;)»	1. Провести обновление «sudo apt update && sudo apt upgrade libupnp-dev libupnp6» для устранения CVE-2018-14328. 2.Обновить версию прошивки Logix Controllers и Studio 5000 для устранения CVE-2018-7251 3. Запуск failover-кластера (если есть) [93].

Регламенты противодействия CAPEC-298, CAPEC-299, CAPEC-618 приводятся в приложении.

4.2 Регулирование рисков

Для минимизации рисков, связанных с воздействием атак класса «Методы активного обнаружения узлов и сервисов» на инфраструктуру организации, будут разработаны и реализованы схемы, направленные на ограничение возможностей для проведения подобных атак до уровня, близкого к минимально допустимому. Кроме того, будут определены и рекомендованы к внедрению меры по устранению уязвимостей в существующей ИТ-инфраструктуре.

Первым на разборе будет шаблон CAPEC-297, указанный на рисунке 32.

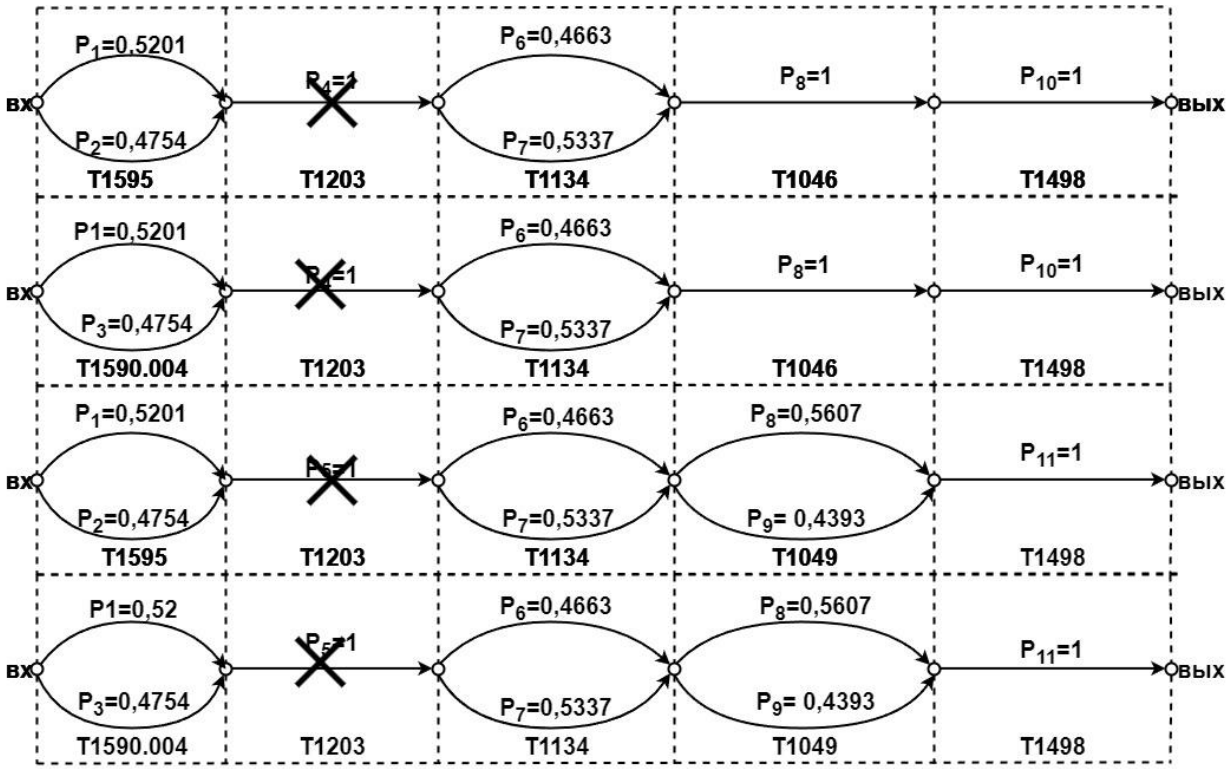


Рисунок 32 – Минимизация рисков группы сценариев CAPEC-297

В данном контексте видятся следующие меры (в дополнение к приведенным выше) по снижению риска в рамках тактик с опорой на базовые защитные меры и лучшие практики согласно ведущим ИБ-компаниям, а именно:

Эксплуатация уязвимостей в клиентском программном обеспечении (T1203).

Для устранения CVE-2015-0310 (переполнение буфера) требуется провести обновление Adobe Flash Player выше версии 16.0.0.296 (Windows/Mac) и 11.2.202.440 (Linux) [94].

Для устранения CVE-2018-20555 (Use-After-Free) требуется провести обновление Adobe Flash Player до версии 32.0.0.101 или новее, либо перейти на использование альтернатив (HTML5, WebGL) [95].

Далее перейдём к рассмотрению шаблона CAPEC-298 (рисунок 33).

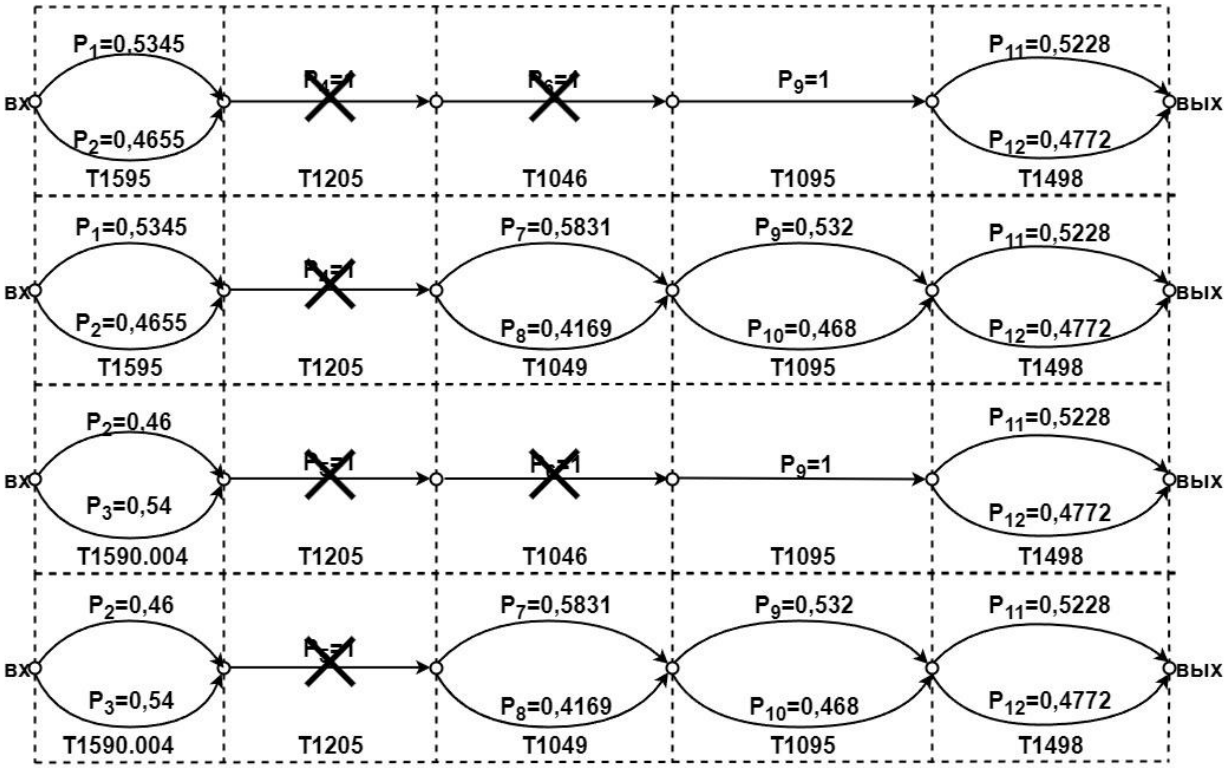


Рисунок 33 – Минимизация рисков группы сценариев CAPEC-298

Для противодействия группе сценариев шаблона CAPEC-298 требуется выполнить следующие меры:

Передача управляющих сигналов в трафике (T1205).

Для устранения CVE-2017-9000 (Aruba ClearPass Policy Manager (веб-интерфейс)) требуется провести обновление до версии 6.6.7+ и выше [96].

Для устранения CVE-2020-7819 уязвимости Use-After-Free в ActiveX-компоненте IONIQ PDF Viewer требуется провести обновление до версии 11.2.0.2126 или новее [97].

Изучение сетевых служб (T1046).

Для устранения CVE-2017-1000362 (stack-based buffer overflow в sudo Linux) требуется провести обновление до версии 1.8.20.

Далее перейдём к рассмотрению шаблона CAPEC-299 (рисунок 34).

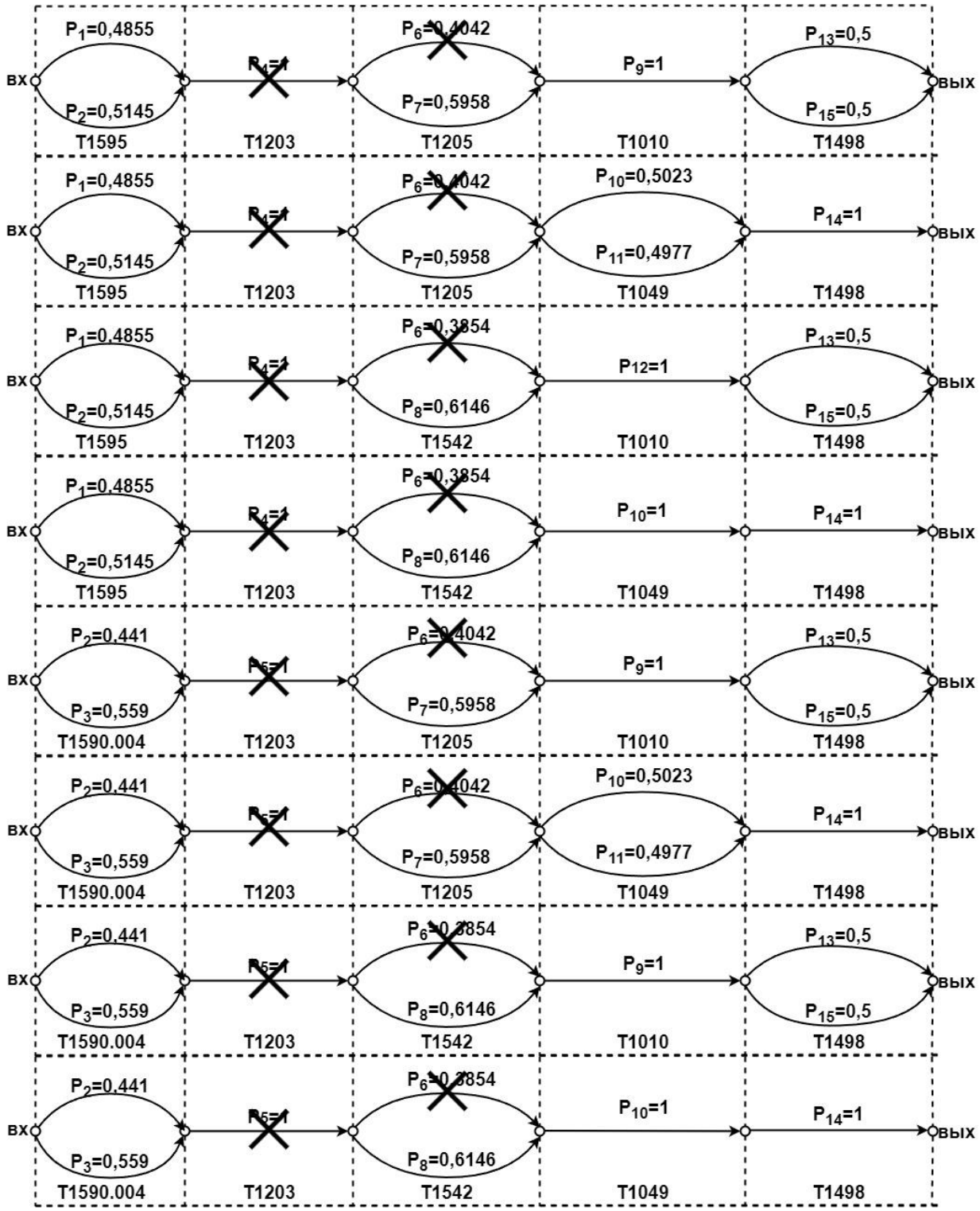


Рисунок 34 – Минимизация рисков группы сценариев CAPEC-299

Для противодействия группе сценариев шаблона CAPEC-299 требуется выполнить следующие меры:

Эксплуатация уязвимостей в клиентском программном обеспечении (T1203).

Для устранения CVE-2016-5757 (выполнение произвольного кода через специально сформированных SVG-файл) требуется провести обновление выше версии 6.9.3-10.

Для устранения CVE-2018-14328 в FFmpeg (мультимедийный фреймворк), приводящая к отказу в обслуживании (DoS) при обработке специально созданного AVI-файла требуется провести обновление выше версии 4.0.1.

Загрузка раньше операционной системы (T1542).

Для устранения CVE-2017-13664 (уязвимость в Sudo, позволяющая локальному пользователю выполнять команды от имени root без пароля) требуется провести обновление выше версии 1.8.19p1 [98].

В конце разберём шаблон CAPEC-618 (рисунок 35).

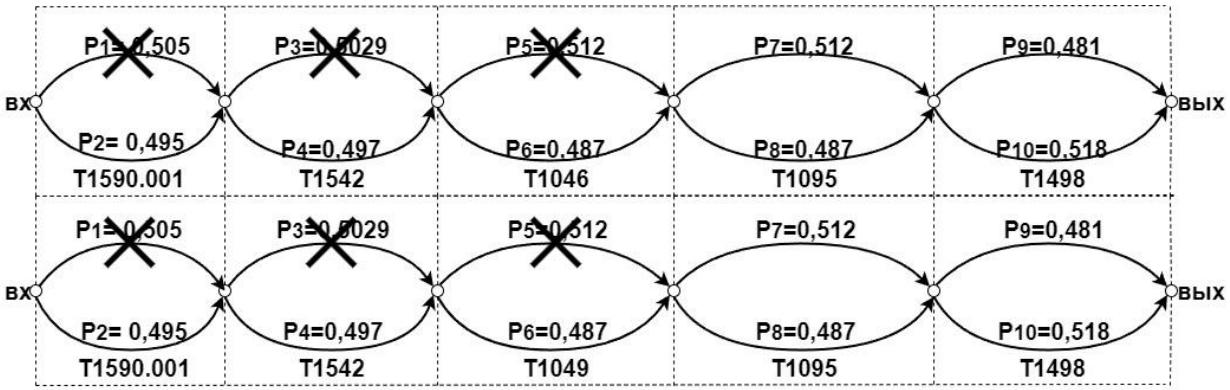


Рисунок 35 – Минимизация рисков группы сценариев CAPEC-618

В соответствии с методикой противодействия инцидентам информационной безопасности для устранения отмеченных крестом уязвимостей требуется выполнить следующие действия:

Разведка (T1590.001).

Для устранения CVE-2016-1265 и CVE-2017-5158 требуется провести обновление уязвимых служб (ISC DHCP, SQL) [99].

Предотвращение обнаружения (T1542).

Для устранения CVE-2017-11510, CVE-2024-1222 требуется провести обновление прошивок и CMS .

Обнаружение (T1046).

Для устранения CVE-2017-3972 требуется провести обновление клиентского ПО.

Обнаружение сетевых подключений системы (T1049).

Для устранения CVE-2017-11510 требуется провести обновление TinyXML2 до 6.2.0 или выше [100].

ЗАКЛЮЧЕНИЕ

В порядке разрешения выявленного противоречия между необходимостью постоянного наличия узконаправленного объема экспертных, статических данных относительно пар «атака - уязвимость» для атакуемых автоматизированных информационных систем и отсутствием похожего материала, собранного из открытых источников, была представлена следующая новизна, практическая ценность и теоретическая значимость:

Новизна исследования заключается в том, что впервые была собрана и структурирована база данных, с помощью которой может осуществляться вероятностное моделирование процесса реализации кибератак класса «Методы активного обнаружения узлов и сервисов» в АИС.

Практическая ценностью является созданная база метрик кибератак класса «Методы активного обнаружения узлов и сервисов» и уязвимостей имеет практическую возможность для расширения в соответствующие проектные ситуации.

Теоретической значимостью является открытость базы данных и возможность её расширения на другие кибертатаки и иные информационные системы.

В порядке разрешения выявленного противоречия между необходимой потребностью установления соответствия между элементов множества рассматриваемого класса кибератак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения информационной безопасности автоматизированных информационных систем, была представлена следующая новизна, практическая ценность и теоретическая значимость:

Новизна исследования заключается в том, что впервые для кибератак класса «Методы активного обнаружения узлов и сервисов» были предложены обобщённые графические модели сценариев атак, которые могут быть реализованы злоумышленником для вторжения в АИС.

Практическая ценность заключается в том, что было сформировано множество сценариев и проведён их рисканализ отражающий реализацию проектной

деятельности, направленной на обеспечение информационной безопасности АИС от атак класса «Методы активного обнаружения узлов и сервисов».

Теоретическую значимость представляет разработанное множество сценариев класса кибератак «Метода активного обнаружения узлов и сервисов», которое в последующем может быть дополнено новыми уязвимостями, либо дополнена смежными техниками.

В порядке разрешения выявленного противоречия между существующей методологией вероятностной оценки опасности кибератак класса «Методы активного обнаружения узлов и сервисов», использующей калькуляторы серии CVSS, EPSS, OWASP и потребностью риск-анализа вторжений в автоматизированию информационную систему:

Новизна заключается в том, что разработана методика оценки рисков нарушения информационной безопасности при реализации кибератак класса «Методы активного обнаружения узлов и сервисов», также определены наиболее вероятный сценарий, с максимальным и минимальным риском.

.Практической ценностью является оценка рисков, представляющее собой базу для рецензирования информационной безопасности АИС посредством кибератак класса «Методы активного обнаружения узлов и сервисов», в том числе путём закрытия эксплуатируемых уязвимостей АИС.

Теоретической значимостью является возможность усовершенствования модели оценки рисков единичных атак класса «Методы активного обнаружения узлов и сервисов» до многократных, поточных, лавинных вторжений.

В порядке разрешения выявленного противоречия между несовершенством процедур регламентации противодействия атакам рассматриваемого класса и потребностью реализовывать такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в защищаемых автоматизированных информационных системах:

Новизна исследования заключается в том, что для выявленных сценариев атак предложены актуальные регламенты реагирования и ликвидации последствий

кибератак. Ориентированные на конкретные этапы реализации вторжения злоумышленника.

Практической ценностью является то, что предложенные регламенты выступают в роли инструмента управления риск-ландшафта успешной реализации кибератак класса «Методы активного обнаружения узлов и сервисов» в АИС.

Теоретическая значимость просматривается в том, что на основе методологии управления риск-ландшафтом успешности реализации атак класса «Методы активного обнаружения узлов и сервисов» на уязвимости вычислительных систем и сетей представляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

СПИСОК ЛИТЕРАТУРЫ

1. Остапенко Г.А. Актуальность и целеполагание построения автоматизированного атласа кибератак в условиях цифровой трансформации / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко // Вопросы обеспечения безопасности в киберпространстве. Материалы II Всероссийской научно-технической конференции. Махачкала, 2024. С. 263-265. – Текст: непосредственный.

2. Остапенко А.Г. Нейросетевые компетенции и инструменты подготовки специалистов по защите информации / А.Г. Остапенко, Е.А. Москалева, А.П. Васильченко, А.А. Остапенко // Кибернетика и информационная безопасность «КИБ-2024»: Сб. науч. трудов Второй Всероссийской научно-технической конференции. Москва, 2024. С. 266-267. – Текст: непосредственный.

3. Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалёва, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. – Текст: непосредственный.

4. Остапенко А.А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 543-552. – Текст: непосредственный.

5. Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 7-30. – Текст: непосредственный.

6. Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54. – Текст: непосредственный.

7. Остапенко А.А. Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А.А. Остапенко, В.П. Шелякин, Е.С. Короткова, А.С. Кривошеин, Д.А. Мальцева, П.А. Меркулов, Н.Д. Никитин, М.О. Титаренко // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 521-542. – Текст: непосредственный.

8. Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков, Д.С. Покудин, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 219-230. – Текст: непосредственный.

9. CAPEC. – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

10. MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

11. MITRE ATT&CK (Positive Technologies). – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

12. MITRE EMB3D. – Электрон. дан. – Режим доступа: https://emb3d.mitre.org/. – Текст: электронный.

13. MITRE ATLAS. – Электрон. дан. – Режим доступа: https://atlas.mitre.org/. – Текст: электронный.

14. MITRE ATLAS (ФБИТ ИТМО). – Электрон. дан. – Режим доступа: https://atlas.securityhub.ru/– Текст: электронный.

15. CVE. – Электрон. дан. – Режим доступа: https://cve.mitre.org/. – Текст: электронный.

16. CWE - Common Weakness Enumeration. – Электрон. дан. – Режим доступа: https://cwe.mitre.org/index.html. – Текст: электронный.

17. Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat – Текст: электронный.

18. НКЦКИ. – Электрон. дан. – Режим доступа: https://cert.gov.ru/ – Текст: электронный.

19. CISA KEV. – Электрон. дан. – Режим доступа: https://www.cisa.gov/known-exploited-vulnerabilities-catalog– Текст: электронный.

20. NIST NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

21. Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss – Текст: электронный.

22. Общая система оценки уязвимостей (CVSS). – Электрон. дан. – Режим доступа: https://www.first.org/cvss/specificationdocument – Текст: электронный.

23. Common Vulnerability Scoring System v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/. – Текст: электронный.

24. Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231-238. – Текст: непосредственный.

25. Смирнов В.В. Кибератаки вида «Анализ целевого объекта»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. – Текст: непосредственный.

26. Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 285-294. – Текст: непосредственный.

27. Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. – Текст: непосредственный.

28. Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А.

Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336. – Текст: непосредственный.

29. Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378. – Текст: непосредственный.

30. Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть III) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, С.В. Безбородых, А.Г. Остапенко, Н.П. Жуков // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 477-488. – Текст: непосредственный.

31. Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть IV) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, С.В. Безбородых, А.Г. Остапенко, Н.П. Жуков // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 489-508. – Текст: непосредственный.

32. Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 239-246. – Текст: непосредственный.

33. Диогенес Ю., Озкайя Э. Кибербезопасность: стратегии атак и обороны / пер. с анг. Д.А. Беликова. // М.: ДМК Пресс, 2020. С. 249-268. – Текст: непосредственный.

34. Организационно-правовая защита сетей / Г. А. Остапенко и др. - Под ред. Академика РАН Д. А. Новикова. Сер. Теория сетевых войн. Вып. 8. - М.: Горячая линия Телеком, 2023.-228с. – Текст: непосредственный.

35. Калашников А.О., Остапенко А.Г., Белов Е.Б., Лось В.П., Остапенко А.А. Сетео-информационная эпидемиология. М.: Горячая линия-Телеком, 2021. – 216 с. – Текст: непосредственный.

36. Международный стандарт – ISO/IEC 27005 – Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности – Второе издание – 2011. – Текст: непосредственный.

37. Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

38. Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

39. Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

40. Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

41. Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

42. Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

43. Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

44. Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

45. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть i) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 1. – С. 7-30. – DOI 10.36622/1682-7813.2024.27.1.001. – Текст: непосредственный.

46. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г. А. Остапенко, А. П. Васильченко, А. А.

Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 1. – С. 31-54. – DOI 10.36622/1682-7813.2024.27.1.002. – Текст: непосредственный.

47. ГОСТ Р ИСО/МЭК 27001-2021 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования». – Текст: непосредственный.

48. Калашников А.О., Остапенко А.Г., Остапенко Г.А., Остапенко О.А., Чапурин Е.Ю. Социальные сети и риск-мониторинг. М.: Горячая линия - Телеком, 2020. – 266 с. – Текст: непосредственный.

49. Справочник законодательства РФ в области информационной безопасности (версия 06.06.2025). – Электрон. дан. – Режим доступа: https://habr.com/ru/articles/432466/. – Текст: электронный.

50. Протокол автоматизации управления данными безопасности (SCAP). – Электрон. дан. – Режим доступа: https://ru.wikipedia.org/wiki/Стандарт_SCAP#:~:text=Протокол%20автоматизации%20управления%20данными%20безопасности,и%20обмена%20данными%20по%20безопасности. – Текст: электронный.

51. Александров А.Г. Анализ угроз информационной безопасности при использовании облачных сервисов / А.Г. Александров, А.Ю. Петухов, М.Ю. Рытов // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 143-151.– Текст: непосредственный.

52. Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло, А.С. Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. - Т. 27. Вып. 2. С. - 185-196. – Текст: непосредственный.

53. Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 197-208. – Текст: непосредственный.

54. Громов Ю.Ю. Изучение возможности виртуализации технических средств защиты объектов с применением имитационного моделирования / Ю.Ю. Громов,

П.И. Карасев, Ф.М. Пыршев // Информация и безопасность. 2024. - Т. 27. Вып. 3. - С. 379-388. – Текст: непосредственный.

55. Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта «Безопасный интернет». / А.Г. Остапенко, И.А. Боков,А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д.Трубицын. // Информация и безопасность. 2021. - Т. 24. Вып. 2. - С. 287-296. – Текст: непосредственный.

56. Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г.Юрасов, Д.С. Печкин // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С.55-66. – Текст: непосредственный.

57. Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 67-80. – Текст: непосредственный.

58. Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 81-90. – Текст: непосредственный.

59. Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 285-294. – Текст: непосредственный.

60. Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 91-98. – Текст: непосредственный.

61. Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин,

Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. -Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный.

62. Смирнов В.В. Кибератаки вида «анализ целевого объекта»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 273-284. – Текст: непосредственный.

63. Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М. Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 99-108. – Текст: непосредственный.

64. Минаев В.А. Геофизические угрозы кибербезопасности / В.А. Минаев, А.О. Фаддеев, А.В. Мокшанцев // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 117-124. – Текст: непосредственный.

65. Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М. Голембиовский, К.Е. Шинаков // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 135-142. – Текст: непосредственный.

66. Подтопельный В.В. Исследование специфики моделирования компьютерных атак с использованием марковских процессов принятий решений и Q-обучения / В.В. Подтопельный // Информация и безопасность. 2024. Т. 27. Вып. 3. - С. 421-440. – Текст: непосредственный.

67. Зимницкий А.Г. Программно-технический комплекс выявления субъектов с повышенным риском девиантного поведения / А.Г. Зимницкий, А.А Остапенко // Информация и безопасность. 2022. - Т. 25. № 4. - С. 571-582. – Текст: непосредственный.

68. Остапенко А.Г. Целеполагание проектной деятельности по созданию инструментария автоматизированного выявления и риск-анализа деструктивных контентов, аффилированных с персоналом корпораций / А.Г. Остапенко, И.А,

Боков, С.В. Лихобабин, Д.С. Ясенко, Е.Ю. Чапурин // Информация и безопасность. 2023. - Т. 26. № 4. - С. 465-494. – Текст: непосредственный.

69. Сервис моделирования кибератак по матрице MITRE ATT&CK – Электрон. дан. – Режим доступа: https://mitre.securitycode.ru/. – Текст: электронный.

70. Петров А.В. Современные угрозы информационной безопасности и методы их нейтрализации / А.В. Петров, Д.К. Сидоров // Безопасность информационных систем. – 2023. – Т. 14. № 3. – С. 8-11. – Текст: непосредственный.

71. Козлов Е.Н. Анализ эффективности систем обнаружения вторжений на основе машинного обучения / Е.Н. Козлов, М.А. Волков // Кибербезопасность и защита данных. – 2022. – Т. 11. № 4. С. 41-61. – Текст: непосредственный.

72. Смирнова О.И. Криптографические протоколы в блокчейн-технологиях: анализ уязвимостей / О.И. Смирнова, В.П. Иванов // Информационная безопасность. – 2023. – Т. 9. № 2. С. 31-39. – Текст: непосредственный.

73. Лебедев С.М. Методы противодействия DDoS-атакам в распределённых сетях / С.М. Лебедев, А.Р. Федотов // Защита информации. Inside. – 2022. – Т. 7. № 1. – Текст: непосредственный.

74. Григорьев П.С. Формирование стратегии киберустойчивости критической инфраструктуры / П.С. Григорьев, Е.Л. Морозова // Информация и безопасность. – 2023. – Т. 26. № 3. С. 43-51. – Текст: непосредственный.

75. Волкова М.К. Организация Security Operations Center (SOC) в крупных корпорациях / М.К. Волкова, И.Н. Семёнов // Кибербезопасность. – 2023. – Т. 6. № 4. С. 21-90. – Текст: непосредственный.

76. Ткаченко Д.В. Автоматизированные системы анализа киберугроз в реальном времени / Д.В. Ткаченко, А.А. Борисов // Безопасность информационных технологий. – 2022. – Т. 18. № 2. С. 56-78. – Текст: непосредственный.

77. Зайцев Р.О. Методы расследования киберинцидентов на основе цифровых следов / Р.О. Зайцев, Л.П. Крылова // Информационная безопасность. – 2023. – Т. 10. № 1. С. 61-78. – Текст: непосредственный.

78. Морозов И.А. Постквантовая криптография: перспективы и вызовы / И.А. Морозов, С.В. Павлов // Криптография и безопасность. – 2023. – Т. 5. № 3. С. 90. – Текст: непосредственный.

79. Кудрявцева Е.С. Анализ стойкости современных алгоритмов шифрования / Е.С. Кудрявцева, В.М. Гусев // Защита информации. – 2022. – Т. 8. № 4. – С. 17-21. – Текст: непосредственный.

80. Фёдоров А.Д. Применение искусственного интеллекта для детектирования APT-атак / А.Д. Фёдоров, К.Л. Соколова // Искусственный интеллект в безопасности. – 2023. – Т. 4. № 2. – С. 5-11. – Текст: непосредственный.

81. Белова Н.Р. Глубокое обучение в анализе вредоносного ПО / Н.Р. Белова, Д.В. Мельников // Кибербезопасность и data science. – 2022. – Т. 12. № 3. – С. 39-41. – Текст: непосредственный.

82. Калинин В.Г. Правовое регулирование кибербезопасности в условиях цифровой трансформации / В.Г. Калинин, О.П. Сергеева // Право и информационная безопасность. – 2023. – Т. 3. № 1. – С. 30-50. – Текст: непосредственный.

83. Антонов Л.М. Управление рисками в корпоративных системах защиты информации / Л.М. Антонов, Е.В. Королёва // Менеджмент безопасности. – 2022. – Т. 9. № 2. – С. 25-35. – Текст: непосредственный.

84. Никитин С.В. Угрозы безопасности промышленного интернета вещей (IIoT) / С.В. Никитин, А.К. Логинов // IoT и кибербезопасность. – 2023. – Т. 7. № 4. – С. 30-40. – Текст: непосредственный.

85. Романов Д.И. Защита SCADA-систем от целевых атак / Д.И. Романов, М.С. Власов // Безопасность критических инфраструктур. – 2022. – Т. 5. № 3. – С. 42-50. – Текст: непосредственный.

86. Гущин А.В. Методы прогнозирования кибератак на основе больших данных / А.В. Гущин, Т.О. Бережная // Киберразведка и аналитика. – 2023. – Т. 8. № 3. – С. 45-90. – Текст: непосредственный.

87. Давыдов И.С. Тактики противодействия Advanced Persistent Threats (APT) / И.С. Давыдов, Н.В. Тихонова // Современные киберугрозы. – 2022. – Т. 13. № 4. – С. 59-80. – Текст: непосредственный.

88. Scanlon, T.J. Network Scanning Techniques: Using Nmap and Beyond / T.J. Scanlon, M.K. Rahman // Journal of Cybersecurity Research. – 2022. – Vol. 7, No. 3. – P. 45-62. – С. 30-35. – Текст: непосредственный.

89. Zalewski, M. Security Scanning Strategies for Modern Networks / M. Zalewski, R. Smith // IEEE Transactions on Information Forensics and Security. – 2021. – Vol. 16. – С. 28-50. – Текст: непосредственный.

90. Lyon, G.F. Nmap Network Scanning: Official Guide / G.F. Lyon // 3rd ed. – Nmap Project, 2023. С. 43-79. – Текст: непосредственный.

91. Shostack, A. Threat Modeling: Designing for Security / A. Shostack. – Wiley, 2022 – С. 1-11. – Текст: непосредственный.

92. Howard, M. Network Vulnerability Assessment: Automated and Manual Approaches / M. Howard, D. LeBlanc // SANS Institute, 2021. – С. 20-30. – Текст: непосредственный.

93. Bejtlich, R. The Practice of Network Security Monitoring / R. Bejtlich. – No Starch Press, 2023. С. 39-60. – Текст: непосредственный.

94. Northcutt, S. Network Intrusion Detection / S. Northcutt, J. Novak. – 4th ed. – New Riders, 2022. – Sec. 3. С. 10-110. – Текст: непосредственный.

95. Ghorbani, A.A. Network Intrusion Detection and Prevention / A.A. Ghorbani et al. – Springer, 2021. – Ch. 5. С. 13-67. – Текст: непосредственный.

96. Engebretson, P. The Basics of Hacking and Penetration Testing / P. Engebretson. – 4th ed. – Syngress, 2023. – Ch. 3. С. 31-91. – Текст: непосредственный.

97. Kim, P. The Hacker Playbook 4: Practical Guide to Penetration Testing / P. Kim. – Secure Planet, 2022. – Sec. 2. С. 52-78. – Текст: непосредственный.

98. O'Gorman, J. Metasploit: The Penetration Tester's Guide / J. O'Gorman, D. Kennedy. – No Starch Press, 2021. – Ch. 5. С. 31-101. – Текст: непосредственный.

99. Faircloth, J. Penetration Tester's Open Source Toolkit / J. Faircloth. – 3rd ed. – Elsevier, 2022. – Part 2. С. 16-41. – Текст: непосредственный.

100. Erickson, J. Hacking: The Art of Exploitation / J. Erickson. – 2nd ed. – No Starch Press, 2021. – Ch. 4. С. 15-98. – Текст: непосредственный.

ПРИЛОЖЕНИЕ А

Таблица А 1 – Паспорт уязвимости CVE-2023-28765

Идентификатор уязвимости	CVE-2023-28765 Злоумышленник с базовыми привилегиями в SAP BusinessObjects Business Intelligence Platform (Promotion Management) - версии 420, 430, может получить доступ к файлу lcmbiar и далее расшифровать файл. После этого злоумышленник может получить доступ к паролям пользователя BI и в зависимости от привилегий пользователя BI, злоумышленник может выполнять операции, которые могут полностью скомпрометировать приложение..
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,0)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 2 – Паспорт уязвимости CVE-2024-38200

Идентификатор уязвимости	CVE-2024-38200 Настройка сетевой безопасности: ограничение NTLM: исходящий трафик NTLM на удаленные серверы параметр политики позволяет разрешать, блокировать или проводить аудит исходящего трафика NTLM с компьютера под управлением Windows Server 2008, Windows Server 2008 R2 или более поздней версии на любой удаленный сервер под управлением операционной системы Windows.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,6)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 3 – Паспорт уязвимости CVE-2015-0310

Идентификатор уязвимости	CVE-2015-0310 Adobe Flash Player до версии 13.0.0.262 и 14.x по 16.x до версии 16.0.0.287 в Windows и OS X, а также до версии 11.2.202.438 в Linux не ограничивает должным образом обнаружение адресов памяти, что позволяет злоумышленникам обходить механизм защиты ASLR в Windows и оказывать неопределенное воздействие на другие платформы через неизвестные векторы, как это было обнаружено в январе 2015 года.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 4 – Паспорт уязвимости CVE-2018-20555

Идентификатор уязвимости	CVE-2018-20555 Плагин Design Chemical Social Network Tabs 1.7.1 для WordPress позволяет удаленным злоумышленникам обнаружить значения Twitter access_token, access_token_secret, consumer_key и consumer_secret, прочитав исходный код dcwp_twitter.php. Это приводит к захвату учетной записи Twitter.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,2)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 5 – Паспорт уязвимости CVE-2024-21793

Идентификатор уязвимости	CVE-2024-21793 Уязвимость внедрения OData существует в BIG-IP Next Central Manager API (URI). Примечание: версии программного обеспечения, достигшие Окончания технической поддержки (EoTS), не оцениваются.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,3)
Статус уязвимости	Подтверждено производителем

Продолжение таблицы А 5

Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 6 – Паспорт уязвимости CVE-2008-0655

Идентификатор уязвимости	CVE-2008-0655 Множество неуказанных уязвимостей в Adobe Reader и Acrobat до версии 8.1.2 имеют неизвестные последствия и векторы атак.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,0)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 7 – Паспорт уязвимости CVE-2018-0127

Идентификатор уязвимости	CVE-2018-0127 Уязвимость в веб-интерфейсе маршрутизаторов Cisco RV132W ADSL2+ Wireless-N VPN и маршрутизаторов Cisco RV134W VDSL2 Wireless-AC VPN может позволить неаутентифицированному удаленному злоумышленнику просматривать параметры конфигурации для уязвимого устройства, что может привести к раскрытию конфиденциальной информации. Уязвимость связана с отсутствием требований аутентификации пользователя для определенных страниц, которые являются частью веб-интерфейса и содержат конфиденциальную информацию для уязвимого устройства. Злоумышленник может воспользоваться этой уязвимостью, отправив специально созданный HTTP-запрос на уязвимое устройство и изучив HTTP-ответ на запрос. Успешный эксплойт может позволить злоумышленнику просматривать параметры конфигурации, включая пароль администратора, для уязвимого устройства. Идентификаторы ошибок Cisco: CSCvg92739, CSCvh60172.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,6)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 8 – Паспорт уязвимости CVE-2018-7251

Идентификатор уязвимости	CVE-2018-7251 Проблема была обнаружена в config/error.php в Anchor 0.12.3. Журнал ошибок отображается по адресу error.log URI и содержит учетные данные MySQL, если произошла ошибка MySQL (например, «Слишком много подключений»).
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 9 – Паспорт уязвимости CVE-2017-11165

Идентификатор уязвимости	CVE-2017-11165 dataTaker DT80 dEX 1.50.012 позволяет удаленным злоумышленникам получать конфиденциальные учетные данные и информацию о конфигурации с помощью прямого запроса URI /services/getFile.cmd?userfile=config.xml.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 10 – Паспорт уязвимости CVE-2018-14328

Идентификатор уязвимости	CVE-2018-14328 Brynamics «Online Trade – система онлайн-торговли и инвестирования в криптовалюту» позволяет удаленным злоумышленникам получать конфиденциальную информацию с помощью прямого запроса к /dashboard/addplan, /dashboard/paywithcard/charge, /dashboard/withdrawal или /privacy&terms, как показано на примере чтения полей имени пользователя базы данных, пароля базы данных, имени базы данных и IP-адреса, связанных с CVE-2018-12908.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Продолжение таблицы А 10

Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 11 – Паспорт уязвимости CVE-2018-1337

Идентификатор уязвимости	CVE-2018-1337 В Apache Directory LDAP API до версии 1.0.2 ошибка в настройке фильтра SSL позволяла другому потоку использовать соединение до установки уровня TLS, если соединение уже было использовано и возвращено в пул соединений, что приводило к утечке любой информации, содержащейся в этом запросе (включая учетные данные при отправке запроса BIND).
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,2)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 12 – Паспорт уязвимости CVE-2017-3185

Идентификатор уязвимости	CVE-2017-3185 Камеры ACTi, включая серии D, B, I и E, использующие версию прошивки A1D-500-V6.11.31-AC, имеют веб-приложение, которое использует метод GET для обработки запросов, содержащих конфиденциальную информацию, такую как имя учетной записи пользователя и пароль, что может раскрыть эту информацию через историю браузера, рефереры, веб-журналы и другие источники.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 13 – Паспорт уязвимости CVE-2017-9000

Идентификатор уязвимости	CVE-2017-9000 ArubaOS, все версии до 6.3.1.25, 6.4 до 6.4.4.16, 6.5.x до 6.5.1.9, 6.5.2, 6.5.3 до 6.5.3.3, 6.5.4 до 6.5.4.2, 8.x до 8.1.0.4 Версии программного обеспечения FIPS и не-FIPS в равной степени подвержены уязвимости к неаутентифицированному произвольному доступу к файлам. Неаутентифицированный пользователь с сетевым доступом к контроллеру мобильности Aruba на TCP-порту 8080 или 8081 может получить доступ к произвольным файлам, хранящимся на контроллере мобильности. Порты 8080 и 8081 используются для функциональности портала захвата и по умолчанию прослушивают все IP-интерфейсы контроллера мобильности, включая интерфейсы портала захвата. Злоумышленник может получить доступ к файлам, содержащим пароли, ключи и другую конфиденциальную информацию, что может привести к полной компрометации системы.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,9)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 14 – Паспорт уязвимости CVE-2020-7819

Идентификатор уязвимости	CVE-2020-7819 Уязвимость SQL-инъекции в nTracker USB Enterprise (решение для безопасного управления USB) позволяет удаленному неаутентифицированному злоумышленнику выполнить SQL-запрос для доступа к имени пользователя, паролю и другой информации, связанной с сеансом.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,8)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 15 – Паспорт уязвимости CVE-2017-1000362

Идентификатор уязвимости	CVE-2017-1000362 Монитор администратора re-key был представлен в Jenkins 1.498 и повторно зашифровал все секреты в JENKINS_HOME новым ключом. Он также создал резервный каталог со всеми старыми секретами и ключом, используемым для их шифрования. Эти резервные копии были доступны для чтения всем и не удалялись впоследствии. Теперь Jenkins удаляет резервный каталог, если он есть. Обновление с версии до 1.498 больше не будет создавать резервный каталог. Администраторам, полагающимся на разрешения на доступ к файлам в своих вручную созданных резервных копиях, рекомендуется проверить их на наличие каталога $JENKINS_HOME/ jenkins.security.RekeySecretAdminMonitor/backups и удалить его, если он есть.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,9)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 16 – Паспорт уязвимости CVE-2019-11991

Идентификатор уязвимости	CVE-2019-11991 Компания HPE обнаружила уязвимость в сервисном процессоре HPE 3PAR (SP) версий 4.1–4.4. Сервисный процессор HPE 3PAR (SP) версий 4.1–4.4 имеет уязвимость удаленного раскрытия информации, которая может привести к нарушению конфиденциальности, целостности и доступности сервисного процессора и любых управляемых массивов 3PAR.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 17 – Паспорт уязвимости CVE-2016-8964

Идентификатор уязвимости	CVE-2016-8964 IBM BigFix Inventory v9 9.2 использует неадекватную настройку блокировки учетной записи, которая может позволить удаленному злоумышленнику взломать учетные данные учетной записи. IBM X-Force ID: 118853.

Продолжение таблицы А 17

Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 18 – Паспорт уязвимости CVE-2019-11991

Идентификатор уязвимости	CVE-2019-11991 Компания HPE обнаружила уязвимость в сервисном процессоре HPE 3PAR (SP) версий 4.1–4.4. Сервисный процессор HPE 3PAR (SP) версий 4.1–4.4 имеет уязвимость удаленного раскрытия информации, которая может привести к нарушению конфиденциальности, целостности и доступности сервисного процессора и любых управляемых массивов 3PAR.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,2)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 19 – Паспорт уязвимости CVE-2024-55875

Идентификатор уязвимости	CVE-2024-55875 http4k – это функциональный набор инструментов для приложений Kotlin HTTP. До версии 5.41.0.0 существовала потенциальная уязвимость XXE (XML External Entity Injection), когда http4k обрабатывал вредоносное содержимое XML в запросах, что могло позволить злоумышленникам читать локальную конфиденциальную информацию на сервере, вызывать подделку запросов на стороне сервера и даже выполнять код при некоторых обстоятельствах.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,4)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 20 – Паспорт уязвимости CVE-2023-39337

Идентификатор уязвимости	CVE-2023-39337 Уязвимость безопасности в версиях EPMM 11.10, 11.9 и 11.8 позволяет злоумышленнику, знающему идентификатор зарегистрированного устройства, получить доступ и извлечь конфиденциальную информацию, включая сведения о конфигурации устройства и среды, а также секреты. Эта уязвимость представляет серьезную угрозу безопасности, потенциально подвергая конфиденциальные данные и целостность системы риску.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 21 – Паспорт уязвимости CVE-2016-7404

Идентификатор уязвимости	CVE-2016-7404 OpenStack Magnum передает учетные данные OpenStack в шаблоны Heat, создавая свои экземпляры. Хотя они должны использоваться только для получения SSL-сертификатов экземпляров, они обеспечивают полный доступ к API и могут использоваться для выполнения любой операции API, которую пользователь авторизован выполнять.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 22 – Паспорт уязвимости CVE-2017-11510

Идентификатор уязвимости	CVE-2017-11510 В сетевой камере HW0021 компании Wanscam существует утечка информации, которая позволяет неавторизованному удаленному злоумышленнику восстановить имя пользователя и пароль администратора с помощью запроса ONVIF GetSnapshotUri.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Продолжение таблицы А 22

Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 23 – Паспорт уязвимости CVE-2017-14443

Идентификатор уязвимости	CVE-2017-14443 В Insteon Hub с прошивкой версии 1012 существует уязвимость утечки информации, которую можно эксплуатировать. Реализация HTTP-сервера неправильно проверяет количество предоставленных параметров GET, что приводит к произвольно контролируемой утечке информации во всей памяти устройства. Злоумышленник может отправить аутентифицированный HTTP-запрос, чтобы вызвать эту уязвимость.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,9)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 24 – Паспорт уязвимости CVE-2016-5757

Идентификатор уязвимости	CVE-2016-5757 Консоль администратора iManager в NetIQ Access Manager 4.1 до версии 4.1.2 Hot Fix 1 и 4.2 до версии 4.2.2 была уязвима для атак с манипуляцией iFrame, что могло позволить удаленным пользователям получить доступ к учетным данным аутентификации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,2)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 25 – Паспорт уязвимости CVE-2018-14328

Идентификатор уязвимости	CVE-2018-14328 Brynamics «Online Trade – система онлайн-торговли и инвестирования в криптовалюту» позволяет удаленным злоумышленникам получать конфиденциальную информацию с помощью прямого запроса к /dashboard/addplan, /dashboard/paywithcard/charge, /dashboard/withdrawal или /privacy&terms, как показано на примере чтения полей имени пользователя базы данных, пароля базы данных, имени базы данных и IP-адреса, связанных с CVE-2018-12908.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 26 – Паспорт уязвимости CVE-2017-13664

Идентификатор уязвимости	CVE-2017-13664 Раскрытие файла паролей в прошивке iSmartAlarm CubeOne версии 2.2.4.8 и более ранних версий позволяет злоумышленникам выполнять произвольные команды с правами администратора, извлекая учетные данные из этого файла.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 27 – Паспорт уязвимости CVE-2018-5726

Идентификатор уязвимости	CVE-2018-5726 Устройства MASTER IPCAMERA01 3.3.4.2103 позволяют удаленным злоумышленникам получать конфиденциальную информацию с помощью специально созданного HTTP-запроса, о чем свидетельствуют имя пользователя, пароль и параметры конфигурации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)

Продолжение таблицы А 27

Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 28 – Паспорт уязвимости CVE-2018-14328

Идентификатор уязвимости	CVE-2018-14328 Уязвимость была обнаружена в панелях SIMATIC HMI Comfort 4" - 22" (все версии < V15.1 Update 1), наружных панелях SIMATIC HMI Comfort 7" и 15" (все версии < V15.1 Update 1), мобильных панелях SIMATIC HMI KTP KTP400F, KTP700, KTP700F, KTP900 и KTP900F (все версии < V15.1 Update 1), SIMATIC WinCC Runtime Advanced (все версии < V15.1 Update 1), SIMATIC WinCC Runtime Professional (все версии < V15.1 Update 1), SIMATIC WinCC (TIA Portal) (все версии < V15.1 Update 1), устройствах SIMATIC HMI Classic (мобильная панель TP/MP/OP/MP) (все версии). Уязвимое устройство предлагало возможности чтения и записи SNMP с общедоступной жестко закодированной строкой сообщества. Уязвимость безопасности может быть использована злоумышленником, имеющим сетевой доступ к уязвимому устройству. Успешная эксплуатация не требует системных привилегий и взаимодействия с пользователем.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,9)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 29 – Паспорт уязвимости CVE-2017-3972

Идентификатор уязвимости	CVE-2017-3972 Уязвимость инфраструктурного футпринтинга в веб-интерфейсе McAfee Network Security Management (NSM) до версии 8.2.7.42.2 позволяет злоумышленникам выполнять произвольный код через баннер сервера, что приводит к утечке потенциально конфиденциальной или важной для безопасности информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,2)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 30 – Паспорт уязвимости CVE-2023-43791

Идентификатор уязвимости	CVE-2023-43791 Label Studio – это многотипный инструмент маркировки и аннотирования данных со стандартизированным форматом вывода. Существует уязвимость, которая может быть связана с уязвимостью ORM Leak, чтобы выдавать себя за любую учетную запись в Label Studio. Злоумышленник может использовать эти уязвимости для повышения своих привилегий с пользователя с низкими привилегиями до пользователя Django Super Administrator. Было обнаружено, что уязвимость затрагивает версии до `1.8.2`, где был представлен патч.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 31 – Паспорт уязвимости CVE-2024-21793

Идентификатор уязвимости	CVE-2024-21793 Уязвимость внедрения OData существует в BIG-IP Next Central Manager API (URI). Примечание: версии программного обеспечения, достигшие Окончания технической поддержки (EoTS), не оцениваются.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,2)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 32 – Паспорт уязвимости CVE-2018-18941

Идентификатор уязвимости	CVE-2018-18941 В Vignette Content Management версии 6 можно получить удаленный доступ к привилегиям администратора, обнаружив пароль администратора в исходном коде HTML vgn/ccb/user/mgmt/user/edit/0,1628,0,00.html?uid=admin, а затем создав учетную запись привилегированного пользователя. ПРИМЕЧАНИЕ: этот продукт больше не поддерживается.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Продолжение таблицы А 32

Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 33 – Паспорт уязвимости CVE-2018-0127

Идентификатор уязвимости	CVE-2018-0127 Уязвимость в веб-интерфейсе маршрутизаторов Cisco RV132W ADSL2+ Wireless-N VPN и маршрутизаторов Cisco RV134W VDSL2 Wireless-AC VPN может позволить неаутентифицированному удаленному злоумышленнику просматривать параметры конфигурации для уязвимого устройства, что может привести к раскрытию конфиденциальной информации. Уязвимость связана с отсутствием требований аутентификации пользователя для определенных страниц, которые являются частью веб-интерфейса и содержат конфиденциальную информацию для уязвимого устройства. Злоумышленник может воспользоваться этой уязвимостью, отправив специально созданный HTTP-запрос на уязвимое устройство и изучив HTTP-ответ на запрос. Успешный эксплойт может позволить злоумышленнику просматривать параметры конфигурации, включая пароль администратора, для уязвимого устройства. Идентификаторы ошибок Cisco: CSCvg92739, CSCvh60172.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,5)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 34 – Паспорт уязвимости CVE-2016-1112

Идентификатор уязвимости	CVE-2016-1112 Adobe Reader и Acrobat до версии 11.0.16, Acrobat и Acrobat Reader DC Classic до версии 15.006.30172, а также Acrobat и Acrobat Reader DC Continuous до версии 15.016.20039 в Windows и OS X позволяют злоумышленникам получать конфиденциальную информацию через неуказанные векторы.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,6)

Продолжение таблицы А 34

Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 35 – Паспорт уязвимости CVE-2020-6170

Идентификатор уязвимости	CVE-2020-6170 Уязвимость обхода аутентификации на устройствах Genexis Platinum-4410 v2.1 P4410-V2 1.28 позволяет злоумышленникам получить учетные данные в открытом виде из исходного HTML-кода URI cgi-bin/index2.asp.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 36 – Паспорт уязвимости CVE-2017-5158

Идентификатор уязвимости	CVE-2017-5158 Проблема раскрытия информации была обнаружена в Schneider Electric Wonderware InTouch Access Anywhere версии 11.5.2 и более ранних. Учетные данные могут быть раскрыты внешним системам через определенные параметры URL, поскольку могут быть указаны произвольные адреса назначения.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 37 – Паспорт уязвимости CVE-2017-11510

Идентификатор уязвимости	CVE-2017-11510 В сетевой камере HW0021 компании Wanscam существует утечка информации, которая позволяет неавторизованному удаленному злоумышленнику восстановить имя пользователя и пароль администратора с помощью запроса ONVIF GetSnapshotUri.
Идентификатор типа ошибки	CWE-200

Продолжение таблицы А 37

Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 38 – Паспорт уязвимости CVE-2024-1222

Идентификатор уязвимости	CVE-2024-1222 Это позволяет злоумышленникам использовать вредоносный API-запрос для получения доступа к уровню авторизации API с повышенными привилегиями. Это применимо к небольшому подмножеству вызовов API PaperCut NG/MF.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,1)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 39 – Паспорт уязвимости CVE-2017-11510

Идентификатор уязвимости	CVE-2017-11510 В сетевой камере HW0021 компании Wanscam существует утечка информации, которая позволяет неавторизованному удаленному злоумышленнику восстановить имя пользователя и пароль администратора с помощью запроса ONVIF GetSnapshotUri.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,0)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 40 – Паспорт уязвимости CVE-2017-3972

Идентификатор уязвимости	CVE-2017-3972 Уязвимость инфраструктурного футпринтинга в веб-интерфейсе McAfee Network Security Management (NSM) до версии 8.2.7.42.2 позволяет злоумышленникам выполнять произвольный код через баннер сервера, что приводит к утечке потенциально конфиденциальной или важной для безопасности информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,3)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 41 – Паспорт уязвимости CVE-2019-14892

Идентификатор уязвимости	CVE-2019-14892 Была обнаружена уязвимость в jackson-databind в версиях до 2.9.10, 2.8.11.5 и 2.6.7.3, где она допускала полиморфную десериализацию вредоносного объекта с использованием классов JNDI commons-configuration 1 и 2. Злоумышленник мог использовать эту уязвимость для выполнения произвольного кода.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 42 – Паспорт уязвимости CVE-2023-43791

Идентификатор уязвимости	CVE-2023-43791 Label Studio – это многотипный инструмент маркировки и аннотирования данных со стандартизированным форматом вывода. Существует уязвимость, которая может быть связана с уязвимостью ORM Leak, чтобы выдавать себя за любую учетную запись в Label Studio. Злоумышленник может использовать эти уязвимости для повышения своих привилегий с пользователя с низкими привилегиями до пользователя Django Super Administrator. Было обнаружено, что уязвимость затрагивает версии до `1.8.2`, где был представлен патч.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Продолжение таблицы А 42

Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,6)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 43 – Паспорт уязвимости CVE-2020-28333

Идентификатор уязвимости	CVE-2020-28333 Устройства Barco wePresent WiPG-1600W позволяют обходить аутентификацию. Затронутые версии: 2.5.1.8. Веб-интерфейс Barco wePresent WiPG-1600W не использует файлы cookie сеанса для отслеживания аутентифицированных сеансов. Вместо этого веб-интерфейс использует токен «SEID», который добавляется в конец URL-адресов в запросах GET. Таким образом, «SEID» будет отображаться в журналах веб-прокси и истории браузера. Злоумышленник, способный перехватить «SEID» и отправлять запросы с того же IP-адреса (через устройство NAT или веб-прокси), сможет получить доступ к пользовательскому интерфейсу устройства, не зная учетных данных.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 8,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

Таблица А 44 – Паспорт уязвимости CVE-2020-6170

Идентификатор уязвимости	CVE-2020-6170 Уязвимость обхода аутентификации на устройствах Genexis Platinum-4410 v2.1 P4410-V2 1.28 позволяет злоумышленникам получить учетные данные в открытом виде из исходного HTML-кода URI cgi-bin/index2.asp.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8) Высокий уровень опасности (базовая оценка CVSS 4.0 составляет 7,7)
Статус уязвимости	Подтверждено производителем
Наличие эксплойта	Имеется
Способ устранения	Обновление версии

ПРИЛОЖЕНИЕ Б

Таблица Б 1 – Организационно-правовой регламент шаблона атаки CAPEC-298

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Разведка	Частые запросы UDP протокола в сети сигнализируют о использовании техники T1595 с эксплуатацией уязвимости CVE-2018-1337.	1.Настройка rate-limiting для UDP-трафика iptables -A INPUT -p udp -m limit --limit 5/s -j ACCEPT iptables -A INPUT -p udp -j DROP. 2. Выявление источников сканирования через tcpdump -n udp.	1. Аудит всех UDP-сервисов. 2. Ротация учетных данных для сервисов, использующих UDP. 3. Внедрение правил мониторинга аномального UDP-трафика. 4. Обновление CVE-2018-1337.
Предотвращение обнаружения	Подозрительный трафик SNMP или незашифрованные SSH пакеты сообщают об использовании T1205 с эксплуатацией CVE-2017-9000.	1. Отключение SNMP протокола 1 и 2 версии. 2. Проверка логов SNMP (/var/log/snmpd.log) 3. Анализ SSH-сессий через last и journalctl -u sshd 4. Принудительное использование SSHv2: echo "Protocol 2" >> /etc/ssh/sshd_config systemctl restart sshd	1. Отключение ненужных SNMP-сервисов. 2. Внедрение VPN вместо прямого SSH-доступа. 3. Настройка MFA для SSH. 4. Обновление версии для устранения CVE-2017-9000.
Обнаружение	Активное использование SNMP протокола сигнализирует о применение техники T1046 с эксплуатацией уязвимости CVE-2017-1000362.	1. Ограничение SNMP-доступа только доверенным IP: snmpd -V 3 -A <strong_password> -a SHA -X AES. 2. Добавление правил в iptables: iptables -A INPUT -p udp --dport 161 -j DROP	1. Смена community-строк. 2. Аудит конфигураций сетевого оборудования. 3. Внедрение SNMPv3 с шифрованием. 4. Обновление net-snmp для устранения CVE-2017-1000362.

Продолжение таблицы Б 1

1	2	3	4
Организация управления	Подозрительное использование нестандартных ICMP кодов сигнализирует о применении техники T1095 с эксплуатацией уязвимости CVE-2019-11991.	1. Блокировка нестандартных ICMP-типов: iptables -A INPUT -p icmp --icmp-type 255 -j DROP 2. Отключение ICMP протокола на сетевых узлах.	1. Настройка корректных ICMP-правил. 2. Мониторинг ICMP-трафика. 3. Проверка систем на наличие ICMP-туннелей. 4. Обновление сетевого стека для устранения CVE-2019-11991
Деструктивное воздействие	В случае получения доступа к узлу по сети это указывает на использование техники T1498 с эксплуатацией уязвимости CVE-2016-7404.	1. Проверка процессов через ps auxf. 2. Анализ сетевых соединений netstat -tulpn 3. Поиск руткитов через rkhunter --checkall	1. Полное переразвертывание системы 2. Глубокий аудит безопасности 3. Внедрение HIDS (OSSEC, Wazuh) 4. Обновление ПО для устранения CVE-2016-7404

Таблица Б 2 – Организационно-правовой регламент шаблона атаки CAPEC-299

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Разведка	Частые запросы TCP протокола в сети без окончания соединения сигнализируют о использовании техники T1590.004 с эксплуатацией уязвимости CVE-2017-11510.	1. Мониторинг через netstat -antp | grep SYN_RECV 2. Анализ трафика с помощью tcpdump -n "tcp[tcpflags] & (tcp-syn) != 0 and tcp[tcpflags] & (tcp-ack) = 0" 3. Проверка логов IDS/IPS 4. Ограничение числа SYN-запросов: iptables -A INPUT -p tcp --syn -m limit --limit 1/s -j ACCEPT	1. Аудит открытых портов. 2. Настройка геофильтрации для критичных сервисов. 3. Внедрение DDoS-защиты. 4. Обновление сетевого стека для устранения CVE-2017-11510

Продолжение таблицы Б 2

1	2	3	4
Выполнение	Частое обращение к клиентской основе сигнализирует о использовании техники T1203 с эксплуатацией уязвимости CVE-2018-14328.	1. Настройка изолированной части сети посредстовм применения зон на NGFW. 2. Поиск SQL-инъекций через grep -r "union select" /var/log/	1. Аудит всех SQL-запросов 2. Внедрение параметризованных запросов 3. Настройка ограничений доступа к БД 4. Обновление СУБД для устранения CVE-2018-14328
Предотвращение обнаружения	В случае если до загрузки ОС генерируется огромный сетевой трафик это показывает, что используется техника T1542 с эксплуатацией уязвимости CVE-2017-13664.	1. Отключение PXE и других сетевых загрузок в BIOS. 2. Проверка DHCP-логов. 3. Анализ сетевых карт на предмет нестандартного ПО.	1. Отключение ненужных сетевых загрузок. 2. Внедрение UEFI с цифровой подписью. 3. Мониторинг трафика на уровне коммутаторов. 4. Устранение CVE-2017-13664.
Обнаружение	Появление огромного потока данных TCP SYN пакетов показывают, что используется техника T1049 с эксплуатацией уязвимости CVE-2023-43791	1. Анализ через ss -ant | grep SYN-RECV | wc -l 2. Настройка алертов при превышении порога 3. Включение защиты на маршрутизаторах: echo 1 > /proc/sys/net/ipv4/tcp_syncookies	1. Настройка SYN-прокси 2. Аудит сетевой инфраструктуры 3. Планирование отказоустойчивости. 4. Обновление сетевого ПО для устранения CVE-2023-43791
Деструктивное воздействие	В случае получения доступа к узлу по сети это указывает на использование техники T1498 с эксплуатацией уязвимости CVE-2016-1112	1. Отключение сетевого потока set link down. 2. Проверка last, lastb 3. Анализ целостности файлов: rpm -Va	1. Смена всех учетных данных. 2. Внедрение SELinux/AppArmor. 3. Настройка централизованного логирования. 4. Обновление для устранения CVE-2016-1112.

Таблица Б 3 – Организационно-правовой регламент вектора атаки CAPEC-618

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Разведка	Частые широковещательные запросы сигнализируют о применении техники T1590.001 с эксплуатацией уязвимостей CVE-2016-1265 иCVE-2017-5158.	1. Ограничение широковещательных запросов посредством команды iptables -A INPUT -m pkttype --pkt-type broadcast -j DROP. 2. Настройка портов коммутаторов в режим no broadcast.	1. Обновление сетевых служб для устранения CVE-2016-1265. 2. Обновление SQL для устранения CVE-2017-5158. 3. Внедрение сегментации сети для минимизации воздействия.
Предотвращение обнаружения	Генерация деструктивного сетевого трафика до загрузки ОС посредством техники T1542 с эксплуатацией уязвимостей CVE-2017-11510 и CVE-2024-1222.	1. Отключение PXE в BIOS/UEFI. 2. Отключение ненужных сетевых загрузок. 3. Настройка Secure Boot командой mokutil --enable-validation.	1. Обновление прошивки для устранения CVE-2017-11510. 2. Обновление CMS-фреймворков для устранения CVE-2024-1222. 3. Внедрение цифровой подписи для всех загрузочных образов.
Обнаружение	Нестандартное использование протоколов управления (Telnet, SNMP) в результате применения техники T1046 с эксплуатацией уязвимостей CVE-2017-11510 иCVE-2017-3972.	1. Настройка Fail2Ban для SSH командой apt install fail2ban systemctl enable fail2ban. 2. Замена Telnet на SSH.	1. Обновление ПО для устранения CVE-2017-11510 и CVE-2017-3972. 2. Внедрение MFA для доступа. 3. Настройка ACL для ограничения доступа.
Организация управления	Несанкционированные ARP-пакеты в результате применения техники T1095 с эксплуатацией уязвимостей CVE-2019-14892 и CVE-2023-4379.	1. Включение защиты от ARP-спуфинга командой echo 1 > /proc/sys/net/ipv4/conf/all/arp_ignore. 1. 2. Настройка DHCP Snooping на коммутаторах.	1. Обновление прошивки для устранения CVE-2019-14892. 2. Обновление API для устранения CVE-2023-43791. 3. Внедрение 802.1X аутентификации.

Продолжение таблицы Б 2

1	2	3	4
Деструктивное воздействие	Отказ в обслуживании сетевого устройства при использовании техники T1498 с эксплуатацией уязвимостей CVE-2020-6170 и CVE-2020-28333.	1. Перезагрузка сетевых служб. 2. Откат к резервной конфигурации. 3. Отключить службу Windows Print Spooler. 4. Ограничить доступ к REST API 1. 5. Блокировка IP-адреса вызывающие DDoS.	1. Обновление прошивки для устранения CVE-2020-6170 и CVE-2020-28333. 2. Обновление криптографических библиотек командой sudo apt-get install --only-upgrade openssl. 3. Внедрение мониторинга доступности (Nagios, Zabbix). 4. Планирование отказоустойчивости 5. Обновить пароли и сертификаты.